

POLITIQUE DE SÉCURITÉ DES SYSTÈMES D'INTELLIGENCE ARTIFICIELLE

PSSI IA — Version 3.0

Document consolidé

Groupe [Nom]

Protection sociale

Classification	CONFIDENTIEL — Diffusion interne
Version	3.0 (refonte intégrale consolidée)
Date d'émission	Juillet 2026
Volume exigences	172 exigences (SIA-001 à SIA-172)
Approbation	Direction Générale / Comité des Risques
Propriétaire	Responsable de la Sécurité des Systèmes d'Information
Référentiels majeurs	AI Act, DORA, NIS2, ISO 42001, ISO 27090, OWASP AISVS 1.0, OWASP Agentic, OWASP GenAI Data Security 2026, NIST AI RMF, MITRE ATLAS,

	CLUSIF, CESIN
Prochaine révision	Juillet 2027 ou événement déclencheur

Table des matières

Pour afficher ou mettre à jour la table des matières dans Word : clic droit → Mettre à jour les champs, ou onglet Références → Mettre à jour la table.

1. Préambule et engagement de la Direction

1.1. Contexte et enjeux

Le Groupe [Nom], acteur de la protection sociale française, traite des données personnelles sensibles — données de santé, données sociales, données financières — pour le compte de plusieurs millions d'adhérents, assurés et bénéficiaires. La protection de ces données, le respect du secret professionnel, la continuité des prestations et la confiance des parties prenantes constituent les fondements de la mission du Groupe et de sa licence d'opérer.

L'intelligence artificielle, et singulièrement l'IA générative et les systèmes agentiques, transforme profondément le secteur de la protection sociale. Elle ouvre des opportunités d'efficacité opérationnelle, d'amélioration du service rendu aux adhérents et de maîtrise des risques, mais elle introduit également des menaces nouvelles, systémiques et potentiellement existentielles : fuites de données par exfiltration modèle, biais algorithmiques aux conséquences discriminatoires, attaques adversariales sur les pipelines d'entraînement, dépendances à des chaînes d'approvisionnement extraterritoriales non souveraines, et émergence d'un usage non maîtrisé de l'IA publique par les collaborateurs (shadow AI).

La présente politique établit le cadre de référence unique du Groupe pour le développement, l'acquisition, le déploiement, l'exploitation, la supervision et la mise hors service de tout système d'intelligence artificielle, qu'il soit interne, acquis, embarqué ou public.

1.2. Engagement de la Direction Générale

La Direction Générale du Groupe [Nom] affirme son engagement plein et entier à déployer les systèmes d'intelligence artificielle de manière responsable, sécurisée, souveraine et conforme aux obligations réglementaires européennes et françaises. Elle alloue les ressources humaines, techniques et financières nécessaires à la mise en œuvre de la présente politique, et garantit l'autorité des lignes de défense chargées de son application.

Cet engagement se décline en six principes directeurs non négociables :

- Sécurité par conception (security by design) : la sécurité est une exigence fondatrice de tout SIA et non une considération a posteriori.
- Supervision humaine (human oversight) : tout SIA intervenant dans une décision à impact matériel sur un adhérent ou un collaborateur reste sous le contrôle effectif d'un humain formé, autorisé et outillé.
- Souveraineté numérique : les données sensibles du Groupe ne transitent pas par des infrastructures extraterritoriales non maîtrisées.
- Proportionnalité des contrôles : les exigences de sécurité sont proportionnées au tier du SIA (conformité AI Act × posture AISVS).
- Transparence et traçabilité : chaque décision, chaque modèle, chaque donnée, chaque action d'agent est documenté, journalisé et auditable.
- Amélioration continue : la politique est revue annuellement, et plus fréquemment en cas d'évolution réglementaire ou d'incident majeur.

1.3. Portée et valeur contractuelle

La présente politique est opposable à l'ensemble des collaborateurs du Groupe, de ses filiales, de ses prestataires et de ses sous-traitants dans la mesure où ils interviennent dans la conception, l'acquisition, le développement, le déploiement, l'exploitation, la supervision, l'utilisation ou l'audit d'un système d'intelligence artificielle pour le compte du Groupe. Son non-respect engage la responsabilité de son auteur, conformément au chapitre 18.

Elle s'articule avec la Politique de Sécurité des Systèmes d'Information Générale (PSSIG), la Politique de Protection des Données à Caractère Personnel et les politiques sectorielles existantes. En cas de conflit, la règle la plus exigeante prévaut.

2. Champ d'application, périmètre et exclusions

2.1. Périmètre inclus

La présente politique s'applique à tous les systèmes d'intelligence artificielle, au sens défini au chapitre 3, conçus, développés, acquis, intégrés, déployés ou utilisés par le Groupe, y compris :

- Les SIA internes, conçus et développés par les équipes du Groupe.
- Les SIA acquis sous forme de logiciels sur mesure, progiciels ou services SaaS IA, y compris les API de modèles tiers.
- Les SIA embarqués dans des produits ou services tiers utilisés par le Groupe, dès lors que ces composants IA traitent des données du Groupe ou agissent pour son compte.
- Les SIA à usage général (GPAI) publics utilisés par les collaborateurs, dans les limites définies au chapitre 13.
- Les SIA en phase de recherche, d'expérimentation ou de preuve de concept (POC), avec allègements contrôlés précisés au chapitre 6.
- Les systèmes agentiques, incluant les agents conversationnels, les agents autonomes et les pipelines d'orchestration multi-agents, traités au chapitre 10.
- Les outils d'assistance à la génération de code source par IA, traités au chapitre 11.

2.2. Exclusions

Sont exclus du périmètre de la présente politique :

- Les traitements statistiques traditionnels n'impliquant pas d'apprentissage automatisé ni de modèle de type réseau de neurones ou apparenté.
- Les systèmes experts à base de règles fixes et exhaustivement programmées par un humain, sans composante adaptative.
- Les outils d'automatisation robotique des processus (RPA) sans composant IA intégré.

L'exclusion se fonde sur la définition du système d'IA retenue à l'article 3 de l'AI Act et reprise au chapitre 3. En cas de doute sur la qualification, la décision revient au Comité IA (chapitre 5), et à défaut, au RSSI.

2.3. Pratiques d'IA prohibées

Conformément à l'article 5 de l'AI Act, les pratiques suivantes sont strictement prohibées au sein du Groupe, sans exception et sans dérogation possible :

- Déploiement de techniques subliminales ou de manipulation psychologique visant à altérer substantiellement le comportement d'une personne.
- Exploitation de vulnérabilités liées à l'âge, au handicap ou à la situation sociale à des fins de manipulation.

- Notation sociale (social scoring) des personnes fondée sur le comportement social ou des caractéristiques personnelles.
- Évaluation ou prédiction du risque de commission d'infractions pénales par des personnes sur la seule base du profilage.
- Création ou extension de bases de données de reconnaissance faciale par moissonnage non ciblé.
- Reconnaissance des émotions sur les lieux de travail et dans les établissements d'enseignement.
- Catégorisation biométrique des personnes pour en déduire la race, les opinions politiques, l'appartenance syndicale, les convictions religieuses ou philosophiques, la vie sexuelle ou l'orientation sexuelle.

Toute proposition de projet comportant une fonctionnalité relevant de ces catégories est rejetée en instance de validation et fait l'objet d'une remontée au Comité des Risques et au Comité d'Éthique.

Exigences

Identifiant	SIA-001
Exigence	Le Groupe doit tenir à jour un inventaire exhaustif de ses systèmes d'intelligence artificielle, couvrant SIA internes, acquis, embarqués, publics utilisés, et SIA en POC, avec rattachement à un propriétaire métier identifié.
Référentiels sources	AI Act art. 17 ; ISO 42001 §6.2 ; CLUSIF SIA-07 ; OWASP AISVS Ch. 6
Contrôle testable / preuve	Registre central des SIA à jour consultable sur demande, avec champs minimaux : identifiant, propriétaire métier, finalité, tier AI Act, tier AISVS, statut cycle de vie, date de dernière revue.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : DSI — Approbateur : RSSI — Consulté : DPO, métiers — Informé : Comité IA
Fréquence de revue	Mise à jour en continu ; revue consolidée trimestrielle

Identifiant	SIA-002
Exigence	Le Groupe ne doit déployer ni utiliser aucun système d'IA relevant des pratiques prohibées listées à l'article 5 de l'AI Act, y compris à titre expérimental, et doit disposer d'un contrôle de conformité explicite en amont de toute validation de projet IA.
Référentiels sources	AI Act art. 5 ; CNIL recommandations IA ; ISO 42001 §4.4
Contrôle testable / preuve	Fiche de qualification AI Act signée en comité de validation de projet, attestant l'absence de pratique prohibée. Archivage de la fiche dans le dossier projet.
Tier applicable (AI Act × AISVS)	Tous tiers, sans dérogation
Rôle RACI	Responsable : chef de projet — Approbateur : Comité IA — Consulté : DPO, RSSI — Informé : Comité des Risques

Fréquence de revue	À chaque initiation de projet + revue annuelle de l'inventaire
---------------------------	--

Identifiant	SIA-003
Exigence	Tout SIA intégrant une composante d'apprentissage automatique ou de modèle statistique auto-adaptatif doit faire l'objet d'une qualification formelle (IN / OUT de périmètre) documentée par le RSSI avant tout développement ou mise en production.
Référentiels sources	AI Act art. 3 ; ISO 42001 §4.3 ; CLUSIF §1.1 ; ISO 27090 §3
Contrôle testable / preuve	Note de qualification signée, archivée dans le dossier projet, référençant la définition AI Act art. 3 et justifiant l'inclusion ou l'exclusion.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : RSSI — Consulté : DPO, architecte SI — Informé : chef de projet
Fréquence de revue	À chaque initiation de projet

3. Définitions et terminologie

Les définitions ci-dessous s'appliquent à l'ensemble de la présente politique et de ses annexes. Elles s'alignent prioritairement sur l'AI Act et la norme ISO/IEC 42001, et à défaut sur les référentiels OWASP, CLUSIF et MITRE.

En cas de divergence terminologique entre référentiels, la définition retenue privilégie, dans l'ordre : AI Act, ISO 42001, ISO 27090, OWASP AISVS, CLUSIF.

Terme	Définition	Source
SIA (Système d'Intelligence Artificielle)	Système conçu pour fonctionner avec un degré d'autonomie variable, capable, à partir des entrées qu'il reçoit, de générer des prédictions, contenus, recommandations ou décisions influençant des environnements réels ou virtuels.	AI Act art. 3(1) ; ISO 42001
GPAI (General Purpose AI Model)	Modèle d'IA à usage général, entraîné sur un large volume de données, présentant une généralité significative, capable d'accomplir de manière compétente un large éventail de tâches et pouvant être intégré dans une variété de systèmes en aval.	AI Act art. 3(63)
GPAI à risque systémique	GPAI présentant des capacités à fort impact évaluées selon les seuils de l'annexe XIII de l'AI Act (notamment puissance de calcul $> 10^{25}$ FLOPs) ou désigné comme tel par la Commission européenne.	AI Act art. 51
SIA à haut risque	SIA relevant de l'annexe III de l'AI Act ou associé à un produit couvert par la législation d'harmonisation listée à l'annexe I.	AI Act art. 6
Cycle de vie d'un SIA	Séquence itérative comportant les phases de conception, développement, données et entraînement, validation (TEVV), déploiement, exploitation-maintenance, et retrait.	ISO 42001 ; CLUSIF §1.4 ; NIST AI RMF
IA générative	Sous-ensemble de l'IA produisant du contenu (texte, image, audio, vidéo, code) à partir d'un corpus d'entraînement, généralement via un modèle à grande échelle.	OWASP GenAI ; CLUSIF §1.5
LLM (Large Language Model)	Catégorie de modèle d'IA générative entraîné sur un large corpus textuel, produisant du texte proche du langage naturel humain.	OWASP LLM Top 10
Modèle d'IA	Fonction paramétrique entraînée — typiquement un réseau de neurones avec ses poids et biais — produisant des sorties à partir d'entrées selon une représentation statistique apprise.	CLUSIF §1.7
Prompt (requête)	Instruction textuelle, structurée ou non, transmise par un utilisateur ou un système à un SIA pour obtenir une réponse.	OWASP LLM01 ; CLUSIF §1.8
Prompt système	Instruction de configuration persistante définissant le rôle, le périmètre et les contraintes d'un SIA, généralement non modifiable par l'utilisateur final.	OWASP LLM01
Attaque adversariale	Envoi de requêtes spécifiquement construites pour tromper ou altérer le fonctionnement d'un SIA, incluant evasion, poisoning, extraction et inference attacks.	MITRE ATLAS ; ISO 27090 ; CLUSIF §1.9
Prompt injection	Insertion de directives malveillantes dans un prompt ou un contexte, visant à détourner le comportement du SIA.	OWASP LLM01
Empoisonnement de données (data poisoning)	Altération intentionnelle des données d'entraînement, de fine-tuning ou de feedback, visant à induire un comportement indésirable du modèle.	OWASP LLM04 ; MITRE ATLAS AML.T0020
Fine-tuning	Spécialisation d'un modèle pré-entraîné sur un ensemble de données ciblées pour une tâche spécifique.	CLUSIF §1.16
Hallucination	Production par un modèle d'une sortie factuellement erronée ou	OWASP

Terme	Définition	Source
	non fondée sur les données disponibles.	LLM09 ; CLUSIF §1.15
Explicabilité	Capacité à rendre compréhensible les éléments ayant contribué à la production d'une sortie par un SIA.	CLUSIF §1.14 ; AI Act art. 13
Agent (IA)	SIA doté d'une capacité d'action autonome sur son environnement via des outils (tool use), avec éventuelle chaîne de décisions multi-étapes.	OWASP Agentic Security
MCP (Model Context Protocol)	Protocole standardisé permettant à un modèle d'IA d'interagir avec des serveurs fournissant des données et des outils exécutables.	OWASP AISVS Ch. 10
AI-BOM (AI Bill of Materials)	Inventaire structuré des composants d'un SIA : modèles, datasets, bibliothèques, outils, APIs, dépendances, avec versions et provenance.	OWASP AISVS Ch. 6
Model Card	Document structuré décrivant un modèle : finalité, données d'entraînement, métriques de performance, limites, risques, contact.	OWASP ; Google Model Cards
Risk Card	Document identifiant et qualifiant les conséquences négatives potentielles d'un SIA sur les utilisateurs, tiers et parties prenantes.	OWASP
Data Card	Document structuré décrivant un jeu de données : origine, licence, qualité, représentativité, sensibilité, usages recommandés et proscrits.	OWASP GenAI Data Security ; Google Data Cards
TEVV (Test, Evaluation, Verification, Validation)	Processus structuré d'évaluation de la fiabilité, de la sécurité et de la conformité d'un SIA avant et pendant son déploiement.	NIST AI RMF ; ISO 42001
Red teaming IA	Exercice offensif structuré visant à identifier les vulnérabilités d'un SIA par simulation adversariale (prompt injection, jailbreak, extraction, evasion).	MITRE ATLAS ; ISO 27090 §5.3
Shadow AI	Usage non déclaré, non référencé et non contrôlé de SIA (typiquement GPAI publics) par des collaborateurs dans un cadre professionnel.	CESIN Baromètre 2026
HITL (Human-In-The-Loop)	Schéma de supervision dans lequel un humain intervient dans la boucle décisionnelle d'un SIA, avec cinq niveaux gradués de 0 (information) à 4 (action autonome avec kill switch).	AI Act art. 14 ; OWASP AISVS Ch. 14
Kill switch	Mécanisme technique permettant l'arrêt immédiat d'un SIA ou de ses actions par un opérateur autorisé.	OWASP AISVS Ch. 9
Drift (dérive)	Évolution dans le temps des performances d'un SIA, due à un écart croissant entre la distribution des données d'entraînement et celle des données observées en production.	ISO 42001 §B.6.2.6
AIIA (AI Impact Assessment)	Évaluation d'impact dédiée à l'IA, couvrant impacts sur droits fondamentaux, santé, sécurité, discrimination.	AI Act art. 27
AIPD (Analyse d'Impact relative à la Protection des Données)	Évaluation d'impact sur la protection des données à caractère personnel obligatoire pour les traitements présentant un risque élevé.	RGPD art. 35

4. Référentiels normatifs, réglementaires et professionnels

4.1. Référentiels applicables

La présente politique s'appuie sur un corpus structuré de référentiels normatifs, réglementaires et professionnels. Chaque exigence de cette politique trace vers au moins un référentiel source identifié en annexe B (matrice de traçabilité détaillée).

Référentiel	Nature	Statut	Usage	Source
AI Act (Règlement UE 2024/1689)	Règlement européen	En vigueur (application par paliers 2024-2027)	Règles harmonisées sur l'intelligence artificielle — cadre juridique contraignant européen.	Commission européenne
RGPD (Règlement UE 2016/679)	Règlement européen	Applicable	Protection des données à caractère personnel.	CNIL
DORA (Règlement UE 2022/2554)	Règlement européen	Applicable depuis janvier 2025	Résilience opérationnelle numérique du secteur financier.	ACPR
NIS2 (Directive UE 2022/2555)	Directive européenne transposée	Applicable	Mesures pour un niveau élevé commun de cybersécurité dans l'Union.	ANSSI
HDS (Hébergeur de Données de Santé)	Certification française	Applicable (secteur santé)	Obligations applicables aux hébergeurs de données de santé à caractère personnel.	Ministère de la Santé / ANS
ISO/IEC 42001:2023	Norme certifiable	Publiée	Système de management de l'intelligence artificielle (AIMS).	ISO/IEC
ISO/IEC 27001:2022	Norme certifiable	Publiée	Système de management de la sécurité de l'information.	ISO/IEC
ISO/IEC 27701:2019	Norme certifiable	Publiée	Extension ISO 27001 pour la protection de la vie privée (PIMS).	ISO/IEC
ISO/IEC 27090 (DIS)	Guidance informative	Draft International Standard	Guidance sur les menaces de sécurité spécifiques à l'IA.	ISO/IEC
ISO/IEC 29119-11	Norme en développement	Discussion	Testing des systèmes fondés sur l'IA.	ISO/IEC
ETSI prEN 304 223	Norme européenne certifiable (draft)	En développement	Exigences certifiables en cybersécurité de l'IA (13 principes, verbes shall / should).	ETSI
prEN 18282 (CEN-CENELEC JTC 21)	Norme européenne harmonisée	En développement	Presumption of conformity AI Act pour SIA à haut risque.	CEN-CENELEC
NIST AI RMF 1.0	Framework volontaire	Publié (2023)	Gestion des risques IA (fonctions Govern, Map, Measure, Manage).	NIST
NIST AI 100-2e2023	Rapport technique	Publié	Taxonomie des attaques sur l'apprentissage automatique (AML).	NIST
OWASP Top 10 for LLM	Référentiel	Publié 2025	Dix risques majeurs des	OWASP

Référentiel	Nature	Statut	Usage	Source
Applications	professionnel		applications LLM.	
OWASP Agentic Security Initiative	Référentiel professionnel	Publié	Sécurité des systèmes agentiques.	OWASP
OWASP GenAI Data Security (2026)	Référentiel professionnel	Publié 2026	Sécurité du pipeline data de l'IA générative.	OWASP
OWASP AISVS 1.0	Référentiel professionnel	Publié	Standard de vérification sécurité IA en 14 chapitres.	OWASP
MITRE ATLAS	Base de connaissances	Maintenue	Tactiques, techniques et procédures adversariales contre les SIA.	MITRE
MIT AI Risk Repository	Base de connaissances	Publiée	Taxonomie consolidée des risques IA issus de la littérature.	MIT
Référentiel CLUSIF — Modèle de PSSI IA	Guide sectoriel français	Publié février 2025	Modèle de politique de sécurité IA pour organisations françaises.	CLUSIF
Baromètre CESIN	Publication professionnelle	Édition 2026	État de la cybersécurité en France, priorités et tendances.	CESIN
Recommandations ANSSI IA	Guides officiels	Publiés	Guides de sécurisation des systèmes d'IA.	ANSSI
Recommandations CNIL IA	Positions doctrinales	Publiées	Recommandations relatives à l'IA et à la protection des données.	CNIL

4.2. Distinction guidance informative vs exigences certifiables

Une distinction opérationnelle critique gouverne l'usage des référentiels par le Groupe :

- ISO 27090, NIST AI RMF, MIT AI Risk Repository, OWASP et CLUSIF sont des référentiels informatifs ou professionnels. Ils n'établissent pas d'exigences certifiables au sens strict, mais fournissent une base solide pour la modélisation des menaces, la gouvernance des risques et la définition des contrôles.
- ISO 42001 et ISO 27001 sont des normes certifiables (certification par tierce partie accréditée).
- ETSI prEN 304 223 (en développement) contient des exigences normatives (verbes shall / should) et ouvrira la voie à la certification cybersécurité IA.
- prEN 18282 (en développement CEN-CENELEC) fournira la presumption of conformity avec l'AI Act pour les SIA à haut risque.
- L'AI Act, le RGPD, DORA, NIS2 et le cadre HDS établissent des obligations juridiques contraignantes.

4.3. Position du Groupe

Le Groupe utilise ISO 27090, NIST AI RMF et la suite OWASP comme références informatives pour l'identification des menaces et la définition des contrôles techniques, tout en se préparant à la certification ISO 42001 à horizon 2027 et à la conformité AI Act haut risque à l'échéance d'août 2026 via prEN 18282 lorsque celle-ci sera publiée. L'adoption d'ETSI prEN 304 223

pour une éventuelle certification cybersécurité IA est évaluée en fonction de la disponibilité du schéma.

5. Gouvernance, organisation et RACI

5.1. Principes directeurs

La gouvernance IA du Groupe repose sur quatre principes issus du NIST AI RMF (fonction Govern), d'ISO 42001 §5 et des recommandations CESIN :

- Séparation des responsabilités : les fonctions d'approbation, de conception, de contrôle et d'audit sont portées par des acteurs distincts.
- Triple ligne de défense : opérationnelle (1re), risque et conformité (2e), audit interne (3e).
- Intégration au SMSI et à la PSSIG existants, avec renvois explicites pour éviter les doublons.
- Supervision humaine effective sur tous les SIA à impact, conformément à l'article 14 de l'AI Act.

5.2. Instances de gouvernance

Cinq instances structurent la gouvernance IA du Groupe :

- Direction Générale — sponsoring stratégique, validation de la politique, arbitrage des dérogations majeures.
- Comité des Risques — validation annuelle de la politique, revue des incidents critiques, pilotage du budget IA sécurité.
- Comité IA (AI Risk Committee) — instance opérationnelle mensuelle, validation des projets IA, traitement des exceptions et dérogations, revue des incidents majeurs.
- Comité d'Éthique IA — consultatif, saisi sur les projets présentant un risque éthique marqué (discrimination potentielle, impact sur droits fondamentaux).
- Cellule de Crise IA — mobilisable sur incident critique, réunit RSSI, DPO, DSI, Direction Juridique et Direction de la Communication.

5.3. Rôles et RACI

Le tableau ci-dessous formalise les rôles structurants. La matrice RACI détaillée par processus est fournie en annexe D.

Fonction	Rôle sécurité IA	Autorité principale
Direction Générale	Executive Sponsor IA, validation stratégique	Décision finale, arbitrage
Comité des Risques	Validation politique, pilotage stratégique des risques	Approbation annuelle
Comité IA	Pilotage opérationnel, validation projets, exceptions	Décision projets et dérogations
RSSI	Owner politique SIA, threat modeling, red teaming, réponse incident	Droit de veto sécurité
DPO	Conformité RGPD, AI Act, AIIA, droits des personnes	Droit de veto conformité
DSI	Architecture, infrastructure, déploiement, AI-BOM	Décision technique

Fonction	Rôle sécurité IA	Autorité principale
Model Steward	Gardien des modèles : Model Card, Risk Card, évaluations TEVV, drift	Validation modèle avant mise en production
Data Steward	Gardien des données : qualité, lineage, consentement, minimisation	Validation données d'entraînement
Propriétaire métier SIA	Responsable fonctionnel du SIA, owner de la finalité et du ROI	Décision d'usage
Audit interne	3e ligne de défense, audit design et operating effectiveness	Audit indépendant
Direction Juridique	Qualification AI Act, contrats fournisseurs, gestion des litiges IA	Avis juridique liant

5.4. Exigences de gouvernance

Identifiant	SIA-004
Exigence	Le Groupe doit disposer d'une instance Comité IA formellement mandatée, se réunissant au moins mensuellement, disposant d'un règlement intérieur, d'un quorum défini et d'une capacité décisionnelle opposable.
Référentiels sources	ISO 42001 §5.1 ; NIST AI RMF Govern ; CESIN 2026
Contrôle testable / preuve	Règlement intérieur signé, calendrier et comptes-rendus archivés sur la période glissante de 24 mois, matrice de décisions prises.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : Président du Comité IA — Approbateur : Direction Générale — Consulté : RSSI, DPO, DSI — Informé : Comité des Risques
Fréquence de revue	Revue annuelle du mandat ; mensuelle pour l'activité

Identifiant	SIA-005
Exigence	Tout projet SIA doit être soumis au Comité IA pour validation avant passage en phase de développement, avec dossier comportant : qualification AI Act, classification tier, AIPD le cas échéant, Model Card prévisionnelle, Risk Card prévisionnelle, plan de tests TEVV.
Référentiels sources	AI Act art. 9, 27 ; ISO 42001 §6 ; CLUSIF SIA-03
Contrôle testable / preuve	Dossier projet archivé avec procès-verbal de validation Comité IA ; traçabilité de la décision et des conditions imposées.
Tier applicable (AI Act × AISVS)	Tous tiers ; dossier allégé pour tier AISVS L1 non haut risque
Rôle RACI	Responsable : chef de projet — Approbateur : Comité IA — Consulté : RSSI, DPO, Model Steward — Informé : métiers
Fréquence de revue	Initiation projet + revues d'étape

Identifiant	SIA-006
-------------	---------

Exigence	Chaque SIA doit avoir un propriétaire métier nommément désigné, responsable de la finalité, du ROI, de la conformité d'usage et porteur ultime de la décision de retrait. Le propriétaire métier ne peut être une fonction support ni la DSI.
Référentiels sources	ISO 42001 §5.3 ; AI Act art. 26
Contrôle testable / preuve	Nomination formalisée dans le registre central des SIA (SIA-001) ; lettre de mission ou équivalent.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : directeur métier de rattachement — Approbateur : Comité IA — Informé : RSSI, DPO
Fréquence de revue	À l'initiation ; revue annuelle

Identifiant	SIA-007
Exigence	Le RSSI doit disposer d'un droit de veto effectif et opposable sur la mise en production de tout SIA pour motif de sécurité, sans que ce veto ne puisse être levé par une instance autre que le Comité des Risques après avis circonstancié.
Référentiels sources	ISO 27001 §5.3 ; ISO 42001 §5.3 ; ANSSI gouvernance
Contrôle testable / preuve	Politique du Groupe mentionnant explicitement ce droit de veto ; procès-verbaux des cas où il a été exercé (le cas échéant).
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : RSSI — Approbateur : Direction Générale — Informé : Comité des Risques, Comité IA
Fréquence de revue	Revue annuelle du mandat

Identifiant	SIA-008
Exigence	Le DPO doit disposer d'un droit de veto effectif et opposable sur la mise en production de tout SIA pour motif de non-conformité au RGPD, à l'AI Act ou à toute autre exigence de protection des données, selon le même régime que SIA-007.
Référentiels sources	RGPD art. 38-39 ; AI Act art. 27 ; ISO 27701
Contrôle testable / preuve	Politique du Groupe mentionnant explicitement ce droit de veto ; procès-verbaux des cas où il a été exercé.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : DPO — Approbateur : Direction Générale — Informé : Comité des Risques, Comité IA
Fréquence de revue	Revue annuelle du mandat

Identifiant	SIA-009
Exigence	Pour chaque SIA de tier AISVS L2 ou L3, un Model Steward et un Data Steward distincts doivent être nominativement désignés, indépendants des équipes de développement, chargés respectivement du suivi du modèle et des données sur l'ensemble du cycle de vie.
Référentiels sources	ISO 42001 §5.3 ; OWASP AISVS Ch. 1 et 3
Contrôle testable / preuve	Nominations formalisées dans le registre central ; lettres de mission ; évaluation annuelle de l'exercice de la fonction.
Tier applicable (AI Act × AISVS)	AISVS L2 et L3
Rôle RACI	Responsable : DSI (Model Steward), Data Office (Data Steward) — Approbateur : Comité IA — Informé : RSSI, DPO
Fréquence de revue	Nomination à l'initiation ; revue annuelle

Identifiant	SIA-010
Exigence	Toute dérogation à la présente politique doit faire l'objet d'une demande formelle motivée, instruite par le RSSI et le DPO, validée par le Comité IA pour les dérogations tier AISVS L1-L2 et par le Comité des Risques pour les dérogations tier AISVS L3 ou AI Act haut risque. La dérogation est temporaire, datée, chiffrée et assortie de mesures compensatoires.
Référentiels sources	ISO 27001 §6.1 ; ISO 42001 §6.1 ; ANSSI
Contrôle testable / preuve	Registre des dérogations tenu par le RSSI, avec motif, durée, mesures compensatoires, date de revue, date de clôture.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : RSSI — Approbateur : Comité IA ou Comité des Risques selon tier — Consulté : DPO, métier — Informé : Audit interne
Fréquence de revue	À la demande ; revue trimestrielle du registre

Identifiant	SIA-011
Exigence	La Direction Générale doit allouer annuellement un budget dédié à la sécurité IA, distinct du budget cyber général, couvrant formation, outillage, red teaming, audit et incident response. Le dimensionnement est proposé par le RSSI sur la base du portefeuille SIA, des priorités de risques et des jalons réglementaires applicables.
Référentiels sources	CESIN 2026 ; NIST AI RMF Govern ; ISO 42001 §7.1
Contrôle testable / preuve	Ligne budgétaire identifiée dans le budget annuel validé par la Direction Générale ; rapport d'exécution budgétaire semestriel.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Approbateur : Direction Générale — Informé : Comité des Risques

Fréquence de revue	Annuelle
---------------------------	----------

Identifiant	SIA-012
Exigence	L'Audit interne doit conduire annuellement un audit de conformité à la présente politique couvrant au moins : gouvernance, tiering, cycle de vie d'un échantillon représentatif de SIA, gestion des incidents, registre des dérogations, supply chain IA.
Référentiels sources	ISO 42001 §9.2 ; DORA art. 6 ; ISO 27001 §9.2
Contrôle testable / preuve	Plan d'audit IA annuel ; rapport d'audit diffusé au Comité des Risques ; plan d'action assorti de dates et responsables.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : Audit interne — Approbateur : Comité des Risques — Consulté : RSSI, DPO — Informé : Comité IA
Fréquence de revue	Annuelle

Identifiant	SIA-013
Exigence	La Cellule de Crise IA doit être activable sous 30 minutes ouvrées et sous 2 heures non ouvrées, disposer de procédures écrites, d'un annuaire de crise à jour et d'exercices de simulation au moins semestriels.
Référentiels sources	ISO 27001 §5.29 ; DORA art. 11 ; NIS2 art. 21 ; AI Act art. 73
Contrôle testable / preuve	Procédures écrites, annuaire à jour testé trimestriellement, rapports d'exercices semestriels, temps d'activation mesuré.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Approbateur : Direction Générale — Consulté : DPO, DSI, Juridique, Communication — Informé : Comité des Risques
Fréquence de revue	Exercice semestriel ; revue annuelle des procédures

6. Tiering des SIA — matrice AI Act × AISVS

6.1. Principe du tiering à deux dimensions

Le tiering des SIA du Groupe repose sur une matrice à deux dimensions orthogonales et non substituables. La première dimension reflète la conformité externe imposée par l'AI Act ; la seconde dimension reflète la posture de sécurité interne choisie par le Groupe selon l'exposition au risque. Un SIA peut donc être classé AI Act « risque limité » tout en étant positionné AISVS L3 pour des raisons internes (sensibilité des données, criticité métier, exposition publique).

Cette double axe permet au Groupe de répondre aux obligations légales minimales tout en se dotant d'une posture de sécurité adaptée à son secteur et à ses valeurs.

6.2. Dimension 1 — Conformité externe AI Act

Niveau AI Act	Description	Référence
Pratiques prohibées	Systèmes listés à l'art. 5 (interdits sans exception)	AI Act art. 5
Haut risque	Systèmes de l'annexe III ou associés à des produits annexe I	AI Act art. 6
GPAI à risque systémique	Modèles puissants (seuils annexe XIII) ou désignés par la Commission	AI Act art. 51
GPAI	Modèles d'IA à usage général n'atteignant pas le seuil systémique	AI Act art. 3(63)
Risque limité (art. 50)	Systèmes soumis à obligations de transparence (chatbots, deepfakes)	AI Act art. 50
Risque minimal	Tout autre SIA, hors obligations spécifiques	AI Act

6.3. Dimension 2 — Posture interne AISVS

Niveau AISVS	Description	SIA typiques
L1 (Baseline)	Contrôles essentiels de base : inventaire, logging, RBAC générique	SIA internes basse sensibilité, outils de productivité, POC
L2 (Standard)	Contrôles standards : Model Card, Risk Card, TEVV, DLP, RBAC granulaire, monitoring avancé	SIA de production, SIA customer-facing, SIA traitant des PII
L3 (Advanced)	Contrôles avancés : red teaming, audit indépendant, HITL renforcé, kill switch, circuit breakers, zero-trust	SIA critiques, SIA santé, SIA financier adhérent, SIA décisionnel

6.4. Matrice de tiering consolidée

La matrice ci-dessous présente la combinatoire des deux dimensions. La cellule cible détermine le socle de contrôles applicable, détaillé dans les chapitres 7 à 14 et synthétisé en annexe G.

Cellule	AI Act × AISVS	Socle applicable
Cellule bloquante	Pratiques prohibées × tout AISVS	Interdit — rejet systématique

Cellule	AI Act × AISVS	Socle applicable
Cellule critique	Haut risque × L3	Ensemble des contrôles ch. 7-14 + audit indépendant + red teaming trimestriel
Cellule renforcée	Haut risque × L2 / GPAI systémique × L2-L3	Ensemble des contrôles ch. 7-14, red teaming semestriel
Cellule standard	Risque limité × L2 / GPAI × L2	Contrôles ch. 7-14 adaptés au tier L2
Cellule allégée	Risque minimal × L1 / Risque limité × L1	Baseline ch. 7 + gouvernance ch. 5
Cellule transparence	Risque limité (art. 50) × tout AISVS	Obligations spécifiques ch. 13 + contrôles du tier AISVS

Règle d'élévation automatique : tout SIA relevant de l'AI Act haut risque est classé au minimum AISVS L2 ; tout SIA traitant des données de santé ou des données financières adhérentes est classé au minimum AISVS L3 (voir SIA-016).

Exigences du chapitre 6

Identifiant	SIA-014
Exigence	Tout SIA doit être classé selon la typologie de conformité externe de l'AI Act : pratiques prohibées (art. 5), haut risque (art. 6 + annexe III), GPAI à risque systémique (art. 51), GPAI (art. 3(63)), risque limité relevant de transparence (art. 50), ou risque minimal. Le classement est documenté et opposable.
Référentiels sources	AI Act art. 3, 5, 6, 50, 51 ; prEN 18282
Contrôle testable / preuve	Fiche de qualification AI Act archivée, référençant explicitement l'article ou l'annexe applicable, et signée par DPO et Direction Juridique.
Tier applicable (AI Act × AISVS)	Méta-exigence — classification initiale
Rôle RACI	Responsable : DPO — Approbateur : Comité IA — Consulté : Direction Juridique, métier — Informé : RSSI
Fréquence de revue	À l'initiation projet, puis revue annuelle

Identifiant	SIA-015
Exigence	Tout SIA doit être classé selon la posture de sécurité interne sur l'échelle AISVS : Level 1 (baseline), Level 2 (standard), ou Level 3 (advanced), indépendamment de sa qualification AI Act. Le classement reflète l'exposition interne et le besoin de contrôles.
Référentiels sources	OWASP AISVS 1.0 ; ISO 42001 §6.1 ; CESIN 2026
Contrôle testable / preuve	Fiche de classification AISVS avec justification fondée sur sensibilité des données, autonomie décisionnelle, exposition publique, criticité métier.
Tier applicable (AI Act × AISVS)	Méta-exigence — classification initiale
Rôle RACI	Responsable : RSSI — Approbateur : Comité IA — Consulté : métier, DPO — Informé : Audit interne
Fréquence de revue	À l'initiation projet, puis revue annuelle

Identifiant	SIA-016
Exigence	Le tier applicable à un SIA est déterminé par la matrice à deux dimensions (AI Act × AISVS) publiée par le RSSI. La cellule cible définit le socle de contrôles minimum applicable. Tout SIA relevant de l'AI Act haut risque est automatiquement classé au minimum AISVS L2 ; tout SIA traitant des données de santé ou financières adhérents est automatiquement classé AISVS L3.
Référentiels sources	AI Act art. 9 ; OWASP AISVS ; NIST AI RMF Map
Contrôle testable / preuve	Matrice AI Act × AISVS diffusée et référencée dans le registre central ; règles d'élévation automatique documentées.
Tier applicable (AI Act × AISVS)	Méta-exigence — règle de décision
Rôle RACI	Responsable : RSSI — Approbateur : Comité IA — Consulté : DPO — Informé : métier
Fréquence de revue	Matrice revue annuellement

Identifiant	SIA-017
Exigence	Le tier déterminé par la matrice doit être propagé automatiquement sur l'ensemble des exigences applicables du cycle de vie via le registre central. Les chapitres 7 à 14 listent, pour chaque exigence, les tiers pour lesquels elle est applicable.
Référentiels sources	ISO 42001 §6.1 ; OWASP AISVS
Contrôle testable / preuve	Registre central affichant pour chaque SIA la liste des exigences applicables dérivées du tier ; outil GRC à jour.
Tier applicable (AI Act × AISVS)	Méta-exigence — propagation
Rôle RACI	Responsable : RSSI — Consulté : Audit interne — Informé : métier
Fréquence de revue	Continue — alerte automatique sur changement de tier

Identifiant	SIA-018
Exigence	Le tier doit être réévalué à la survenue de tout événement déclencheur : changement de finalité, extension de périmètre d'utilisateurs ou de données, incident de sécurité majeur ou critique, évolution réglementaire, modification substantielle du modèle, ou au plus tard tous les douze mois.
Référentiels sources	AI Act art. 9(2) ; ISO 42001 §9.3 ; NIST AI RMF Manage
Contrôle testable / preuve	Journal des re-classifications dans le registre central avec motif, date, ancien et nouveau tier.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : RSSI — Approbateur : Comité IA — Informé : métier, DPO
Fréquence de revue	À événement + revue annuelle systématique

Identifiant	SIA-019
Exigence	Le tier de chaque SIA doit être publié dans le registre central et communiqué aux équipes opérationnelles, au propriétaire métier, au Model Steward, au Data Steward et aux éventuels fournisseurs impactés. Le tier n'est pas confidentiel en interne.
Référentiels sources	ISO 42001 §7.4 ; CESIN 2026
Contrôle testable / preuve	Registre central avec colonne tier visible ; notification formalisée aux acteurs RACI lors d'une classification ou re-classification.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : RSSI — Informé : propriétaire métier, Stewards, fournisseur
Fréquence de revue	À chaque classification ou changement

Identifiant	SIA-020
Exigence	Le Groupe doit publier annuellement un rapport consolidé de tiering présentant la distribution des SIA par cellule de la matrice AI Act × AISVS, les re-classifications de l'année, les SIA retirés, et les tendances d'évolution du portefeuille IA.
Référentiels sources	ISO 42001 §9.3 ; NIST AI RMF Govern
Contrôle testable / preuve	Rapport annuel présenté au Comité des Risques et annexé au rapport RSSI.
Tier applicable (AI Act × AISVS)	Gouvernance
Rôle RACI	Responsable : RSSI — Approbateur : Comité des Risques — Informé : Comité IA, DG
Fréquence de revue	Annuelle

7. Exigences de sécurité par phase du cycle de vie

Le cycle de vie d'un SIA est décomposé en sept phases non strictement séquentielles : conception, développement, données et entraînement, validation TEVV, déploiement, exploitation et maintenance, retrait. Chaque phase porte des exigences propres, dont l'applicabilité dépend du tier déterminé au chapitre 6.

Les phases peuvent se dérouler de manière itérative. La décision de retrait peut intervenir à tout moment sur décision du Comité IA ou du propriétaire métier avec validation RSSI et DPO.

7.1. Phase 1 — Conception

La phase de conception pose les fondations du SIA : compréhension du besoin métier, modélisation des menaces, arbitrage make/buy/API, sélection du modèle et définition de l'architecture zero-trust. Toute lacune de cette phase se propage dans l'ensemble du cycle de vie.

Identifiant	SIA-021
Exigence	Tout SIA doit faire l'objet d'un threat modeling formel en phase de conception, couvrant au minimum les cinq catégories d'attaques de l'AML selon ISO 27090 : evasion, poisoning, extraction, inference et failure. Le threat model utilise MITRE ATLAS comme taxonomie de référence.
Référentiels sources	ISO 27090 §5.2 ; MITRE ATLAS ; CLUSIF SIA-03 ; OWASP AISVS Ch. 11 ; AI Act art. 9
Contrôle testable / preuve	Rapport de threat modeling archivé, référençant les TTPs ATLAS retenues, mis à jour à chaque évolution majeure.
Tier applicable (AI Act × AISVS)	AISVS L1-L3 ; obligation renforcée L2-L3
Rôle RACI	Responsable : RSSI — Consulté : architectes IA, Model Steward — Informé : Comité IA
Fréquence de revue	À l'initiation + à chaque évolution substantielle

Identifiant	SIA-022
Exigence	Tout SIA relevant de l'AI Act haut risque ou traitant des données RGPD art. 9 doit faire l'objet d'une AIIA (AI Impact Assessment) et d'une AIPD (Analyse d'Impact relative à la Protection des Données) coordonnées, validées avant la phase de développement.
Référentiels sources	AI Act art. 27 ; RGPD art. 35 ; CNIL
Contrôle testable / preuve	AIIA et AIPD signées par DPO et Comité IA, archivées dans le dossier projet.
Tier applicable (AI Act × AISVS)	AI Act haut risque ; AISVS L2-L3 ; données RGPD art. 9
Rôle RACI	Responsable : DPO — Approbateur : Comité IA — Consulté : RSSI, métier — Informé : Direction Juridique

Fréquence de revue	Initiation + mise à jour en cas d'évolution substantielle
---------------------------	---

Identifiant	SIA-023
Exigence	L'architecture d'un SIA devrait appliquer les principes zero-trust : authentification forte de tous les appels au modèle, micro-segmentation réseau, moindre privilège appliqué aux pipelines de training et d'inférence, chiffrement en transit et au repos.
Référentiels sources	ISO 27090 ; ANSSI zero-trust ; NIST SP 800-207
Contrôle testable / preuve	Dossier d'architecture référençant explicitement les principes zero-trust appliqués ; revue architecturale signée.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : architecte sécurité — Consulté : RSSI — Informé : DSI
Fréquence de revue	À la conception + revue annuelle

Identifiant	SIA-024
Exigence	La décision de construire, d'utiliser un modèle existant (avec ou sans fine-tuning) ou de consommer une API externe doit faire l'objet d'une analyse comparative documentée couvrant : posture sécurité du fournisseur, maîtrise des données, souveraineté, coûts, dépendance et réversibilité.
Référentiels sources	CLUSIF SIA-04 ; ETSI prEN 304 223 ; ANSSI supply chain
Contrôle testable / preuve	Note de décision make/buy/API archivée, citant les critères analysés et la décision justifiée.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : chef de projet — Approbateur : Comité IA — Consulté : RSSI, Direction Juridique — Informé : DSI
Fréquence de revue	À l'initiation projet

Identifiant	SIA-025
Exigence	La sélection d'un modèle doit considérer explicitement : complexité du modèle, adéquation au cas d'usage, capacité d'explicabilité, caractéristiques des datasets d'entraînement (qualité, représentativité, sensibilité, âge, diversité), provenance et chaîne d'approvisionnement. Les modèles plus simples et plus interprétables sont préférés lorsque les performances sont équivalentes.
Référentiels sources	CLUSIF §3.3.4 ; OWASP AISVS Ch. 3 ; NIST AI RMF Map
Contrôle testable / preuve	Fiche de sélection de modèle documentant les critères et la justification du choix.
Tier applicable (AI Act × AISVS)	Tous tiers

Rôle RACI	Responsable : Model Steward — Consulté : métier, RSSI — Informé : Comité IA
Fréquence de revue	À la conception + à chaque changement de modèle

7.2. Phase 2 — Développement

La phase de développement construit le SIA selon les pratiques DevSecOps applicables à l'IA : isolation des environnements, gestion des secrets, documentation vivante, pilotage de la dette technique IA.

Identifiant	SIA-026
Exigence	Les composants logiciels d'un SIA doivent être développés dans des environnements sécurisés en appliquant les pratiques DevSecOps : intégration continue avec tests de sécurité automatisés, revue de code systématique, scan de secrets, scan SAST et SCA, validation des dépendances ML.
Référentiels sources	CLUSIF SIA-05 ; ISO 27001 §8.25 ; NIST SSDF
Contrôle testable / preuve	Pipeline CI/CD outillé et documenté ; rapports de scan archivés ; exigence de passage des gates sécurité avant merge.
Tier applicable (AI Act × AISVS)	AISVS L1-L3
Rôle RACI	Responsable : lead développeur — Consulté : RSSI — Informé : DSI
Fréquence de revue	Continue ; audit annuel du pipeline

Identifiant	SIA-027
Exigence	Les environnements de recherche, de développement, de pré-production et de production doivent être strictement isolés. Aucune donnée de production ne doit être utilisée dans les environnements de développement sans anonymisation ou pseudonymisation préalable.
Référentiels sources	ISO 27001 §8.31 ; CLUSIF SIA-10 ; RGPD art. 5
Contrôle testable / preuve	Architecture réseau documentée ; contrôles d'accès séparés ; registre des accès cross-environnement limité.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Audit interne
Fréquence de revue	Continue ; revue annuelle

Identifiant	SIA-028
Exigence	Aucun secret (clé API, identifiants, tokens, poids de modèle propriétaire) ne doit être stocké en clair dans le code, les notebooks, les configurations ou les logs. Un gestionnaire de secrets centralisé doit être utilisé avec rotation automatique.

Référentiels sources	OWASP LLM07 ; ISO 27001 §8.24 ; CLUSIF SIA-05
Contrôle testable / preuve	Scan de secrets automatique en CI ; inventaire des secrets géré ; politique de rotation audité.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : lead développeur — Consulté : RSSI — Informé : DSI
Fréquence de revue	Continue

Identifiant	SIA-029
Exigence	Chaque SIA de tier AISVS L2 ou L3 doit disposer d'une Model Card, d'une Data Card et d'une Risk Card à jour, couvrant finalité, données, métriques, limites, biais connus, risques et mitigations. Les prompts systèmes sont documentés comme actifs de même rang que le modèle.
Référentiels sources	CLUSIF SIA-08 ; OWASP AISVS Ch. 1 et 3 ; AI Act Annexe IV
Contrôle testable / preuve	Templates remplis, archivés, versionnés ; revue annuelle documentée. Templates fournis en annexe E.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : Model Steward, Data Steward — Consulté : métier, RSSI — Informé : DPO
Fréquence de revue	À la mise en production + revue annuelle

Identifiant	SIA-030
Exigence	Le Groupe doit identifier, suivre et gérer activement la dette technique IA sur chaque SIA : modèles obsolètes, versions superposées non consolidées, pipelines de données non maintenus, dépendances fin de vie, documentation lacunaire. Un registre de dette technique IA doit être tenu et revu trimestriellement.
Référentiels sources	CLUSIF SIA-09 ; ISO 42001 §9.3 ; NIST AI RMF Manage
Contrôle testable / preuve	Registre de dette technique IA à jour ; plan de résorption par SIA critique ; revue trimestrielle en Comité IA.
Tier applicable (AI Act × AISVS)	AISVS L2-L3 obligatoire ; L1 recommandé
Rôle RACI	Responsable : DSI — Approbateur : Comité IA — Consulté : Model Steward, RSSI — Informé : Audit interne
Fréquence de revue	Trimestrielle

7.3. Phase 3 — Données et entraînement

La phase de données et d'entraînement garantit la qualité, la traçabilité et l'intégrité cryptographique des artefacts constitutifs du modèle. L'empoisonnement des données et la

dérive non contrôlée des jeux d'entraînement constituent des menaces structurantes du secteur.

Identifiant	SIA-031
Exigence	La provenance et le lineage de toutes les données utilisées pour l'entraînement, le fine-tuning, l'évaluation et l'augmentation contextuelle (RAG) doivent être tracés et documentés, de la source primaire jusqu'à l'ingestion dans le SIA.
Référentiels sources	OWASP AISVS Ch. 1 ; OWASP GenAI Data Security ; AI Act art. 10
Contrôle testable / preuve	Outillage de data lineage déployé ; Data Cards à jour ; vérification échantillonnée par Audit interne.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : Data Steward — Consulté : DPO — Informé : Model Steward
Fréquence de revue	Continue ; audit annuel

Identifiant	SIA-032
Exigence	Des contrôles de détection d'empoisonnement des données d'entraînement, de fine-tuning et de feedback doivent être appliqués : détection d'anomalies statistiques, vérification de cohérence, isolation des sources externes non fiables, tests de robustesse post-entraînement.
Référentiels sources	OWASP LLM04 ; MITRE ATLAS AML.T0020 ; ISO 27090
Contrôle testable / preuve	Rapport de contrôle data poisoning avant chaque cycle d'entraînement majeur ; seuils d'alerte documentés.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : Data Steward, Model Steward — Consulté : RSSI — Informé : Comité IA
Fréquence de revue	Avant chaque entraînement ; audit semestriel

Identifiant	SIA-033
Exigence	Toutes les composantes d'un SIA — modèles, poids, datasets, checkpoints, prompts systèmes, configurations — doivent être versionnées dans un système de gestion de versions dédié, permettant la reproductibilité et le retour à un état antérieur.
Référentiels sources	ISO 42001 §B.6 ; OWASP AISVS Ch. 3 ; CLUSIF SIA-08
Contrôle testable / preuve	Registre de versions à jour ; possibilité de reconstituer un état historique démontrée sur demande.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : Model Steward — Consulté : DSI — Informé : RSSI
Fréquence de revue	Continue

Identifiant	SIA-034
Exigence	Tout fichier de poids de modèle, tout dataset d'entraînement majeur et tout prompt système doit disposer d'un hachage cryptographique (SHA-256 minimum) et, pour les artefacts déployés, d'une signature cryptographique (ECDSA P-256 ou Ed25519). La vérification des signatures est automatique au chargement.
Référentiels sources	CLUSIF SIA-12 ; prEN 18282 ; ANSSI guides cryptographiques
Contrôle testable / preuve	Registre des empreintes et signatures ; vérification à chaque chargement de modèle ; alerte en cas d'écart.
Tier applicable (AI Act × AISVS)	AISVS L2-L3 ; obligation AI Act haut risque
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Audit interne
Fréquence de revue	À chaque nouveau modèle / dataset ; contrôle continu en exploitation

7.4. Phase 4 — Validation TEVV (Test, Evaluation, Verification, Validation)

La phase de validation vérifie, avant mise en production, que le SIA respecte ses objectifs fonctionnels, ses exigences de fairness, sa robustesse adversariale et, pour les tiers les plus exposés, sa résilience face à une équipe offensive dédiée.

Identifiant	SIA-035
Exigence	Avant toute mise en production, un SIA doit faire l'objet de tests fonctionnels documentés couvrant précision, rappel, cohérence, robustesse aux variations d'entrée et performance opérationnelle, avec seuils minimaux définis par le Model Steward.
Référentiels sources	NIST AI RMF Measure ; ISO 42001 §9.1 ; OWASP AISVS Ch. 13
Contrôle testable / preuve	Rapport de tests fonctionnels signé ; seuils documentés ; jeux de test conservés pour reproduction.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : Model Steward — Consulté : métier — Informé : RSSI
Fréquence de revue	Avant chaque mise en production + régression continue

Identifiant	SIA-036
Exigence	Tout SIA prenant ou influençant des décisions affectant des personnes doit faire l'objet de tests de biais et de fairness documentés (disparate impact, equalized odds, demographic parity selon le cas), avec critères d'acceptation définis et mitigations appliquées si nécessaire.
Référentiels sources	AI Act art. 10 ; NIST AI RMF ; AI Act art. 15

Contrôle testable / preuve	Rapport de fairness signé ; actions de mitigation documentées ; revue DPO.
Tier applicable (AI Act × AISVS)	AI Act haut risque ; AISVS L2-L3
Rôle RACI	Responsable : Model Steward — Consulté : DPO, métier — Informé : Comité IA
Fréquence de revue	Avant mise en production + monitoring en exploitation

Identifiant	SIA-037
Exigence	Tout SIA de tier AISVS L2 ou L3 doit faire l'objet de tests adversariaux documentés couvrant prompt injection, jailbreak, extraction, inference, evasion, en utilisant des outils reconnus (ART, CleverHans, Garak ou équivalents).
Référentiels sources	OWASP LLM01-10 ; MITRE ATLAS ; ISO 27090 §5.3
Contrôle testable / preuve	Rapport de tests adversariaux ; couverture MITRE ATLAS documentée ; remédiations appliquées avant production.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : RSSI — Consulté : Model Steward — Informé : Comité IA
Fréquence de revue	Avant mise en production + trimestrielle en exploitation pour L3

Identifiant	SIA-038
Exigence	Tout SIA de tier AISVS L3 ou AI Act haut risque doit faire l'objet d'une campagne de red teaming formelle avant mise en production, réalisée par une équipe distincte de l'équipe de développement, avec rapport opposable et plan de remédiation.
Référentiels sources	CLUSIF SIA-14 ; AI Act art. 55 (GPAI systémique) ; MITRE ATLAS
Contrôle testable / preuve	Rapport red team archivé ; remédiations tracées et validées avant go-live.
Tier applicable (AI Act × AISVS)	AISVS L3 ; AI Act haut risque ; GPAI systémique
Rôle RACI	Responsable : RSSI — Consulté : Model Steward — Informé : Comité des Risques
Fréquence de revue	Avant mise en production + trimestrielle

7.5. Phase 5 — Déploiement

La phase de déploiement conditionne le passage en production au franchissement d'un Security Gate, à la disponibilité d'un plan de rollback, de kill switch et de circuit breakers, et à la maîtrise des mises à jour sécurisées avec canarisation.

Identifiant	SIA-039
Exigence	Aucun SIA ne peut être mis en production sans franchissement documenté d'un Security Gate validant : threat model à jour, tests TEVV passés, documentation complète, plan de rollback, plan d'incident, validation RSSI et DPO.
Référentiels sources	OWASP AISVS Ch. 4 ; CLUSIF SIA-14 ; ISO 42001 §8
Contrôle testable / preuve	Checklist Security Gate signée et archivée ; blocage automatique en cas d'élément manquant.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : RSSI — Approbateur : Comité IA — Consulté : DPO, métier
Fréquence de revue	Avant chaque mise en production

Identifiant	SIA-040
Exigence	Chaque SIA de tier AISVS L2 ou L3 doit disposer d'un plan de rollback testé permettant le retour à la version stable précédente en moins de 24 heures ouvrées pour L2 et en moins de 4 heures pour L3.
Référentiels sources	ISO 42001 §8.1 ; DORA art. 11
Contrôle testable / preuve	Plan de rollback documenté ; exercice de rollback annuel pour L2, semestriel pour L3 avec chronomètre.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : DSI — Consulté : RSSI, Model Steward — Informé : métier
Fréquence de revue	Annuelle (L2) / semestrielle (L3)

Identifiant	SIA-041
Exigence	Tout SIA de tier AISVS L3, tout SIA AI Act haut risque et tout système agentique (voir ch. 10) doit disposer d'un kill switch permettant son arrêt immédiat par un opérateur autorisé, testé semestriellement.
Référentiels sources	OWASP AISVS Ch. 9 ; AI Act art. 14
Contrôle testable / preuve	Procédure documentée ; liste d'opérateurs autorisés ; test semestriel horodaté et archivé.
Tier applicable (AI Act × AISVS)	AISVS L3 ; AI Act haut risque ; agentique
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Comité IA
Fréquence de revue	Semestrielle

Identifiant	SIA-042
Exigence	Chaque SIA de tier AISVS L2 ou L3 doit disposer de circuit breakers —

	disjoncteurs automatiques limitant le volume de requêtes, le coût, la latence, le taux d'erreur ou les comportements anormaux au-delà de seuils définis.
Référentiels sources	OWASP AISVS Ch. 9 ; ISO 27001 §8.6
Contrôle testable / preuve	Seuils documentés par SIA ; alertes testées ; déclenchements historiques audités.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : DSI — Consulté : RSSI, Model Steward — Informé : métier
Fréquence de revue	Configuration à la mise en production ; revue trimestrielle des seuils

Identifiant	SIA-043
Exigence	Les mises à jour de modèles, poids, prompts systèmes et configurations doivent suivre une procédure sécurisée : tests de régression en pré-production, canarisation sur un sous-ensemble contrôlé, monitoring renforcé post-déploiement sur au moins 72 heures, et rollback automatique en cas de dégradation mesurée.
Référentiels sources	CLUSIF SIA-17 ; OWASP AISVS Ch. 4 ; ISO 42001 §8.3
Contrôle testable / preuve	Procédure documentée ; journal des mises à jour avec métriques pré- et post-déploiement ; rollbacks historiques audités.
Tier applicable (AI Act × AISVS)	AISVS L2-L3 ; L1 recommandé
Rôle RACI	Responsable : Model Steward — Consulté : DSI, RSSI — Informé : métier
Fréquence de revue	À chaque mise à jour

7.6. Phase 6 — Exploitation et maintenance

La phase d'exploitation assure la surveillance continue du comportement du SIA, la détection des dérives et des anomalies, la journalisation exhaustive et la validation des sorties. Elle constitue la phase la plus longue du cycle de vie et la plus susceptible d'exposition à des incidents réels.

Identifiant	SIA-044
Exigence	Chaque SIA en exploitation doit faire l'objet d'un monitoring continu du drift : dérive des distributions d'entrée, dérive des performances, dérive des distributions de sortie, avec seuils d'alerte et actions automatiques définies.
Référentiels sources	CLUSIF SIA-15 ; ISO 42001 §B.6.2.6 ; OWASP AISVS Ch. 13
Contrôle testable / preuve	Dashboard de monitoring opérationnel ; alertes configurées ; rapport mensuel au Model Steward.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : Model Steward — Consulté : RSSI — Informé : métier

Fréquence de revue	Continue ; revue mensuelle
---------------------------	----------------------------

Identifiant	SIA-045
Exigence	Toutes les entrées d'un SIA — requêtes, prompts, fichiers joints, contextes — doivent être journalisées de manière immuable, avec horodatage, identifiant utilisateur, identifiant session, et hachage du contenu, dans le respect du RGPD et des politiques de minimisation.
Référentiels sources	CLUSIF SIA-16 ; AI Act art. 12 ; RGPD ; ISO 27090 §5.4
Contrôle testable / preuve	Configuration de logging audité ; échantillonnage vérifié par Audit interne ; durée de conservation documentée.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : DSI — Consulté : DPO, RSSI — Informé : Audit interne
Fréquence de revue	Continue

Identifiant	SIA-046
Exigence	Un dispositif de détection d'anomalies comportementales couvrant les entrées, les sorties et les métriques internes du modèle doit être déployé sur tout SIA de tier AISVS L2 ou L3, avec escalade automatique au SOC en cas d'incident suspect.
Référentiels sources	MITRE ATLAS ; ISO 27090 §5.4 ; OWASP AISVS Ch. 13
Contrôle testable / preuve	Intégration au SIEM du Groupe ; scénarios de détection documentés ; exercices d'évaluation.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : RSSI — Consulté : Model Steward — Informé : SOC
Fréquence de revue	Continue ; revue semestrielle des scénarios

Identifiant	SIA-047
Exigence	Les sorties générées par un SIA doivent faire l'objet de validations et d'un DLP sortant adapté à la sensibilité du contexte : scan contre les exfiltrations de PII, contre les fuites de secrets, contre les contenus inappropriés, avec blocage ou mise en quarantaine selon le tier.
Référentiels sources	OWASP LLM05 ; OWASP AISVS Ch. 7 ; RGPD
Contrôle testable / preuve	Configuration DLP sortant documentée ; taux de faux positifs monitoré ; incidents audités.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : RSSI — Consulté : DPO — Informé : Model Steward
Fréquence de revue	Continue

7.7. Phase 7 — Retrait et fin de vie

Le retrait d'un SIA est un acte de gouvernance au même titre que sa mise en production. Il garantit la destruction conforme des données personnelles, la conservation sélective de la documentation légalement exigible et la capitalisation des enseignements pour les SIA futurs.

Identifiant	SIA-048
Exigence	Le retrait d'un SIA doit suivre une procédure formelle couvrant : destruction sécurisée des données (RGPD art. 17), retrait contrôlé du modèle, archivage de la documentation légalement requise, information des utilisateurs et des parties prenantes, retour d'expérience (post-mortem) et mise à jour de l'inventaire. Les modèles retirés dont les poids sont conservés en archive doivent être chiffrés et accessibles uniquement au Model Steward sur autorisation.
Référentiels sources	RGPD art. 17 ; ISO 42001 §B.6 ; NIST AI RMF Manage
Contrôle testable / preuve	Plan de retrait signé ; attestations de destruction ; rapport post-mortem ; mise à jour registre central.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : Model Steward — Approbateur : Comité IA — Consulté : DPO, RSSI, Juridique
Fréquence de revue	À la décision de retrait

8. Gestion des données pour les SIA

Les données constituent l'actif le plus sensible et le plus stratégique des SIA du Groupe. La sécurité des données pour les SIA suit les principes du pipeline OWASP GenAI Data Security 2026, articulés avec le RGPD, le cadre HDS et les recommandations CNIL.

Les exigences de ce chapitre s'appliquent transversalement à toutes les phases du cycle de vie décrites au chapitre 7, avec une attention renforcée pour les traitements de données de santé (RGPD art. 9) et de données financières adhérentes.

8.1. Principes structurants

- Data discovery exhaustive : toute donnée qui entre dans un SIA est connue, documentée et classifiée.
- Classification opérante : le niveau de sensibilité conditionne les contrôles applicables.
- Filtrage à l'entrée et validation à la sortie, couvrant prompt injection et exfiltration.
- Masquage dynamique des PII lorsque la finalité ne justifie pas l'exposition en clair.
- Provenance et lineage traçables de la source primaire à l'ingestion.
- Minimisation, consentement, durées de conservation strictement maîtrisés.
- Souveraineté et interdiction absolue de transmission aux GPAI publics pour les données adhérents.

8.2. Exigences

Identifiant	SIA-049
Exigence	Toutes les sources de données des pipelines IA — data warehouses, data lakes, vector stores, bases documentaires, APIs internes et externes — doivent être inventoriées et cartographiées dans un registre unique data-IA, maintenu en continu.
Référentiels sources	OWASP GenAI Data Security ; OWASP AISVS Ch. 1
Contrôle testable / preuve	Registre data-IA à jour ; scan automatisé trimestriel ; reconciliation avec l'AI-BOM.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : Data Steward — Consulté : DPO — Informé : RSSI
Fréquence de revue	Continue ; audit trimestriel

Identifiant	SIA-050
Exigence	Chaque dataset utilisé par un SIA doit être classifié selon l'échelle de sensibilité du Groupe (Public / Interne / Confidentiel / Secret) et selon la typologie RGPD (données courantes / sensibles art. 9 / pénales art. 10). La classification conditionne les contrôles applicables.

Référentiels sources	OWASP GenAI Data Security ; RGPD art. 9-10 ; HDS
Contrôle testable / preuve	Tags de classification appliqués ; revue échantillonnée ; cohérence avec les Data Cards.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : Data Steward — Consulté : DPO — Informé : RSSI
Fréquence de revue	À l'intégration + revue annuelle

Identifiant	SIA-051
Exigence	Les entrées transmises aux SIA doivent être filtrées en amont contre les injections de prompt, les contenus malveillants, les tentatives d'exfiltration d'instructions système, et les PII non autorisées selon le tier du SIA.
Référentiels sources	OWASP LLM01 ; OWASP GenAI Data Security ; OWASP AISVS Ch. 2
Contrôle testable / preuve	Configuration du filtre documentée ; taux de blocage et faux positifs suivis mensuellement.
Tier applicable (AI Act × AISVS)	AISVS L1-L3
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Model Steward
Fréquence de revue	Continue

Identifiant	SIA-052
Exigence	Les données personnelles transitant par un SIA doivent être masquées dynamiquement lorsque le tier ou la finalité ne justifient pas leur exposition en clair : tokenisation, pseudonymisation, k-anonymity, l-diversity selon le contexte.
Référentiels sources	RGPD art. 5 ; OWASP GenAI Data Security ; ISO 27701
Contrôle testable / preuve	Règles de masquage documentées par SIA ; audit technique du déploiement.
Tier applicable (AI Act × AISVS)	AISVS L2-L3 ; données RGPD art. 9 obligatoire
Rôle RACI	Responsable : Data Steward — Consulté : DPO — Informé : RSSI
Fréquence de revue	Continue ; audit semestriel

Identifiant	SIA-053
Exigence	Les sorties d'un SIA doivent faire l'objet d'un scan post-génération visant à détecter les fuites de données sensibles, les PII non attendues, les secrets techniques et les contenus hors politique. Les détections critiques entraînent blocage de la sortie et alerte.
Référentiels sources	OWASP LLM05 ; OWASP AISVS Ch. 7 ; DLP

Contrôle testable / preuve	DLP sortant opérationnel ; alertes loguées dans le SIEM ; revue mensuelle des incidents.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : RSSI — Consulté : DPO — Informé : Model Steward
Fréquence de revue	Continue

Identifiant	SIA-054
Exigence	La provenance de chaque donnée utilisée en entraînement ou en RAG doit être documentée dans la Data Card correspondante, incluant source primaire, date d'acquisition, licence, consentement applicable, transformations subies.
Référentiels sources	OWASP AISVS Ch. 1 ; AI Act art. 10 ; RGPD
Contrôle testable / preuve	Data Card complète ; lineage démontrable à l'audit ; absence de données non traçables en production.
Tier applicable (AI Act × AISVS)	Tous tiers ; obligation renforcée AISVS L2-L3
Rôle RACI	Responsable : Data Steward — Consulté : DPO — Informé : Audit interne
Fréquence de revue	À chaque ingestion ; revue annuelle

Identifiant	SIA-055
Exigence	Aucune donnée adhérent, patient, assuré ou bénéficiaire identifiable ou ré-identifiable ne doit être transmise à un SIA GPAI public ou à un service IA tiers hors maîtrise du Groupe, quel que soit le volume ou la finalité. Le non-respect constitue un manquement grave au sens du chapitre 18.
Référentiels sources	RGPD art. 5, 32 ; HDS ; ANSSI R34 ; AI Act art. 10
Contrôle testable / preuve	Politique technique bloquant les exports ; DLP sortant ; contrôles d'accès Internet ; sanctions documentées.
Tier applicable (AI Act × AISVS)	Tous tiers — impératif
Rôle RACI	Responsable : RSSI — Consulté : DPO, Juridique — Informé : Direction Générale
Fréquence de revue	Continue

Identifiant	SIA-056
Exigence	Les données collectées ou utilisées par un SIA doivent respecter le principe de minimisation : seules les données strictement nécessaires à la finalité déclarée sont collectées, traitées et conservées. Les finalités non explicitement déclarées sont interdites.
Référentiels sources	RGPD art. 5(1)(c) ; AI Act art. 10

Contrôle testable / preuve	AIPD documentant la minimisation ; revue annuelle des données utilisées.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : DPO — Consulté : Data Steward, métier — Informé : RSSI
Fréquence de revue	À la conception + revue annuelle

Identifiant	SIA-057
Exigence	Le traitement de données de santé par un SIA doit disposer de la base légale adéquate au sens du RGPD art. 9(2), s'effectuer sur infrastructure certifiée HDS, et faire l'objet d'une AIPD spécifique santé validée par le DPO et le médecin-conseil lorsque pertinent.
Référentiels sources	RGPD art. 9 ; HDS ; Code de la santé publique ; AI Act art. 10
Contrôle testable / preuve	Base légale documentée ; certification HDS hébergeur vérifiée ; AIPD santé archivée.
Tier applicable (AI Act × AISVS)	Données de santé — tous tiers
Rôle RACI	Responsable : DPO — Approbateur : Comité IA — Consulté : médecin-conseil, Juridique — Informé : RSSI
Fréquence de revue	À l'initiation + revue annuelle

Identifiant	SIA-058
Exigence	Les datasets d'entraînement comportant des données personnelles devraient être anonymisés ou pseudonymisés par défaut, sauf nécessité démontrée d'utilisation en clair documentée dans l'AIPD.
Référentiels sources	RGPD art. 4(5), 25 ; CNIL guide anonymisation
Contrôle testable / preuve	Data Card précisant l'état des données ; justification en AIPD si données en clair.
Tier applicable (AI Act × AISVS)	Tous tiers ; impératif AISVS L3
Rôle RACI	Responsable : Data Steward — Consulté : DPO — Informé : Model Steward
Fréquence de revue	À l'ingestion ; revue annuelle

Identifiant	SIA-059
Exigence	Les durées de conservation des données utilisées par les SIA — données d'entraînement, embeddings, logs de prompts, feedbacks — doivent être définies par finalité, documentées, et faire l'objet de purges automatiques à l'échéance. Aucune donnée personnelle ne doit être conservée au-delà de la finalité.
Référentiels sources	RGPD art. 5(1)(e) ; HDS ; CNIL

Contrôle testable / preuve	Durées documentées par catégorie ; jobs de purge automatiques audités ; rapports de purge.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : DPO — Consulté : Data Steward — Informé : Audit interne
Fréquence de revue	Continue ; audit annuel

Identifiant	SIA-060
Exigence	Toutes les opérations du pipeline de données IA — ingestion, transformation, accès, suppression, export — doivent être journalisées de manière immuable avec chaînage cryptographique, permettant la preuve intègre en cas d'investigation.
Référentiels sources	OWASP GenAI Data Security ; AI Act art. 12 ; DORA
Contrôle testable / preuve	Logs immuables centralisés ; vérification périodique de l'intégrité de la chaîne.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Audit interne
Fréquence de revue	Continue

Identifiant	SIA-061
Exigence	Les embeddings dérivés de données sensibles doivent être chiffrés au repos, stockés sur infrastructure maîtrisée, soumis aux mêmes contrôles d'accès que les données originales, et purgés en cas de retrait du consentement ou d'exercice du droit à l'oubli.
Référentiels sources	OWASP LLM08 ; RGPD art. 17 ; HDS
Contrôle testable / preuve	Politique de chiffrement vérifiée ; procédure de purge testée ; registre des requêtes droit à l'oubli.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : Data Steward — Consulté : DPO, RSSI — Informé : Audit interne
Fréquence de revue	Continue ; audit semestriel

9. Supply chain, AI-BOM et intégrité cryptographique

La sécurité de la chaîne d'approvisionnement IA est une préoccupation structurante pour le Groupe, compte tenu de la diversité des composants (modèles, datasets, bibliothèques, services SaaS, APIs) et de la sensibilité des données traitées. Le présent chapitre consolide les exigences de due diligence, de documentation (AI-BOM, SBOM), d'intégrité cryptographique et de réversibilité.

Les exigences de ce chapitre s'articulent avec les obligations DORA (articles 28-30 sur la gestion des risques ICT liés aux tiers) et NIS2 (gestion des risques de cybersécurité de la chaîne d'approvisionnement).

9.1. Cadre général

Tout composant IA externe est traité par défaut comme une zone d'incertitude nécessitant contrôles, contrats et vérifications. Le niveau d'exigence est proportionné au tier du SIA intégrateur et à la criticité du composant au sens DORA.

9.2. Exigences

Identifiant	SIA-062
Exigence	Toute acquisition de composant IA — modèle, dataset, bibliothèque, service SaaS, API — doit être précédée d'une due diligence sécurité formelle couvrant : posture sécurité du fournisseur, certifications, hébergement, garanties contractuelles, audit right, réversibilité.
Référentiels sources	CLUSIF SIA-06 ; ETSI prEN 304 223 ; DORA art. 28 ; ANSSI
Contrôle testable / preuve	Dossier de due diligence archivé ; grille d'évaluation standard ; décision validée par RSSI et Comité IA.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : Direction des Achats — Approbateur : RSSI — Consulté : DPO, Juridique — Informé : Comité IA
Fréquence de revue	À chaque contractualisation + revue annuelle

Identifiant	SIA-063
Exigence	Les fournisseurs de composants IA doivent être certifiés a minima ISO 27001 ; HDS pour tout composant traitant des données de santé ; SecNumCloud est recommandé (et non obligatoire) pour tout composant classé en tier AISVS L3, priorité accordée aux offres qualifiées ; ISO 42001 recommandé à partir de 2027.
Référentiels sources	HDS ; SecNumCloud ; ISO 27001 ; ISO 42001 ; ETSI prEN 304 223
Contrôle testable / preuve	Attestations de certification en cours de validité archivées ; vérification périodique.

Tier applicable (AI Act × AISVS)	Par tier et par nature de données
Rôle RACI	Responsable : Direction des Achats — Consulté : RSSI — Informé : Comité IA
Fréquence de revue	À la contractualisation + annuelle

Identifiant	SIA-064
Exigence	Les composants IA traitant des données sensibles du Groupe doivent être hébergés en France ou dans l'Union européenne, sur infrastructures exemptes de risque d'accès par une loi extraterritoriale non compatible RGPD. Les dérogations sont traitées selon SIA-010.
Référentiels sources	RGPD art. 44-49 ; ANSSI ; CESIN 2026 ; Cloud Act
Contrôle testable / preuve	Attestation d'hébergement ; clauses contractuelles ; cartographie des flux données.
Tier applicable (AI Act × AISVS)	Tous tiers — données sensibles
Rôle RACI	Responsable : DSI — Approbateur : RSSI — Consulté : Juridique — Informé : Comité IA
Fréquence de revue	À la contractualisation + revue annuelle

Identifiant	SIA-065
Exigence	Les contrats avec les fournisseurs IA doivent comporter une clause explicite de non-rétroaction interdisant au fournisseur d'utiliser les données du Groupe, les prompts, les outputs ou les feedbacks pour entraîner, affiner ou améliorer ses modèles, sauf accord exprès écrit préalable.
Référentiels sources	RGPD art. 28 ; AI Act art. 25 ; CESIN 2026 ; CLUSIF
Contrôle testable / preuve	Clause type validée par la Direction Juridique ; revue annuelle des contrats existants.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : Direction Juridique — Consulté : DPO, RSSI — Informé : Achats
Fréquence de revue	À la contractualisation + audit annuel

Identifiant	SIA-066
Exigence	Chaque fournisseur de modèle ou de service IA doit fournir un AI-BOM à jour documentant : identité des modèles, versions, architectures, données d'entraînement (nature, sources, licences), dépendances, limites connues, modes de défaillance.
Référentiels sources	OWASP AISVS Ch. 6 ; AI Act art. 53 ; ETSI prEN 304 223
Contrôle testable /	AI-BOM archivé et versionné ; revue annuelle ; écart constaté déclenche

preuve	alerte supply chain.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : RSSI — Consulté : Model Steward — Informé : Comité IA
Fréquence de revue	À la contractualisation + mise à jour à chaque version

Identifiant	SIA-067
Exigence	Les SIA internes doivent disposer d'un SBOM étendu aux composants ML (modèles, datasets, frameworks, librairies) au format standard (CycloneDX-ML ou équivalent). Le SBOM est produit à chaque build et publié aux parties prenantes.
Référentiels sources	OWASP AISVS Ch. 6 ; CISA SBOM ; DORA art. 8
Contrôle testable / preuve	Pipeline CI générant le SBOM automatiquement ; stockage centralisé ; vérifiabilité à l'audit.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Audit interne
Fréquence de revue	À chaque build

Identifiant	SIA-068
Exigence	Les dépendances des pipelines IA doivent être scannées automatiquement et quotidiennement contre des bases de vulnérabilités reconnues (CVE, GitHub Advisory, Snyk) avec remédiation priorisée selon la criticité CVSS.
Référentiels sources	OWASP AISVS Ch. 6 ; ISO 27001 §8.8 ; DORA
Contrôle testable / preuve	Outil de scan déployé ; rapports quotidiens ; SLA de remédiation documenté et suivi.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Audit interne
Fréquence de revue	Continue

Identifiant	SIA-069
Exigence	Les licences de tous les modèles, datasets et outils IA utilisés doivent être identifiées, documentées et respectées. Les licences incompatibles avec les finalités du Groupe sont interdites d'usage en production.
Référentiels sources	OWASP AISVS Ch. 6 ; Code de la propriété intellectuelle
Contrôle testable / preuve	Inventaire des licences à jour ; scan automatisé ; revue juridique annuelle.
Tier applicable (AI Act × AISVS)	Tous tiers

Act × AISVS)	
Rôle RACI	Responsable : DSI — Consulté : Direction Juridique — Informé : Comité IA
Fréquence de revue	Continue ; revue annuelle juridique

Identifiant	SIA-070
Exigence	Les modèles tiers importés doivent être traités comme du code non fiable : vérification de signature, scan statique des fichiers de poids (recherche de code arbitraire dans Pickle, HDF5, SafeTensors), isolation en sandbox lors du premier chargement.
Référentiels sources	CLUSIF §3.3.3 ; OWASP AISVS Ch. 6 ; ANSSI
Contrôle testable / preuve	Procédure d'import documentée ; scan systématique ; rapports d'analyse archivés.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : Model Steward — Consulté : RSSI — Informé : DSI
Fréquence de revue	À chaque import de modèle tiers

Identifiant	SIA-071
Exigence	Les contrats avec les fournisseurs IA critiques — au sens DORA art. 28 pour les services ICT — doivent comporter un droit d'audit annuel exerçable par le Groupe, par un tiers auditeur mandaté, ou par les autorités de tutelle.
Référentiels sources	DORA art. 28 ; ISO 27001 §5.20
Contrôle testable / preuve	Clause d'audit validée ; planification annuelle des audits ; rapports d'audit archivés.
Tier applicable (AI Act × AISVS)	Fournisseurs critiques ; AISVS L2-L3
Rôle RACI	Responsable : Direction Juridique — Consulté : RSSI, Audit interne — Informé : Comité des Risques
Fréquence de revue	Annuelle

Identifiant	SIA-072
Exigence	Chaque fournisseur IA critique doit faire l'objet d'une stratégie de sortie documentée permettant la migration ou l'internalisation du composant en cas de défaillance, rupture contractuelle, évolution réglementaire ou décision stratégique. La stratégie est testée au moins tous les 24 mois.
Référentiels sources	DORA art. 28 ; ESMA guidelines outsourcing
Contrôle testable / preuve	Plan d'exit archivé ; exercice de reversibilité documenté ; revue bisannuelle.
Tier applicable (AI Act × AISVS)	Fournisseurs critiques

Rôle RACI	Responsable : DSI — Consulté : RSSI, Juridique — Informé : Comité des Risques
Fréquence de revue	Documentation continue ; test bisannuel

Identifiant	SIA-073
Exigence	La performance opérationnelle et la posture sécurité des fournisseurs IA doivent être monitorées en continu : SLA, incidents, évolutions contractuelles, changements d'actionnariat, alertes CERT, avec remontée trimestrielle au Comité IA.
Référentiels sources	DORA art. 28-30 ; NIS2 ; CESIN 2026
Contrôle testable / preuve	Tableau de bord fournisseurs tenu ; rapport trimestriel au Comité IA.
Tier applicable (AI Act × AISVS)	Fournisseurs critiques ; AISVS L2-L3
Rôle RACI	Responsable : RSSI — Consulté : Achats, DSI — Informé : Comité IA
Fréquence de revue	Continue ; rapport trimestriel

10. Systèmes agentiques

Un système agentique est un SIA doté d'une capacité d'action autonome sur son environnement, opérant via l'appel d'outils (tool use), l'orchestration de chaînes de décisions multi-étapes, et potentiellement la coordination entre plusieurs agents. Cette catégorie recouvre les assistants conversationnels enrichis d'outils, les agents autonomes, les pipelines d'orchestration multi-agents, les copilotes intégrés à des systèmes métier.

Les systèmes agentiques introduisent des risques spécifiques non couverts par les SIA conventionnels : amplification des effets via l'action réelle, escalade de privilèges via chaînage d'outils, prompt injection indirecte via les sources de contexte, perte de traçabilité dans les chaînes longues, désalignement entre l'intention de l'utilisateur et l'action exécutée. Le présent chapitre établit le socle de contrôles dédié.

10.1. Typologie des agents

Type	Description	Risque caractéristique
Agent réactif	Agent sans état, répondant à une requête ponctuelle via un ou plusieurs outils	Prompt injection, fuite de permissions
Agent délibératif	Agent planifiant une séquence d'actions pour atteindre un objectif	Décalage intention/exécution, boucles
Agent autonome	Agent opérant sur longue durée, prenant des décisions sans intervention humaine par défaut	Excès d'autonomie, actions non voulues
Système multi-agents	Orchestration de plusieurs agents collaborant	Cascading failures, collusion, perte de traçabilité

10.2. Principes de sécurité agentique

- Moindre privilège strict appliqué aux outils, aux données et aux périmètres d'action.
- Journalisation complète et immuable de toutes les actions, incluant les paramètres d'appels et les résultats.
- Kill switch dédié, distinct du kill switch du modèle sous-jacent.
- Supervision humaine explicite (HITL niveau 4) pour les actions à conséquences significatives.
- Sandboxing des actions modifiantes et des exécutions de code.
- Rate limits et quotas pour contenir la divergence ou la consommation anormale.
- Interdictions absolues de périmètre sur certaines classes d'actions.
- Chaîne de responsabilité formalisée et imputabilité finale humaine.

10.3. Exigences

Identifiant	SIA-074
Exigence	Tout SIA doté d'une capacité d'action autonome sur son environnement — appel d'outils (tool use), modification de données, interaction avec des systèmes tiers, orchestration multi-agents — doit être qualifié comme système agentique et classé au minimum AISVS L2, indépendamment de

	son tier AI Act.
Référentiels sources	OWASP Agentic Security ; OWASP AISVS Ch. 9-10 ; MIT AI Risk Repository
Contrôle testable / preuve	Qualification agentique formalisée à la conception, archivée dans le registre central, avec typologie (réactif, délibératif, autonome).
Tier applicable (AI Act × AISVS)	Méta-exigence — qualification
Rôle RACI	Responsable : RSSI — Consulté : Model Steward, architecte — Informé : Comité IA
Fréquence de revue	À l'initiation + revue annuelle

Identifiant	SIA-075
Exigence	Chaque agent déployé doit disposer d'un AI-BOM agentique documentant : modèle sous-jacent, outils autorisés, permissions associées, chaînes d'appels inter-agents, serveurs MCP utilisés, sources de contexte. Cet AI-BOM est mis à jour à chaque évolution et soumis à revue trimestrielle.
Référentiels sources	OWASP AISVS Ch. 6 ; OWASP Agentic Security
Contrôle testable / preuve	AI-BOM agentique archivé, versionné, accessible à l'audit ; revue trimestrielle documentée.
Tier applicable (AI Act × AISVS)	Agentique — tous tiers
Rôle RACI	Responsable : Model Steward — Consulté : RSSI — Informé : Audit interne
Fréquence de revue	À chaque évolution + revue trimestrielle

Identifiant	SIA-076
Exigence	Les agents doivent opérer selon le principe de moindre privilège : chaque outil, chaque API, chaque accès à une source de données nécessite une autorisation explicite, restreinte au périmètre strictement nécessaire, documentée et audité. Aucune permission globale n'est accordée par défaut.
Référentiels sources	OWASP Agentic Security ; OWASP AISVS Ch. 5, 9 ; ISO 27001 §8.3
Contrôle testable / preuve	Matrice de permissions par agent publiée et auditable ; rapport de revue d'accès semestriel.
Tier applicable (AI Act × AISVS)	Agentique — tous tiers
Rôle RACI	Responsable : RSSI — Consulté : Model Steward, DSI — Informé : Audit interne
Fréquence de revue	Continue ; revue semestrielle

Identifiant	SIA-077
--------------------	----------------

Exigence	L'utilisation du Model Context Protocol doit respecter un cadre de sécurité renforcé : manifests MCP signés cryptographiquement, allowlist explicite des serveurs MCP autorisés, scope des outils limité et documenté, mécanismes de révocation immédiate, surveillance des appels MCP au niveau du SOC.
Référentiels sources	OWASP AISVS Ch. 10 ; OWASP Agentic Security ; ANSSI
Contrôle testable / preuve	Allowlist MCP publiée ; vérification de signature à chaque chargement ; logs MCP intégrés au SIEM.
Tier applicable (AI Act × AISVS)	Agentique utilisant MCP
Rôle RACI	Responsable : RSSI — Consulté : DSI, Model Steward — Informé : SOC
Fréquence de revue	Continue ; revue trimestrielle de l'allowlist

Identifiant	SIA-078
Exigence	Toute action d'un agent sur un système tiers — écriture de fichier, envoi d'email, appel d'API modifiante, exécution de commande — doit se dérouler dans un environnement d'exécution confiné (sandbox) permettant l'audit, la limitation des effets et la révocation immédiate.
Référentiels sources	OWASP Agentic Security ; OWASP AISVS Ch. 9
Contrôle testable / preuve	Architecture sandbox documentée ; audit semestriel des évactions potentielles.
Tier applicable (AI Act × AISVS)	Agentique — tous tiers
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Model Steward
Fréquence de revue	Continue ; audit semestriel

Identifiant	SIA-079
Exigence	Toutes les actions d'un agent doivent être journalisées de manière immuable, avec horodatage, identifiant agent, identifiant session, nom de l'outil appelé, paramètres, résultat, décision associée du modèle et justification textuelle. La journalisation est auditée indépendamment et conservée selon les durées du ch. 8.
Référentiels sources	AI Act art. 12 ; OWASP Agentic Security ; ISO 27090 §5.4 ; DORA
Contrôle testable / preuve	Logs agents centralisés et immuables ; vérification échantillonnée par Audit interne ; chaînage d'intégrité cryptographique.
Tier applicable (AI Act × AISVS)	Agentique — tous tiers
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Audit interne
Fréquence de revue	Continue

Identifiant	SIA-080
--------------------	----------------

Exigence	Chaque agent doit disposer d'un kill switch dédié, distinct du kill switch du modèle sous-jacent (SIA-041), permettant l'arrêt immédiat de l'ensemble des actions en cours et le blocage de toute nouvelle action, sans latence supérieure à 30 secondes. Le kill switch est testé trimestriellement.
Référentiels sources	OWASP AISVS Ch. 9 ; OWASP Agentic Security ; AI Act art. 14
Contrôle testable / preuve	Procédure dédiée documentée ; liste d'opérateurs autorisés ; test trimestriel horodaté et chronométré.
Tier applicable (AI Act × AISVS)	Agentique — tous tiers
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Comité IA
Fréquence de revue	Trimestrielle

Identifiant	SIA-081
Exigence	Toute action d'un agent ayant une conséquence financière, juridique, contractuelle, ou un impact sur un adhérent, un assuré ou un bénéficiaire, doit faire l'objet d'une confirmation humaine explicite préalable (HITL niveau 4), sauf exemption documentée et validée par le Comité IA.
Référentiels sources	AI Act art. 14 ; OWASP Agentic Security ; OWASP AISVS Ch. 14
Contrôle testable / preuve	Matrice des actions soumises à HITL niveau 4 publiée ; journal des confirmations archivé.
Tier applicable (AI Act × AISVS)	Agentique — tous tiers
Rôle RACI	Responsable : propriétaire métier — Consulté : RSSI, DPO — Informé : Comité IA
Fréquence de revue	Continue ; revue semestrielle de la matrice

Identifiant	SIA-082
Exigence	Les agents ne peuvent exécuter de manière autonome aucune action relevant des catégories suivantes : exécution de paiements, modification de contrats, transmission de données adhérents vers un tiers, modification de droits d'accès, décision sur prestation santé ou indemnisation, souscription de nouveaux contrats, résiliation de contrats existants. Ces actions exigent une validation humaine non contournable.
Référentiels sources	AI Act art. 14 ; RGPD art. 22 ; OWASP Agentic Security
Contrôle testable / preuve	Liste des actions interdites configurée techniquement ; contrôle par filtre de permissions ; audit semestriel.
Tier applicable (AI Act × AISVS)	Agentique — tous tiers — impératif
Rôle RACI	Responsable : RSSI — Approbateur : Comité IA — Consulté : DPO, métier — Informé : DSI
Fréquence de revue	Continue ; audit semestriel

Identifiant	SIA-083
Exigence	Les agents doivent être soumis à des quotas et rate limits paramétrés : nombre maximum d'appels d'outils par session, coût maximum par exécution, profondeur maximum des chaînes d'appels, durée maximum d'exécution, avec arrêt automatique en cas de dépassement et alerte au SOC.
Référentiels sources	OWASP Agentic Security ; OWASP AISVS Ch. 9
Contrôle testable / preuve	Quotas configurés par agent ; tableau de bord de consommation ; alertes loguées au SOC.
Tier applicable (AI Act × AISVS)	Agentique — tous tiers
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Model Steward
Fréquence de revue	Continue ; revue trimestrielle des seuils

Identifiant	SIA-084
Exigence	Les agents doivent faire l'objet de tests spécifiques avant mise en production, couvrant : injection de prompt via tool chaining, rôle confusion, détournement de contexte, excès d'autonomie, boucles infinies, escalade de privilèges via outils, ré-identification de données à travers les appels inter-agents.
Référentiels sources	OWASP Agentic Security ; OWASP AISVS Ch. 11 ; MITRE ATLAS
Contrôle testable / preuve	Rapport de tests agentiques archivé ; couverture des cas d'usage documentée ; remédiations appliquées avant go-live.
Tier applicable (AI Act × AISVS)	Agentique — tous tiers
Rôle RACI	Responsable : RSSI — Consulté : Model Steward — Informé : Comité IA
Fréquence de revue	Avant mise en production + trimestrielle

Identifiant	SIA-085
Exigence	La chaîne de responsabilité pour les actions des agents doit être formellement établie et documentée : l'imputabilité finale d'une action revient au propriétaire métier du SIA ; l'opérateur de supervision est responsable du contrôle en temps réel ; l'équipe technique est responsable de l'intégrité technique de l'agent.
Référentiels sources	AI Act art. 26 ; ISO 42001 §5.3 ; OWASP Agentic Security
Contrôle testable / preuve	Chaîne de responsabilité publiée par agent dans le registre central ; formations associées vérifiées.
Tier applicable (AI Act × AISVS)	Agentique — tous tiers
Rôle RACI	Responsable : Comité IA — Consulté : Juridique — Informé : propriétaire métier, RSSI
Fréquence de revue	À la mise en production + revue annuelle

11. Génération de code source assistée par IA

Les outils d'IA générative spécialisés dans la production de code source — copilotes, assistants de développement, générateurs à la demande — offrent un gain de productivité important, mais introduisent des risques spécifiques : vulnérabilités introduites par construction, hallucinations de bibliothèques ou d'API, intégration involontaire de code tiers sans licence compatible, fuites de code propriétaire vers des services externes, atténuation de la vigilance du développeur.

Le présent chapitre définit un cadre strict, hérité des règles CLUSIF SIA-20, SIA-21 et SIA-22, et enrichi des enjeux spécifiques au secteur de la protection sociale. Il s'applique à tout collaborateur du Groupe, qu'il soit développeur à plein temps, développeur occasionnel, ou utilisateur d'outils low-code/no-code comportant une composante génération de code.

11.1. Cadre général

Les règles du chapitre 11 ne remplacent pas les pratiques de développement sécurisé du SMSI du Groupe mais les complètent par des garde-fous spécifiques à la génération de code par IA.

Tout code généré par IA est considéré par défaut comme du code non fiable, nécessitant validation avant intégration. La responsabilité finale du code produit reste celle du développeur qui en sollicite la génération et celle de son équipe.

11.2. Périmètres interdits

Certains périmètres applicatifs cumulent une sensibilité particulière (impact sécurité et réglementaire) et une difficulté élevée d'audit automatique. Pour ces périmètres, la génération de code par IA est strictement interdite (voir SIA-086).

11.3. Exigences

Identifiant	SIA-086
Exigence	Il est interdit d'utiliser un outil d'IA générative pour produire des blocs de code destinés aux modules suivants : cryptographie (authentification, chiffrement, signature, gestion de clés), gestion des droits et des accès utilisateurs et administrateurs, traitement direct de données de santé ou financières adhérents, implémentation de règles anti-fraude, logique de calcul actuariel, modules de conformité réglementaire (reporting ACPR, CNIL, DORA, NIS2 et obligations similaires). Le code généré pour ces périmètres doit être produit par un développeur humain qualifié.
Référentiels sources	CLUSIF SIA-21 ; ANSSI ; OWASP LLM09
Contrôle testable / preuve	Liste publiée des périmètres interdits ; revue de code systématique des pull requests sur ces modules vérifiant l'origine humaine ; attestation développeur.
Tier applicable (AI Act × AISVS)	Tous tiers — impératif

Rôle RACI	Responsable : RSSI — Approbateur : Comité IA — Consulté : Architecte SI — Informé : Managers développement
Fréquence de revue	Continue ; audit semestriel

Identifiant	SIA-087
Exigence	L'exécution automatique de code source généré par IA dans les environnements de développement, de pré-production ou de production est interdite. Tout code généré par IA doit être explicitement soumis à exécution par un développeur humain dans un environnement confiné avant toute intégration.
Référentiels sources	CLUSIF SIA-20 ; OWASP LLM09
Contrôle testable / preuve	Configuration des IDE et copilotes désactivant l'auto-exécution ; audit trimestriel.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : développeurs
Fréquence de revue	Continue

Identifiant	SIA-088
Exigence	Le commit automatique de code source généré par IA dans les dépôts est interdit. Tout commit comportant du code généré par IA doit être précédé d'une revue humaine attestée, explicitement tracée dans le message de commit ou l'historique de la pull request.
Référentiels sources	CLUSIF SIA-20
Contrôle testable / preuve	Politique de branches protégées ; hooks pré-commit vérifiant l'absence d'auto-commit ; métrique revue.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : développeurs
Fréquence de revue	Continue

Identifiant	SIA-089
Exigence	Tout code source généré par IA doit être soumis à un pipeline de vérification automatisée comportant au minimum : analyse statique (SAST), scan de secrets, analyse de composition logicielle (SCA), linting sécurité. Les vulnérabilités critiques ou hautes doivent être corrigées avant merge.
Référentiels sources	CLUSIF SIA-20 ; OWASP AISVS Ch. 6 ; ISO 27001 §8.28
Contrôle testable / preuve	Pipeline CI intégrant les outils ; rapports archivés ; gate de blocage sur vulnérabilités critiques.
Tier applicable (AI Act × AISVS)	Tous tiers

Rôle RACI	Responsable : lead développeur — Consulté : RSSI — Informé : DSI
Fréquence de revue	Continue

Identifiant	SIA-090
Exigence	Les bibliothèques, paquets et dépendances référencés par le code généré par IA doivent être vérifiés avant utilisation : existence réelle du paquet (détection des hallucinations de packages), vérification de la réputation, scan de vulnérabilités, conformité de licence, revue de la version pinnée.
Référentiels sources	OWASP LLM04, LLM09 ; CLUSIF SIA-20 ; ENISA supply chain
Contrôle testable / preuve	Outil de validation des dépendances intégré en CI ; journal des rejets ; liste noire des paquets suspects maintenue.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : lead développeur — Consulté : RSSI — Informé : Audit interne
Fréquence de revue	Continue

Identifiant	SIA-091
Exigence	Toute pull request comportant du code généré par IA doit faire l'objet d'une revue de code humaine attestée par un développeur distinct de celui ayant sollicité la génération, avec examen explicite des risques spécifiques : hallucinations, vulnérabilités introduites, logique incorrecte, dépendances suspectes.
Référentiels sources	CLUSIF SIA-20 ; ISO 27001 §8.25
Contrôle testable / preuve	Politique de revue de code imposant un second reviewer ; template de revue listant les risques IA ; audit trimestriel.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : lead développeur — Consulté : RSSI — Informé : DSI
Fréquence de revue	Continue

Identifiant	SIA-092
Exigence	Le Groupe doit conduire des campagnes périodiques de contrôle de qualité du code généré par IA : analyse d'échantillons représentatifs, comparaison qualité code généré vs code humain, taux de vulnérabilités introduites, taux de fausses dépendances détectées. Les résultats sont présentés au Comité IA.
Référentiels sources	CLUSIF SIA-20
Contrôle testable / preuve	Rapport semestriel de qualité du code généré présenté au Comité IA ; tendances surveillées.
Tier applicable (AI Act × AISVS)	Tous tiers

Act × AISVS)	
Rôle RACI	Responsable : Audit interne — Consulté : RSSI, lead tech — Informé : Comité IA
Fréquence de revue	Semestrielle

Identifiant	SIA-093
Exigence	Les développeurs utilisant des outils de génération de code par IA doivent suivre une formation initiale obligatoire (4h minimum) et une sensibilisation annuelle, couvrant : risques spécifiques, modules interdits, techniques de prompt engineering sécurisé, obligations de revue, signalement des anomalies.
Référentiels sources	CLUSIF SIA-22 ; CESIN 2026
Contrôle testable / preuve	Attestations de formation archivées ; taux de complétion suivi ; contenus à jour des référentiels.
Tier applicable (AI Act × AISVS)	Tous développeurs utilisant ces outils
Rôle RACI	Responsable : DRH / direction formation — Consulté : RSSI, lead tech — Informé : Comité IA
Fréquence de revue	Initiale + annuelle

Identifiant	SIA-094
Exigence	Les sollicitations des outils de génération de code — prompts envoyés, réponses générées, code finalement intégré — doivent être journalisées pour les périmètres sensibles, permettant la traçabilité en cas d'incident ou d'audit, dans le respect des obligations RGPD et de la politique de confidentialité du code.
Référentiels sources	CLUSIF SIA-22 ; AI Act art. 12
Contrôle testable / preuve	Logs intégrés aux outils de développement pour les modules sensibles ; politique de conservation définie.
Tier applicable (AI Act × AISVS)	Périmètres sensibles
Rôle RACI	Responsable : DSI — Consulté : RSSI, DPO — Informé : Audit interne
Fréquence de revue	Continue

Identifiant	SIA-095
Exigence	L'utilisation d'outils de génération de code doit être limitée aux outils approuvés et référencés par le Groupe, exécutés sur infrastructure maîtrisée ou dans un cadre contractuel garantissant la non-rétroaction (voir SIA-065). L'usage d'outils personnels ou non référencés est un cas de shadow AI relevant du ch. 13.
Référentiels sources	CESIN 2026 ; CLUSIF ; CNIL

Contrôle testable / preuve	Liste des outils approuvés publiée et tenue à jour ; détection technique des outils non approuvés ; régularisation selon ch. 13.
Tier applicable (AI Act × AISVS)	Tous développeurs
Rôle RACI	Responsable : RSSI — Consulté : DSI, lead tech — Informé : Comité IA
Fréquence de revue	Continue ; revue trimestrielle de la liste

12. Supervision humaine et accountability

La supervision humaine est l'une des obligations centrales de l'article 14 de l'AI Act pour les SIA à haut risque, et un principe fondateur de la présente politique au-delà du seul cadre réglementaire. Elle vise à préserver la capacité d'une personne formée, autorisée et outillée d'intervenir efficacement sur un SIA dans toutes les situations où son action est requise, et à garantir l'imputabilité des décisions prises avec ou par le SIA.

12.1. Niveaux HITL

Niveau	Description	Supervision typique	Exemple
Niveau 0 — Information	SIA fournit de l'information sans décision	Aucune obligation spécifique	Recherche documentaire
Niveau 1 — Recommandation	SIA recommande, l'humain décide	Revue systématique possible	Suggestion de prestation
Niveau 2 — Décision assistée	SIA propose une décision, validation humaine obligatoire	Validation avant application	Proposition d'indemnisation
Niveau 3 — Décision automatisée	SIA décide, monitoring a posteriori et voie de contestation	Monitoring + audit	Scoring risque
Niveau 4 — Action autonome	SIA agit, avec kill switch et monitoring intensif	Kill switch + supervision renforcée	Agent de traitement

12.2. Capacités requises pour une supervision effective

L'article 14 de l'AI Act, complété par le chapitre 14 d'OWASP AISVS, identifie cinq capacités qu'un superviseur doit posséder pour une supervision effective : connaissance du système, capacité de surveillance, pouvoir d'intervention, autorité et formation. Ces cinq dimensions structurent les exigences ci-dessous.

12.3. Exigences

Identifiant	SIA-096
Exigence	Chaque SIA doit être positionné explicitement sur l'échelle HITL du Groupe (niveaux 0 à 4) selon sa capacité d'action et l'impact de ses décisions. Le positionnement conditionne les obligations de supervision applicables et est cohérent avec le tiering du ch. 6.
Référentiels sources	AI Act art. 14 ; OWASP AISVS Ch. 14 ; CLUSIF
Contrôle testable / preuve	Niveau HITL documenté dans le registre central ; revue annuelle systématique.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : propriétaire métier — Approbateur : Comité IA — Consulté : RSSI — Informé : superviseurs
Fréquence de revue	À la mise en production + revue annuelle

Identifiant	SIA-097
Exigence	Les superviseurs humains de tout SIA de tier AI Act haut risque ou AISVS L2-L3 doivent disposer d'une connaissance suffisante des capacités et des limites du système, documentée par une formation initiale et une formation continue, et attestée par une évaluation.
Référentiels sources	AI Act art. 14(4)(a) ; OWASP AISVS Ch. 14
Contrôle testable / preuve	Attestations de formation et d'évaluation archivées ; suivi annuel du taux de superviseurs formés.
Tier applicable (AI Act × AISVS)	AI Act haut risque ; AISVS L2-L3
Rôle RACI	Responsable : propriétaire métier — Consulté : DRH / formation, RSSI — Informé : DPO
Fréquence de revue	Initiale + annuelle

Identifiant	SIA-098
Exigence	Les superviseurs doivent disposer d'interfaces et d'outils leur permettant de comprendre les sorties du SIA, de détecter les anomalies et les dérives, et d'obtenir des explications sur les décisions générées, à un niveau de détail adapté à leur rôle.
Référentiels sources	AI Act art. 14(4)(b) ; OWASP AISVS Ch. 14
Contrôle testable / preuve	Interfaces de supervision déployées ; retours utilisateurs recueillis ; améliorations itératives documentées.
Tier applicable (AI Act × AISVS)	AI Act haut risque ; AISVS L2-L3
Rôle RACI	Responsable : DSI — Consulté : propriétaire métier, RSSI — Informé : superviseurs
Fréquence de revue	Continue ; revue annuelle de l'ergonomie

Identifiant	SIA-099
Exigence	Les superviseurs doivent disposer d'un pouvoir effectif d'intervention : correction, override, interruption, déclenchement du kill switch. Ce pouvoir est techniquement disponible sans délai et organisationnellement délégué sans escalade bloquante.
Référentiels sources	AI Act art. 14(4)(c-d) ; OWASP AISVS Ch. 14
Contrôle testable / preuve	Fonctionnalités d'intervention auditées ; délégations formalisées ; exercices de simulation.
Tier applicable (AI Act × AISVS)	AI Act haut risque ; AISVS L2-L3
Rôle RACI	Responsable : DSI, propriétaire métier — Consulté : RSSI — Informé : superviseurs

Fréquence de revue	Continue ; exercice semestriel
---------------------------	--------------------------------

Identifiant	SIA-100
Exigence	Les superviseurs d'un SIA doivent disposer d'une autorité effective pour intervenir : position hiérarchique appropriée, délégation formelle, absence de contrainte organisationnelle les dissuadant d'exercer leur rôle (notamment pas d'objectifs de performance privilégiant systématiquement l'acceptation des sorties du SIA).
Référentiels sources	AI Act art. 14(4)(c) ; OWASP AISVS Ch. 14 ; ISO 42001
Contrôle testable / preuve	Lettre de mission ou équivalent ; revue du dispositif d'objectifs des superviseurs ; enquête anonyme annuelle.
Tier applicable (AI Act × AISVS)	AI Act haut risque ; AISVS L2-L3
Rôle RACI	Responsable : DRH — Consulté : propriétaire métier, RSSI — Informé : Comité IA
Fréquence de revue	Annuelle

Identifiant	SIA-101
Exigence	Le dispositif de supervision doit prévenir le biais d'automation (sur-confiance dans la sortie du SIA) : alertes contextuelles, tests aveugles aléatoires, rotation des superviseurs, mesure du taux d'override et des désaccords, feedback aux superviseurs.
Référentiels sources	NIST AI RMF Measure ; recherche académique HCI ; CNIL
Contrôle testable / preuve	Taux d'override suivi mensuellement ; dispositif de test aveugle documenté ; rapport annuel au Comité IA.
Tier applicable (AI Act × AISVS)	AISVS L3 ; AI Act haut risque à impact personnes
Rôle RACI	Responsable : Model Steward — Consulté : RSSI, métier — Informé : Comité IA
Fréquence de revue	Continue ; revue annuelle

Identifiant	SIA-102
Exigence	Le temps d'exposition continue d'un superviseur à un SIA générant de grandes volumétries de décisions à valider devrait être limité, avec rotations, pauses prévues et diversification des tâches, afin de préserver la vigilance et d'éviter la fatigue décisionnelle.
Référentiels sources	ergonomie cognitive ; NIST AI RMF Govern ; OWASP AISVS
Contrôle testable / preuve	Planning de rotation documenté ; indicateurs de fatigue suivis ; retours superviseurs collectés.
Tier applicable (AI Act × AISVS)	Supervision volumétrique

Rôle RACI	Responsable : propriétaire métier — Consulté : DRH, médecine du travail — Informé : Comité IA
Fréquence de revue	Continue

Identifiant	SIA-103
Exigence	Toute personne affectée par une décision significativement automatisée d'un SIA doit pouvoir exercer ses droits au titre de l'article 22 du RGPD : être informée, obtenir une explication, contester la décision, demander un réexamen humain. Les processus et outils associés doivent être documentés et opérationnels.
Référentiels sources	RGPD art. 22 ; AI Act art. 86 ; CNIL
Contrôle testable / preuve	Procédures documentées ; registre des demandes et des traitements ; délais de réponse suivis.
Tier applicable (AI Act × AISVS)	SIA à décisions significatives
Rôle RACI	Responsable : DPO — Consulté : métier, Juridique — Informé : RSSI
Fréquence de revue	Continue ; rapport annuel

13. GPAI publics, transparence et shadow AI

Ce chapitre traite trois sujets interdépendants : les obligations de transparence instituées par l'article 50 de l'AI Act vis-à-vis des personnes interagissant avec un SIA ou exposées à ses sorties, les règles d'usage des GPAI publics (ChatGPT, Claude, Gemini, Perplexity, Copilot public, outils équivalents) par les collaborateurs du Groupe, et la politique de prévention et de traitement du shadow AI.

Le baromètre CESIN 2026 identifie le shadow AI comme le premier comportement à risque de l'année et la souveraineté numérique comme un critère de choix majeur. Le Groupe considère ces enjeux comme stratégiques.

13.1. Transparence (AI Act art. 50)

L'article 50 de l'AI Act institue quatre obligations principales de transparence : information des personnes interagissant avec un SIA, marquage des contenus synthétiques par watermarking et mention lisible, obligations spécifiques pour les deepfakes, information sur la nature du contenu généré dans certains contextes professionnels. Ces obligations s'appliquent indépendamment du caractère « haut risque » du SIA et s'imposent aux déployeurs autant qu'aux fournisseurs.

13.2. Usage des GPAI publics

Les GPAI publics offrent une valeur métier réelle mais exposent à des risques structurels : perte de confidentialité des données transmises, absence de garantie de non-rétroaction chez certains fournisseurs, hébergement extraterritorial soumis à des lois non compatibles RGPD, absence de traçabilité robuste des interactions. Le Groupe encadre strictement leur usage.

13.3. Shadow AI

Le shadow AI désigne l'usage non déclaré, non référencé et non contrôlé de SIA par des collaborateurs dans le cadre de leurs activités professionnelles. Il constitue un risque majeur parce qu'il échappe par construction aux contrôles de la présente politique. Le Groupe adopte une approche combinant détection, accompagnement et mise à disposition d'alternatives souveraines.

13.4. Exigences

Identifiant	SIA-104
Exigence	Tout SIA interagissant directement avec des personnes physiques — adhérents, assurés, collaborateurs, candidats — doit informer clairement ses interlocuteurs qu'ils interagissent avec un système d'intelligence artificielle, sauf si la nature de l'interaction rend ce constat évident au regard des circonstances.
Référentiels sources	AI Act art. 50(1)
Contrôle testable /	Mention d'information visible en tête d'interaction ; vérification ergonomique ;

preuve	revue de conformité DPO.
Tier applicable (AI Act × AISVS)	SIA interagissant avec personnes
Rôle RACI	Responsable : propriétaire métier — Consulté : DPO, Communication — Informé : RSSI
Fréquence de revue	À la mise en production + revue annuelle

Identifiant	SIA-105
Exigence	Tout contenu synthétique (texte, image, audio, vidéo) généré par un SIA du Groupe et diffusé à l'extérieur doit être marqué de manière détectable par machine (watermarking) lorsque la technologie le permet, et accompagné d'une mention explicite lisible pour un humain lorsque le contexte ne rend pas l'origine synthétique évidente.
Référentiels sources	AI Act art. 50(2)
Contrôle testable / preuve	Politique de marquage documentée ; outils de marquage déployés ; vérification d'efficacité périodique.
Tier applicable (AI Act × AISVS)	SIA générant du contenu diffusé
Rôle RACI	Responsable : Model Steward — Consulté : DPO, Communication — Informé : RSSI
Fréquence de revue	Continue ; audit semestriel

Identifiant	SIA-106
Exigence	La production de deepfakes — contenus synthétiques représentant des personnes réelles de manière réaliste — est interdite sauf dans des cadres strictement encadrés : consentement explicite de la personne représentée, finalité légitime documentée, marquage renforcé, information complète de l'audience.
Référentiels sources	AI Act art. 50(4) ; Code civil art. 9 ; RGPD
Contrôle testable / preuve	Politique interne deepfake publiée ; registre des cas autorisés avec consentements archivés ; sanctions en cas de manquement.
Tier applicable (AI Act × AISVS)	Tous tiers — impératif
Rôle RACI	Responsable : Direction Juridique — Approbateur : Comité IA — Consulté : DPO, RSSI — Informé : Direction Communication
Fréquence de revue	Continue

Identifiant	SIA-107
Exigence	L'utilisation de GPAI publics (ChatGPT, Claude, Gemini, Perplexity, Copilot public, outils similaires) par les collaborateurs doit respecter la matrice d'autorisation par classification de données définie par le Groupe. Les données classées Confidentiel ou Secret ne doivent en aucun cas transiter

	par ces services.
Référentiels sources	AI Act art. 4, 25 ; CESIN 2026 ; CNIL
Contrôle testable / preuve	Matrice d'autorisation publiée ; charte d'utilisation signée ; filtres techniques (DLP, proxy) déployés ; rapport d'usage mensuel.
Tier applicable (AI Act × AISVS)	Tous tiers — impératif
Rôle RACI	Responsable : RSSI — Consulté : DPO, DSI — Informé : DRH, Comité IA
Fréquence de revue	Continue ; revue annuelle de la matrice

Identifiant	SIA-108
Exigence	Aucune donnée adhérent, assuré, patient, bénéficiaire, candidat ou collaborateur identifiable ou ré-identifiable ne doit être transmise à un GPAI public ni à un service IA tiers non-souverain, quel que soit le volume, la finalité invoquée ou le niveau de criticité apparent de la tâche. Cette interdiction est absolue et ne fait pas l'objet de dérogation.
Référentiels sources	SIA-055 ; RGPD art. 5, 32, 44-49 ; HDS ; ANSSI R34 ; AI Act art. 25
Contrôle testable / preuve	Filtres techniques bloquant ces transferts ; DLP sortant ; détection comportementale ; sanctions disciplinaires (ch. 18).
Tier applicable (AI Act × AISVS)	Tous tiers — impératif absolu
Rôle RACI	Responsable : RSSI — Approbateur : Direction Générale — Consulté : DPO, Juridique — Informé : Comité des Risques
Fréquence de revue	Continue

Identifiant	SIA-109
Exigence	Le Groupe doit déployer et maintenir un dispositif de détection du shadow AI — usage non déclaré, non référencé et non contrôlé de SIA par des collaborateurs — couvrant au minimum : analyse des flux réseau sortants, inspection des endpoints, analyse des notes de frais et des achats IT non centralisés, signalements internes.
Référentiels sources	CESIN 2026 ; ANSSI ; OWASP
Contrôle testable / preuve	Dispositif technique déployé et documenté ; rapport trimestriel de détection ; taux de couverture mesuré.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : DSI, DRH — Informé : Comité IA
Fréquence de revue	Continue ; rapport trimestriel

Identifiant	SIA-110
Exigence	Tout cas de shadow AI identifié doit faire l'objet d'un traitement formalisé :

	entretien avec le collaborateur, évaluation de l'impact (données exposées, durée, finalité), remédiation (cessation de l'usage, ré-orientation vers un SIA souverain, éventuelles notifications RGPD ou AIPD), enregistrement au registre des incidents, communication pédagogique.
Référentiels sources	CESIN 2026 ; RGPD art. 33-34
Contrôle testable / preuve	Procédure écrite diffusée ; registre des cas traités ; mesure du délai moyen de traitement.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : DPO, DRH, manager — Informé : Comité IA
Fréquence de revue	À chaque cas ; rapport trimestriel

Identifiant	SIA-111
Exigence	Le Groupe doit offrir à ses collaborateurs des alternatives souveraines et sécurisées couvrant les principaux cas d'usage IA (rédaction, synthèse, traduction, recherche documentaire, génération de code) et s'assurer de leur accessibilité, de leur performance et de leur ergonomie afin de réduire la pression incitative au shadow AI.
Référentiels sources	CESIN 2026 ; stratégie souveraineté Groupe
Contrôle testable / preuve	Catalogue des SIA souverains publié ; taux d'adoption suivi ; satisfaction utilisateurs mesurée semestriellement.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : DSI — Consulté : RSSI, métier — Informé : Comité IA
Fréquence de revue	Revue semestrielle

Identifiant	SIA-112
Exigence	Le Groupe, lorsqu'il met à disposition un GPAI de sa propre conception à des tiers ou à ses filiales, doit respecter les obligations des fournisseurs de GPAI au sens de l'AI Act : documentation technique conforme annexe XI, information aux déployeurs en aval, politique de respect du droit d'auteur, résumé des données d'entraînement.
Référentiels sources	AI Act art. 53 ; ISO 42001
Contrôle testable / preuve	Documentation technique produite et tenue à jour ; information aux déployeurs en aval formalisée ; audit de conformité annuel.
Tier applicable (AI Act × AISVS)	Fournisseur GPAI interne
Rôle RACI	Responsable : Model Steward — Consulté : DPO, Juridique, RSSI — Informé : Comité IA
Fréquence de revue	À la mise à disposition + revue annuelle

Identifiant	SIA-113
Exigence	Tout GPAI à risque systémique développé, acquis ou déployé par le Groupe au sens de l'article 51 de l'AI Act doit faire l'objet des obligations renforcées : évaluation systémique, red teaming avec résultats partagés à l'AI Office le cas échéant, suivi des incidents graves, cybersécurité renforcée au niveau de l'état de l'art.
Référentiels sources	AI Act art. 55
Contrôle testable / preuve	Rapport d'évaluation systémique ; registre des incidents graves ; politique cybersécurité renforcée documentée.
Tier applicable (AI Act × AISVS)	GPAI à risque systémique
Rôle RACI	Responsable : RSSI — Consulté : DPO, Juridique — Informé : Comité des Risques, DG
Fréquence de revue	Continue ; rapport semestriel

Identifiant	SIA-114
Exigence	L'usage de GPAI publics par le Groupe doit faire l'objet d'une évaluation régulière du risque agrégé : volumes transférés, catégories de données, finalités, incidents, évolutions contractuelles du fournisseur, position CNIL et régulateurs. L'évaluation alimente le comité IA et peut conduire à restreindre ou interdire un GPAI public donné.
Référentiels sources	CESIN 2026 ; CNIL ; AI Act art. 4
Contrôle testable / preuve	Rapport semestriel au Comité IA ; décisions documentées ; mise à jour de la matrice d'autorisation.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : DPO, Juridique — Informé : Comité IA, DG
Fréquence de revue	Semestrielle

Identifiant	SIA-115
Exigence	Le Groupe doit informer les parties prenantes externes pertinentes — adhérents, partenaires, régulateurs, instances représentatives du personnel — de manière proportionnée, de son usage de SIA dans les processus les affectant, en respectant ses obligations de transparence légale (RGPD, AI Act) et contractuelle.
Référentiels sources	RGPD art. 13-14 ; AI Act art. 50 ; Code du travail
Contrôle testable / preuve	Mentions d'information à jour dans les communications, contrats, politiques de confidentialité, documents IRP ; revue annuelle juridique.
Tier applicable (AI Act × AISVS)	Tous SIA à impact externe
Rôle RACI	Responsable : DPO — Consulté : Juridique, Communication, DRH — Informé : Comité IA

Fréquence de revue	Annuelle
---------------------------	----------

14. Détection, incident response et red teaming

La capacité à détecter les incidents de sécurité affectant les SIA, à y répondre dans les délais et selon les canaux réglementaires exigés, et à valider en continu la posture de sécurité par des exercices offensifs dédiés, constitue un pilier essentiel de la présente politique. L'hypothèse de travail retenue est celle de l'inévitabilité des incidents : ce chapitre vise à les minimiser, les contenir, en tirer les enseignements et les communiquer aux parties prenantes.

14.1. Typologie des incidents IA

Gravité	Exemples	Délai d'activation	Destinataires
Critique	Fuite massive de données adhérents, décision erronée causant préjudice significatif, compromission d'un agent, GPAI systémique corrompu	< 1h	DG, RSSI, DPO, ACPR, CNIL, ANSSI
Majeur	Attaque adversariale réussie, dérive significative, biais détecté avec impact, incident DORA majeur	< 4h	RSSI, DPO, Comité IA, autorités selon matrice SIA-118
Mineur	Tentative bloquée, faux positif DLP significatif, incident opérationnel limité	< 24h	RSSI, équipe sécurité, SOC
Information	Événement à suivre, signal faible	< 72h	RSSI, SOC

14.2. Matrice de notifications réglementaires

En cas d'incident, les obligations de notification cumulent plusieurs cadres. Le tableau ci-dessous rappelle les délais principaux applicables. Le détail opérationnel figure en annexe H (Playbook incident IA).

Cadre	Nature du délai	Délai	Autorité
NIS2	Pré-notification	< 24h	ANSSI (CSIRT national)
NIS2	Notification initiale	< 72h	ANSSI
NIS2	Rapport final	< 1 mois	ANSSI
DORA	Notification incident ICT majeur	Selon RTS	ACPR
RGPD	Notification violation données	< 72h	CNIL
AI Act	Incident grave SIA haut risque	< 15 jours	Autorité nationale AI Act
AI Act	GPAI systémique — incident grave	Sans délai	AI Office (Commission européenne)

14.3. Exigences

Identifiant	SIA-116
Exigence	Un dispositif de détection des incidents de sécurité spécifiques aux SIA doit être déployé et intégré au SOC du Groupe, couvrant : attaques adversariales (prompt injection, jailbreak, evasion), tentatives d'exfiltration modèle ou données, anomalies comportementales, dérives majeures, accès non autorisés aux pipelines.

Référentiels sources	ISO 27090 §5.4 ; MITRE ATLAS ; NIS2 art. 21 ; DORA art. 10
Contrôle testable / preuve	Règles de détection MITRE ATLAS intégrées au SIEM ; taxonomie des alertes documentée ; taux de détection testé annuellement.
Tier applicable (AI Act × AISVS)	Tous tiers — obligation renforcée AISVS L2-L3
Rôle RACI	Responsable : RSSI — Consulté : SOC, Model Steward — Informé : Comité IA
Fréquence de revue	Continue ; revue semestrielle des règles

Identifiant	SIA-117
Exigence	Les incidents IA doivent être qualifiés selon une typologie en quatre niveaux : Critique (fuite massive de données adhérents, décision erronée causant préjudice significatif, prise de contrôle d'un agent, GPAI systémique compromis), Majeur (attaque réussie, dérive significative, biais détecté avec impact), Mineur (tentative bloquée, faux positif DLP significatif), Information (événement à suivre).
Référentiels sources	ISO 27090 §5.4 ; ENISA ; AI Act art. 73
Contrôle testable / preuve	Taxonomie documentée et diffusée ; playbook par niveau ; registre des incidents avec qualification.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : RSSI — Consulté : DPO, propriétaire métier — Informé : Comité IA
Fréquence de revue	À chaque incident ; revue annuelle de la taxonomie

Identifiant	SIA-118
Exigence	Les délais de notification applicables doivent être respectés pour chaque cadre réglementaire concerné : NIS2 (pré-notification < 24h à l'ANSSI, notification initiale < 72h, rapport final < 1 mois), DORA (notification ICT majeure selon règles ITS), RGPD (< 72h à la CNIL en cas de violation), AI Act (incident grave < 15 jours à l'autorité compétente). Un tableau de synchronisation est maintenu et appliqué automatiquement.
Référentiels sources	NIS2 art. 23 ; DORA art. 19 ; RGPD art. 33 ; AI Act art. 73
Contrôle testable / preuve	Tableau de synchronisation des délais diffusé ; exercice semestriel de notification croisée ; registre des notifications réellement effectuées.
Tier applicable (AI Act × AISVS)	Tous tiers — obligation absolue
Rôle RACI	Responsable : RSSI — Approbateur : Direction Juridique — Consulté : DPO, Direction de la Communication — Informé : DG, Comité des Risques
Fréquence de revue	Continue ; exercice semestriel

Identifiant	SIA-119
--------------------	----------------

Exigence	Tout incident IA de niveau Critique ou Majeur doit déclencher l'activation de la Cellule de Crise IA (voir SIA-013) selon les délais du ch. 5, avec convocation du RSSI, du DPO, du DSI, de la Direction Juridique, de la Direction de la Communication et du propriétaire métier concerné.
Référentiels sources	ISO 27001 §5.29 ; DORA art. 11 ; ANSSI
Contrôle testable / preuve	Procédure écrite ; annuaire de crise à jour testé trimestriellement ; comptes-rendus des activations archivés.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : RSSI — Approbateur : DG — Consulté : DPO, DSI, Juridique — Informé : Comité des Risques
Fréquence de revue	À chaque incident Critique/Majeur ; exercice semestriel

Identifiant	SIA-120
Exigence	Tout SIA de tier AISVS L3, tout SIA AI Act haut risque et tout système agentique à impact personnes doit faire l'objet d'une campagne de red teaming trimestrielle, conduite par une équipe distincte des développeurs, utilisant MITRE ATLAS comme taxonomie de référence et couvrant les chaînes d'attaque emblématiques du secteur.
Référentiels sources	CLUSIF SIA-14 ; MITRE ATLAS ; ISO 27090 §5.3 ; AI Act art. 55
Contrôle testable / preuve	Planning trimestriel ; rapports de red teaming archivés ; plans de remédiation avec dates et responsables ; clôture tracée.
Tier applicable (AI Act × AISVS)	AISVS L3 ; AI Act haut risque ; agentique impact personnes
Rôle RACI	Responsable : RSSI — Consulté : Model Steward — Informé : Comité IA, Audit interne
Fréquence de revue	Trimestrielle

Identifiant	SIA-121
Exigence	Des exercices de purple teaming associant équipes offensives et défensives doivent être conduits au moins semestriellement sur un échantillon de SIA critiques, afin de renforcer la détection en conditions quasi-réelles et d'accélérer la capitalisation des enseignements.
Référentiels sources	MITRE ATLAS ; ANSSI ; ENISA
Contrôle testable / preuve	Planning semestriel ; rapports partagés RSSI/SOC ; mesures d'efficacité (temps de détection, temps de réponse).
Tier applicable (AI Act × AISVS)	AISVS L3 ; AI Act haut risque
Rôle RACI	Responsable : RSSI — Consulté : SOC, Model Steward — Informé : Comité IA
Fréquence de revue	Semestrielle

Identifiant	SIA-122
Exigence	Des exercices de tabletop (simulation sur table) couvrant des scénarios de crise IA — fuite massive de données adhérents via RAG, compromission d'un agent autonome, hallucination en masse dans une communication client, détection d'un deepfake dans un processus de souscription — doivent être organisés au moins semestriellement, impliquant la Cellule de Crise IA et la Direction Générale.
Référentiels sources	NIS2 art. 21 ; DORA art. 24 ; ANSSI
Contrôle testable / preuve	Scénarios documentés ; rapports d'exercice archivés ; plans d'amélioration assortis de dates et responsables.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : Cellule de Crise — Informé : DG, Comité des Risques
Fréquence de revue	Semestrielle

Identifiant	SIA-123
Exigence	Tout incident Critique ou Majeur doit faire l'objet d'un post-mortem formalisé dans un délai de 15 jours ouvrés, couvrant : chronologie, causes racines, impact réel et potentiel, actions de remédiation, mesures préventives, enseignements pour le reste du portefeuille IA. Le post-mortem est présenté au Comité IA et, pour les cas Critiques, au Comité des Risques.
Référentiels sources	ISO 27001 §5.27 ; NIST AI RMF Manage ; DORA art. 11
Contrôle testable / preuve	Rapport de post-mortem archivé ; plan d'action avec suivi au Comité IA ; intégration des enseignements aux procédures.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : RSSI — Consulté : propriétaire métier, DPO, DSI — Informé : Comité IA, Comité des Risques
Fréquence de revue	À chaque incident Critique/Majeur

Identifiant	SIA-124
Exigence	Le Groupe devrait participer activement aux dispositifs de partage d'information sur les menaces IA : CERT-FR, ISAC sectoriel (santé, assurance, banque), initiatives ANSSI et ENISA. Les incidents anonymisés sont partagés aux communautés pertinentes dans le respect des obligations de confidentialité et des intérêts commerciaux.
Référentiels sources	NIS2 art. 29 ; ANSSI ; ENISA
Contrôle testable / preuve	Adhésion documentée aux dispositifs ; journal des partages d'information ; veille entrante intégrée au dispositif de détection.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : Juridique — Informé : Comité IA

Fréquence de revue	Continue
---------------------------	----------

Identifiant	SIA-125
Exigence	Une base de connaissance des incidents IA et des enseignements tirés doit être tenue par le RSSI, accessible aux acteurs habilités, utilisée pour la formation continue, la mise à jour des scénarios de red teaming et l'adaptation de la politique. La base est revue annuellement pour en extraire les tendances.
Référentiels sources	ISO 27001 §5.27 ; NIST AI RMF Manage
Contrôle testable / preuve	Base de connaissance en place ; rapport annuel de tendances ; intégration aux contenus de formation.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : Model Steward, SOC — Informé : Comité IA
Fréquence de revue	Continue ; rapport annuel

15. Conformité réglementaire

Ce chapitre consolide en un lieu unique les obligations de conformité applicables aux SIA du Groupe. Il ne se substitue pas aux politiques transverses existantes (PSSIG, politique RGPD, dispositif DORA, dispositif NIS2), mais les articule spécifiquement pour ce qui concerne l'IA. Chaque obligation réglementaire majeure est ancrée dans une ou plusieurs exigences des chapitres 5 à 14, dont la traçabilité est restituée en annexe B.

15.1. Cartographie réglementaire

Cadre	Objet principal pour l'IA	Autorité
AI Act (Règlement 2024/1689)	Règles harmonisées SIA — obligations par niveau de risque	AI Office, autorités nationales
RGPD (Règlement 2016/679)	Protection des données personnelles, AIPD, décisions automatisées	CNIL
DORA (Règlement 2022/2554)	Résilience opérationnelle numérique — gestion ICT, tiers, incidents, tests	ACPR
NIS2 (Directive 2022/2555)	Cybersécurité entités essentielles/importantes — art. 20, 21, 23	ANSSI
HDS	Hébergement des données de santé	ANS, Ministère de la Santé
ISO 42001	Système de management IA (certification)	Organismes de certification accrédités
ETSI prEN 304 223 / prEN 18282	Cybersécurité IA / presumption of conformity AI Act	ETSI / CEN-CENELEC

15.2. Exigences

Identifiant	SIA-126
Exigence	Un dispositif de veille réglementaire IA doit être opérationnel, couvrant AI Act et ses actes délégués, DORA et ses RTS/ITS, NIS2 et sa transposition française, RGPD et positions CNIL, HDS, normes ETSI et CEN-CENELEC (prEN 304 223, prEN 18282), ISO 42001 et évolutions. La veille alimente un comité trimestriel dédié qui décide des impacts et des adaptations de la politique.
Référentiels sources	AI Act ; DORA ; NIS2 ; ISO 42001 §9.3
Contrôle testable / preuve	Dispositif de veille documenté ; compte-rendu trimestriel au Comité IA ; journal des adaptations politique.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : Direction Juridique — Consulté : RSSI, DPO — Informé : Comité IA, Comité des Risques
Fréquence de revue	Continue ; revue trimestrielle

Identifiant	SIA-127
Exigence	Le Groupe doit tenir une feuille de route de conformité AI Act publiée et tenue à jour, comportant pour chaque obligation et chaque échéance (août 2025 pour GPAI, août 2026 pour haut risque, août 2027 pour obligations complètes) : périmètre impacté, actions à mener, responsable, état d'avancement, jalons. La feuille de route est revue semestriellement par le Comité des Risques.
Référentiels sources	AI Act art. 113 ; prEN 18282
Contrôle testable / preuve	Feuille de route à jour ; indicateurs de complétude par échéance ; rapports semestriels au Comité des Risques.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : DPO — Consulté : RSSI, Juridique — Informé : Comité des Risques, DG
Fréquence de revue	Semestrielle

Identifiant	SIA-128
Exigence	Les SIA critiques au sens DORA — supportant des fonctions métiers critiques ou importantes — doivent être intégrés au cadre de gestion des risques ICT du Groupe (registre des systèmes, testing, gestion des tiers, gestion des incidents). La classification DORA est cohérente avec le tiering interne du ch. 6.
Référentiels sources	DORA art. 5-10 ; DORA art. 24-27 (testing)
Contrôle testable / preuve	Cartographie DORA des SIA critiques ; intégration dans le registre ICT ; TLPT planifié pour les systèmes éligibles.
Tier applicable (AI Act × AISVS)	SIA supportant fonction critique au sens DORA
Rôle RACI	Responsable : RSSI — Consulté : risk manager ICT — Informé : ACPR si demandé
Fréquence de revue	Continue ; revue annuelle

Identifiant	SIA-129
Exigence	Pour les SIA relevant du périmètre NIS2 du Groupe (entité importante ou essentielle), les obligations de gestion des risques cybersécurité (art. 21), de notification d'incident selon les délais 24h/72h/1 mois (art. 23) et de sensibilisation du management (art. 20) doivent être intégrées et documentées.
Référentiels sources	NIS2 art. 20, 21, 23
Contrôle testable / preuve	Intégration NIS2 documentée ; procédures de notification testées ; attestation de formation du management.
Tier applicable (AI Act × AISVS)	Selon périmètre NIS2 du Groupe
Rôle RACI	Responsable : RSSI — Approbateur : Direction Générale — Informé : ANSSI

Fréquence de revue	Continue ; revue annuelle
---------------------------	---------------------------

Identifiant	SIA-130
Exigence	Tout SIA traitant des données de santé à caractère personnel doit être hébergé sur une infrastructure certifiée HDS. L'hébergeur et ses sous-traitants doivent satisfaire les engagements HDS tout au long du cycle de vie du SIA. L'ouverture d'un SIA santé conditionne la vérification d'un hébergement HDS valide.
Référentiels sources	HDS ; Code de la santé publique art. L.1111-8 ; ANS
Contrôle testable / preuve	Attestation HDS en cours de validité archivée ; revue annuelle ; vérification des sous-traitants.
Tier applicable (AI Act × AISVS)	SIA traitant données santé — impératif
Rôle RACI	Responsable : DPO — Consulté : RSSI, DSI — Informé : médecin-conseil
Fréquence de revue	À l'initiation + annuelle

Identifiant	SIA-131
Exigence	Tout SIA entrant dans le registre des traitements RGPD doit y figurer avec : finalité, base légale, catégories de données, destinataires, durées de conservation, mesures de sécurité, AIPD si applicable. Le registre est tenu par le DPO et accessible à l'audit interne et, sur demande, à la CNIL.
Référentiels sources	RGPD art. 30, 35, 36 ; CNIL
Contrôle testable / preuve	Registre RGPD à jour ; AIPD archivées ; cohérence vérifiée avec le registre IA (SIA-001).
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : DPO — Consulté : propriétaire métier — Informé : RSSI
Fréquence de revue	Continue ; audit semestriel

Identifiant	SIA-132
Exigence	Le Groupe devrait se doter d'un système de management de l'IA (AIMS) conforme à ISO 42001 et engager une démarche de certification à horizon 2027, avec jalons : auto-évaluation de maturité, plan de mise en conformité, pré-audit, audit de certification. L'AIMS s'intègre au SMSI ISO 27001 existant.
Référentiels sources	ISO 42001 ; ISO 27001 §4.4
Contrôle testable / preuve	Plan AIMS publié ; auto-évaluation de maturité semestrielle ; rapport d'avancement annuel au Comité des Risques.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : Audit interne, Qualité — Informé : DG

Fréquence de revue	Semestrielle
---------------------------	--------------

Identifiant	SIA-133
Exigence	Un audit externe annuel de conformité IA doit être conduit par un tiers indépendant accrédité, couvrant gouvernance, tiering, cycle de vie, supply chain, gestion des incidents, et — à partir de l'entrée en vigueur de la certification — l'AIMS ISO 42001. Le rapport d'audit est présenté au Comité des Risques et à la Direction Générale.
Référentiels sources	ISO 42001 §9.2 ; AI Act ; DORA art. 6
Contrôle testable / preuve	Rapport d'audit externe annuel ; plan d'action assorti de dates et responsables ; suivi de clôture.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : Audit interne — Approbateur : Comité des Risques — Consulté : RSSI, DPO — Informé : DG
Fréquence de revue	Annuelle

Identifiant	SIA-134
Exigence	Pour les SIA supportant des fonctions métiers critiques ou importantes au sens DORA, des tests de pénétration avancés (Threat Led Penetration Testing ou équivalents) doivent être conduits selon les exigences des RTS DORA, couvrant l'ensemble de la surface d'attaque incluant les composants IA.
Référentiels sources	DORA art. 26 et RTS TLPT
Contrôle testable / preuve	Planning TLPT ; rapport TLPT archivé ; plan de remédiation suivi ; échange avec l'ACPR si requis.
Tier applicable (AI Act × AISVS)	SIA DORA critique
Rôle RACI	Responsable : RSSI — Consulté : Direction Juridique — Informé : ACPR
Fréquence de revue	Selon périodicité DORA (au moins tous les 3 ans)

Identifiant	SIA-135
Exigence	Le reporting réglementaire périodique aux autorités (ACPR pour DORA et Solvabilité II lorsque pertinent, CNIL pour RGPD, ANSSI pour NIS2, éventuellement AI Office pour GPAI systémique) doit être piloté par un responsable identifié, avec plan de production, revue qualité et archivage des réponses transmises.
Référentiels sources	ACPR ; CNIL ; ANSSI ; AI Act art. 55
Contrôle testable / preuve	Plan de reporting annuel ; archives des rapports transmis ; journal des échanges avec les autorités.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel

Rôle RACI	Responsable : Direction Juridique — Consulté : RSSI, DPO, Direction des Risques — Informé : DG
Fréquence de revue	Selon calendrier réglementaire

16. Formation et sensibilisation

La maîtrise du risque IA repose autant sur les dispositifs techniques et organisationnels que sur la compétence des femmes et des hommes qui conçoivent, déploient, exploitent, supervisent et utilisent les SIA du Groupe. Le présent chapitre établit le cadre de formation et de sensibilisation, en articulation avec la politique RH formation et la politique de sensibilisation cybersécurité existantes, et en s'appuyant sur les recommandations du baromètre CESIN 2026.

L'article 4 de l'AI Act institue une obligation de compétence IA pour les fournisseurs et les déployeurs de SIA. Cette obligation est déclinée opérationnellement dans les exigences ci-dessous.

16.1. Publics et volumes de formation

Public	Formation	Durée	Fréquence
Tous collaborateurs	Sensibilisation IA-sécurité	1h	Embauche + annuelle
Utilisateurs SIA internes	Usage responsable par outil	2h	Avant accès + annuelle
Développeurs IA	Sécurité développement IA	8h	Avant projet + annuelle
Superviseurs HITL	Supervision humaine et anomalies	4h	Avant supervision + annuelle
RSSI, DPO, DSI	Gouvernance et cadre normatif IA	16h	Annuelle
Management	Enjeux stratégiques et obligations AI Act	2h	Annuelle
Comités IA, Risques, Éthique	Sujets émergents, arbitrages	4h	Annuelle

16.2. Exigences

Identifiant	SIA-136
Exigence	Un plan de formation et de sensibilisation IA-sécurité doit être établi annuellement par le RSSI en coordination avec la DRH, validé par le Comité IA, couvrant : tous les collaborateurs (sensibilisation), les utilisateurs de SIA internes, les développeurs IA, les superviseurs HITL, les RSSI / DPO / DSI, le management, les membres d'instances de gouvernance IA.
Référentiels sources	AI Act art. 4 ; CESIN 2026 ; NIST AI 100-2 ; CLUSIF SIA-01, 22
Contrôle testable / preuve	Plan annuel validé ; taux de complétion suivi par public ; rapport annuel au Comité IA.
Tier applicable (AI Act x AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : DRH / formation — Consulté : RSSI, DPO — Informé : Comité IA
Fréquence de revue	Annuelle

Identifiant	SIA-137
Exigence	Chaque collaborateur doit suivre, à l'embauche puis annuellement, une sensibilisation obligatoire d'au moins une heure couvrant : notions clés d'IA, risques sécurité et confidentialité, règles de la présente politique, identification du shadow AI, points de contact.
Référentiels sources	AI Act art. 4 ; CESIN 2026 ; CLUSIF SIA-02
Contrôle testable / preuve	Plateforme de formation déployée ; attestations individuelles ; taux de complétion publié au Comité IA.
Tier applicable (AI Act × AISVS)	Tous collaborateurs
Rôle RACI	Responsable : DRH — Consulté : RSSI — Informé : managers
Fréquence de revue	À l'embauche + annuelle

Identifiant	SIA-138
Exigence	Les membres de la fonction sécurité (RSSI et équipe), de la fonction DPO et de la DSI directement impliqués dans les SIA doivent suivre une formation approfondie de 16 heures minimum par an, couvrant : AI Act et actes délégués, ISO 42001, ETSI prEN 304 223, prEN 18282, NIST AI RMF, OWASP AISVS, MITRE ATLAS, red teaming IA, techniques d'audit IA.
Référentiels sources	AI Act art. 4 ; CESIN 2026 ; CLUSIF SIA-01
Contrôle testable / preuve	Programme de formation annuel ; attestations individuelles ; évaluation des acquis.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : DRH — Consulté : RSSI, DPO — Informé : Comité IA
Fréquence de revue	Annuelle

Identifiant	SIA-139
Exigence	Les développeurs IA doivent suivre, avant tout projet et annuellement, une formation de 8 heures minimum couvrant : OWASP LLM Top 10, OWASP AISVS, OWASP GenAI Data Security, ISO 27090, pratiques de pipeline sécurisé, gestion des secrets, revue de code IA, prompt engineering sécurisé, risques du code généré par IA (en lien avec SIA-093).
Référentiels sources	CLUSIF SIA-01 ; OWASP ; NIST SSDF
Contrôle testable / preuve	Programme documenté ; attestations ; évaluation pratique intégrée.
Tier applicable (AI Act × AISVS)	Tous développeurs IA
Rôle RACI	Responsable : DRH / lead tech — Consulté : RSSI — Informé : Comité IA
Fréquence de revue	Avant projet + annuelle

Identifiant	SIA-140
Exigence	Les superviseurs humains de SIA AI Act haut risque ou AISVS L2-L3 doivent suivre une formation dédiée de 4 heures minimum par an, couvrant : rôle et responsabilités HITL, limites et modes de défaillance du SIA supervisé, interfaces et outils, procédures d'escalade, prévention du biais d'automation.
Référentiels sources	AI Act art. 14(4)(a) ; OWASP AISVS Ch. 14 ; SIA-097
Contrôle testable / preuve	Programme spécifique par SIA ; attestations ; évaluation.
Tier applicable (AI Act × AISVS)	AI Act haut risque ; AISVS L2-L3
Rôle RACI	Responsable : propriétaire métier — Consulté : DRH, RSSI — Informé : DPO
Fréquence de revue	Avant supervision + annuelle

Identifiant	SIA-141
Exigence	Des communications régulières — newsletters, alertes internes, retours d'expérience anonymisés, points d'actualité réglementaire — doivent être diffusées par le RSSI aux populations concernées afin d'entretenir la vigilance et d'intégrer rapidement les enseignements d'incidents internes ou externes.
Référentiels sources	CESIN 2026 ; NIST AI RMF Govern
Contrôle testable / preuve	Calendrier de communication ; archives des diffusions ; mesure d'engagement.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : Direction Communication — Informé : DRH
Fréquence de revue	Continue ; cadence mensuelle minimale

Identifiant	SIA-142
Exigence	La maturité IA-sécurité du Groupe doit être évaluée annuellement : enquêtes de connaissance, mesure des comportements (taux de shadow AI détecté, incidents évitables), évaluation du retour sur formation, benchmark CESIN. Les résultats orientent le plan de formation de l'année suivante.
Référentiels sources	CESIN 2026 ; NIST AI RMF Measure
Contrôle testable / preuve	Rapport annuel de maturité ; comparaison d'année en année ; alimentation du plan SIA-136.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : DRH — Informé : Comité IA, DG
Fréquence de revue	Annuelle

17. Souveraineté numérique et maîtrise des tiers

Le Groupe opère au cœur d'un secteur où la confiance des adhérents repose sur la maîtrise effective des données traitées. Cette maîtrise inclut la capacité à savoir, contrôler et décider où et comment ces données sont traitées, sans dépendance incontrôlée à un acteur étranger dont la juridiction pourrait imposer des accès ou des contraintes incompatibles avec nos obligations. Le présent chapitre établit les principes de souveraineté numérique appliqués aux SIA, en cohérence avec les recommandations CESIN, ANSSI et CLUSIF.

La souveraineté numérique n'est pas un objectif absolu mais une exigence proportionnée à la sensibilité des données et à la criticité du SIA. Elle compose avec des critères fonctionnels, économiques et temporels, sans s'y soumettre.

17.1. Contexte

- 63 % des entreprises françaises font de la souveraineté numérique un critère de choix structurant pour les infrastructures critiques (CESIN 2026).
- 52 % des entreprises identifient la rigidité contractuelle des fournisseurs cloud comme un risque (CESIN 2026).
- 48 % identifient un risque lié aux lois extraterritoriales (CESIN 2026).
- Le Groupe, acteur de la protection sociale, considère ces tendances comme particulièrement alignées avec ses valeurs et sa mission.

17.2. Matrice d'hébergement par classification

Classification	Datacenter Groupe (France)	SaaS France / UE	SaaS hors UE
Public (C0)	Autorisé	Autorisé	Autorisé
Interne (C1)	Autorisé	Autorisé	Interdit
Confidentiel (C2)	Autorisé	Autorisé avec conditions	Interdit
Secret (C3)	Autorisé	Interdit sauf SecNumCloud	Interdit
Données santé	Autorisé HDS	Autorisé HDS France/UE	Interdit
Données financières adhérents	Autorisé	Autorisé France/UE	Interdit

17.3. Exigences

Identifiant	SIA-143
Exigence	Le Groupe affirme la souveraineté numérique comme un critère structurant de ses choix IA, au même titre que la sécurité, la conformité et la performance. Cette position se traduit par des exigences différenciées selon la sensibilité des données et la criticité du SIA, opposables aux directions métier et aux fonctions achats.
Référentiels sources	CESIN 2026 ; ANSSI ; CLUSIF
Contrôle testable /	Position validée en Direction Générale ; déclinaison opérationnelle dans la

preuve	politique achats ; revue annuelle.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : Direction Générale — Consulté : RSSI, Achats — Informé : Comité IA
Fréquence de revue	Annuelle

Identifiant	SIA-144
Exigence	Les SIA traitant des données classées Confidentiel ou Secret, les SIA supportant des fonctions critiques, et tout SIA traitant des données de santé adhérent doivent être hébergés sur infrastructure certifiée HDS, SecNumCloud (recommandé pour AISVS L3) ou équivalent reconnu par l'ANSSI et hébergée en France ou dans l'UE, sauf dérogation validée par le Comité des Risques.
Référentiels sources	HDS ; SecNumCloud ; RGPD art. 44-49 ; ANSSI
Contrôle testable / preuve	Inventaire des hébergements ; attestations de certification ; dérogations tracées et motivées.
Tier applicable (AI Act × AISVS)	Données Confidentiel/Secret ; fonctions critiques ; santé
Rôle RACI	Responsable : DSI — Approbateur : RSSI — Consulté : Direction Juridique — Informé : Comité IA
Fréquence de revue	Continue ; revue annuelle

Identifiant	SIA-145
Exigence	À caractéristiques fonctionnelles et de sécurité équivalentes, les éditeurs européens et les composants issus d'initiatives de souveraineté numérique (modèles ouverts européens, cloud souverain, écosystèmes Gaia-X) devraient être privilégiés lors des choix d'acquisition, en cohérence avec la stratégie d'indépendance du Groupe.
Référentiels sources	Stratégie souveraineté Groupe ; CESIN 2026
Contrôle testable / preuve	Grille de choix documentée ; journalisation des décisions ; reporting annuel au Comité IA.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : Direction des Achats — Consulté : RSSI, DSI — Informé : Comité IA
Fréquence de revue	Continue ; rapport annuel

Identifiant	SIA-146
Exigence	Toute contractualisation d'un composant IA intégrant le traitement de données du Groupe doit inclure, dans les clauses contractuelles types, la clause de non-rétroaction (voir SIA-065), la clause de localisation

	(France/UE), la clause d'audit (SIA-071), la clause de stratégie de sortie (SIA-072), et les clauses AI Act pour les SIA à haut risque.
Référentiels sources	RGPD art. 28 ; AI Act art. 25 ; DORA art. 28 ; CLUSIF
Contrôle testable / preuve	Clauses types validées par la Direction Juridique ; revue annuelle des contrats existants ; action de régularisation des contrats non conformes.
Tier applicable (AI Act × AISVS)	Tous contrats IA
Rôle RACI	Responsable : Direction Juridique — Consulté : RSSI, DPO, Achats — Informé : Comité IA
Fréquence de revue	Continue ; revue annuelle

Identifiant	SIA-147
Exigence	Le Groupe doit documenter, pour chaque SIA dépendant d'un composant critique externe (modèle propriétaire, API, infrastructure cloud), un plan de réversibilité et de substitution permettant la migration ou l'internalisation en cas de rupture, d'évolution réglementaire défavorable, de défaillance du fournisseur, ou de décision stratégique. Le plan est testé tous les 24 mois pour les fournisseurs critiques DORA.
Référentiels sources	DORA art. 28 ; ANSSI ; ENISA
Contrôle testable / preuve	Plans de réversibilité archivés ; exercices de test documentés ; rapport bisannuel au Comité des Risques.
Tier applicable (AI Act × AISVS)	Fournisseurs critiques
Rôle RACI	Responsable : DSI — Consulté : RSSI, Juridique — Informé : Comité des Risques
Fréquence de revue	Continue ; test bisannuel

Identifiant	SIA-148
Exigence	Le Groupe doit suivre l'évolution des risques extraterritoriaux affectant les composants IA qu'il utilise : Cloud Act américain, lois chinoises sur la cybersécurité, évolutions du Schrems et Data Privacy Framework, sanctions internationales. Les adaptations nécessaires sont intégrées via SIA-126.
Référentiels sources	CESIN 2026 ; CNIL Schrems II ; ANSSI
Contrôle testable / preuve	Cartographie des risques extraterritoriaux ; rapport semestriel au Comité des Risques ; actions d'atténuation documentées.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : Direction Juridique — Consulté : RSSI, DPO — Informé : Comité des Risques
Fréquence de revue	Semestrielle

Identifiant	SIA-149
Exigence	Le Groupe devrait participer à des initiatives collectives ou sectorielles renforçant la souveraineté numérique IA : Gaia-X, groupes de travail CLUSIF et CESIN, consortiums de l'écosystème santé-protection sociale, pilotes d'hébergement et de modèles souverains, afin de contribuer à la maturation de l'offre européenne.
Référentiels sources	Stratégie Groupe ; CESIN 2026 ; CLUSIF
Contrôle testable / preuve	Adhésions documentées ; contributions évaluées annuellement ; veille stratégique partagée au Comité IA.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : Direction Juridique — Informé : DG, Comité IA
Fréquence de revue	Annuelle

18. Sanctions et mesures disciplinaires

La présente politique étant opposable à tous les collaborateurs, prestataires et sous-traitants (voir ch. 1), ses manquements font l'objet de sanctions graduées selon leur gravité. Le présent chapitre ne se substitue pas au règlement intérieur du Groupe mais le complète pour les situations spécifiques à l'IA. Il s'articule par ailleurs avec les régimes civil et pénal applicables.

18.1. Grille de sanctions

Niveau	Type de manquement (exemples)	Sanction typique
Mineur	Usage non intentionnel de SIA public sur données non sensibles ; oubli de formalisation	Avertissement + formation
Majeur	Usage de SIA public sur données internes ; contournement de contrôle technique ; non-déclaration d'un SIA	Blâme ; restriction d'accès ; mutation
Grave	Usage de SIA public sur données adhérents ; contournement délibéré des contrôles souveraineté ; fuite non intentionnelle	Suspension ; procédure disciplinaire ; signalement CNIL
Très grave	Fuite volontaire ; revente de données ; sabotage d'un SIA ; complicité externe	Licenciement pour faute grave ; signalement pénal

18.2. Exigences

Identifiant	SIA-150
Exigence	Les manquements à la présente politique sont sanctionnés selon une grille graduée à quatre niveaux : Mineur (usage non intentionnel, données non sensibles), Majeur (usage de SIA public sur données internes, contournement de contrôles), Grave (exposition de données adhérents, fuite, contournement délibéré des contrôles de souveraineté), Très grave (fuite volontaire, revente, sabotage, complicité externe). Chaque niveau déclenche un traitement gradué : avertissement et formation pour les cas mineurs, sanction disciplinaire pouvant aller jusqu'au licenciement pour faute grave et signalement pénal pour les cas très graves.
Référentiels sources	Code du travail L.1331-1 ; RGPD art. 83-84 ; AI Act art. 99 ; règlement intérieur
Contrôle testable / preuve	Grille publiée en annexe du règlement intérieur ; registre des sanctions tenu par la DRH avec anonymisation statistique ; revue annuelle.
Tier applicable (AI Act × AISVS)	Tous collaborateurs
Rôle RACI	Responsable : DRH — Approbateur : Direction Générale — Consulté : RSSI, DPO, Juridique — Informé : IRP
Fréquence de revue	Application au cas par cas ; revue annuelle de la grille

Identifiant	SIA-151
Exigence	Toute procédure disciplinaire consécutive à un manquement à la présente politique doit respecter les droits de la défense du collaborateur : information écrite des griefs, entretien préalable avec possibilité d'assistance, instruction

	impartiale, décision motivée, voies de recours. Les dispositions du Code du travail et du règlement intérieur s'appliquent intégralement.
Référentiels sources	Code du travail L.1332-1 à L.1332-5 ; règlement intérieur
Contrôle testable / preuve	Procédure formalisée ; formation des managers aux procédures disciplinaires ; audit RH annuel.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : DRH — Consulté : Juridique — Informé : IRP
Fréquence de revue	Continue

Identifiant	SIA-152
Exigence	Les manquements à la présente politique qui constituent par ailleurs une infraction pénale (atteinte aux données, violation du secret professionnel, divulgation illégale, contrefaçon) ou une faute civile (manquement à une obligation contractuelle, préjudice à un tiers) doivent faire l'objet des suites appropriées : signalement au procureur de la République pour les faits pénaux, mise en œuvre des mécanismes de responsabilité civile pour les préjudices. Le RSSI et la Direction Juridique pilotent conjointement ces suites.
Référentiels sources	Code pénal art. 226-16 à 226-24 ; Code civil art. 1240 ; RGPD art. 84
Contrôle testable / preuve	Procédure de signalement documentée ; registre des signalements ; coordination RSSI / Juridique.
Tier applicable (AI Act × AISVS)	Tous tiers
Rôle RACI	Responsable : Direction Juridique — Consulté : RSSI, DPO — Informé : DG
Fréquence de revue	Au cas par cas

Identifiant	SIA-153
Exigence	Les cas significatifs de manquements à la présente politique, une fois traités et clos, peuvent faire l'objet d'une communication interne anonymisée à visée pédagogique, dans le respect des droits des personnes concernées. Cette communication nourrit le dispositif de sensibilisation (ch. 16) et contribue à la prévention de la récidive.
Référentiels sources	CESIN 2026 ; Règlement intérieur
Contrôle testable / preuve	Processus de communication validé par DRH et Juridique ; cas anonymisés publiés.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : DRH, Juridique — Informé : Comité IA
Fréquence de revue	Au cas par cas ; bilan annuel

19. Processus de revue et d'amélioration continue

La présente politique est conçue comme un dispositif vivant, qui évolue avec le cadre réglementaire, l'état de l'art technologique, la maturité du Groupe et l'enseignement tiré des incidents. Le présent chapitre définit la cadence de revue, les indicateurs de pilotage et les modalités de mise à jour.

19.1. Cadence de revue

Événement	Action
Revue annuelle programmée	Refonte ou reconduction pilotée par le RSSI, validée en Comité des Risques (SIA-154)
Publication d'un acte délégué AI Act, RTS DORA, évolution majeure	Revue d'urgence dans les 30 jours ouvrés (SIA-155)
Incident critique ou majeur	Intégration des enseignements via post-mortem (SIA-123, 158)
Nouvelle technologie disruptive	Évaluation ad hoc et amendement de la politique
Audit interne ou contrôle régulateur	Mise à jour selon recommandations

19.2. Indicateurs de performance (KPI)

Un panier d'indicateurs pilote la mise en œuvre effective de la politique. Les valeurs cibles sont calibrées annuellement en fonction de la maturité atteinte.

Indicateur	Cible indicative	Fréquence
Taux de conformité des SIA à la politique	> 95 %	Trimestrielle
Couverture Model Card / Risk Card pour SIA AISVS L2-L3	100 %	Trimestrielle
Red teaming effectué sur SIA AISVS L3 et AI Act haut risque	100 % par trimestre	Trimestrielle
MTTD incident IA (temps moyen de détection)	< 1h pour incidents critiques	Mensuelle
MTTC incident IA (temps moyen de contention)	< 4h pour incidents critiques	Mensuelle
Taux de détection du shadow AI	> 90 %	Mensuelle
Taux de complétion des formations obligatoires	> 95 %	Trimestrielle
Écarts d'audit ouverts au-delà des délais	< 5 % des écarts	Trimestrielle
Satisfaction utilisateurs des SIA souverains	> 4 / 5	Semestrielle

19.3. Exigences

Identifiant	SIA-154
Exigence	La présente politique doit faire l'objet d'une revue annuelle complète pilotée par le RSSI, avec contributions du DPO, de la DSI, de la Direction Juridique et des instances métier, validée en Comité des Risques. La revue examine la cohérence avec le cadre réglementaire en vigueur, l'état des incidents de l'année, l'évolution du portefeuille IA, les enseignements des audits et des exercices de red teaming.

Référentiels sources	ISO 42001 §9.3 ; ISO 27001 §9.3 ; NIST AI RMF Manage
Contrôle testable / preuve	Planification revue annuelle ; compte-rendu ; décisions de mise à jour validées ; diffusion de la nouvelle version.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Approbateur : Comité des Risques — Consulté : DPO, DSI, Juridique — Informé : DG
Fréquence de revue	Annuelle

Identifiant	SIA-155
Exigence	Une revue d'urgence doit être déclenchée en cas d'événement majeur impactant le cadre de la politique : publication d'un texte réglementaire structurant (acte délégué AI Act, RTS DORA, directive nationale), incident critique interne ou de place, décision d'une autorité de tutelle, évolution technologique disruptive. La revue d'urgence est conduite sous 30 jours ouvrés et peut aboutir à une mise à jour ciblée immédiate.
Référentiels sources	ISO 42001 §9.3 ; ISO 27001
Contrôle testable / preuve	Procédure d'urgence documentée ; journal des revues d'urgence ; mises à jour ciblées tracées.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Approbateur : Comité IA — Informé : Comité des Risques
Fréquence de revue	À événement

Identifiant	SIA-156
Exigence	Un jeu d'indicateurs de performance clé doit être défini, mesuré et publié : taux de conformité des SIA à la politique, couverture Model Card / Risk Card, fréquence et qualité du red teaming, MTDD et MTTC des incidents IA, taux de détection du shadow AI, satisfaction utilisateur des SIA souverains, taux de complétion des formations, projets IA validés en temps et en forme, écarts d'audit ouverts. La cible et la fréquence de chaque indicateur sont documentées.
Référentiels sources	ISO 42001 §9.1 ; NIST AI RMF Measure ; CESIN 2026
Contrôle testable / preuve	Tableau d'indicateurs publié ; revue mensuelle ou trimestrielle selon la nature ; rapport annuel au Comité IA.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : Model Stewards, DSI — Informé : Comité IA
Fréquence de revue	Mensuelle à trimestrielle selon indicateur

Identifiant	SIA-157
Exigence	Un tableau de bord de pilotage de la sécurité IA doit être maintenu, accessible aux instances de gouvernance, présentant la vision consolidée : portefeuille IA, tiers, incidents, audits, dérogations, dette technique, shadow AI, formation, conformité réglementaire. Le tableau de bord est présenté à chaque Comité IA et à chaque Comité des Risques.
Référentiels sources	ISO 42001 §9.1 ; CESIN 2026
Contrôle testable / preuve	Tableau de bord opérationnel ; captures archivées ; cohérence avec le registre central SIA-001.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : DSI — Informé : Comité IA, Comité des Risques
Fréquence de revue	Mise à jour continue ; présentation à chaque instance

Identifiant	SIA-158
Exigence	Les enseignements tirés des incidents IA (ch. 14) doivent être systématiquement intégrés aux mises à jour de la politique et des procédures associées, selon un processus formalisé : analyse en post-mortem, proposition de mise à jour, validation en Comité IA, révision de la politique si nécessaire, communication aux populations concernées.
Référentiels sources	NIST AI RMF Manage ; ISO 27001 §5.27
Contrôle testable / preuve	Traçabilité incident → mise à jour documentée ; journal des évolutions politique liées aux incidents.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : Model Stewards — Informé : Comité IA
Fréquence de revue	À chaque incident significatif

Identifiant	SIA-159
Exigence	Le Groupe devrait conduire annuellement un benchmark externe de sa posture IA-sécurité, s'appuyant sur les études CESIN, les publications CLUSIF, les retours des pairs sectoriels via les groupes de travail professionnels, les rapports d'observatoires (ANSSI, ENISA). Le benchmark alimente la revue annuelle et identifie les axes de progrès.
Référentiels sources	CESIN 2026 ; CLUSIF ; ENISA
Contrôle testable / preuve	Rapport de benchmark annuel présenté au Comité IA ; plan d'actions priorisées.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Consulté : Direction Juridique — Informé : Comité IA, DG

Fréquence de revue	Annuelle
---------------------------	----------

Identifiant	SIA-160
Exigence	Toute évolution de la présente politique — mise à jour annuelle, mise à jour d'urgence, corrections ponctuelles — doit suivre un processus documenté : proposition motivée, consultation des parties prenantes (RSSI, DPO, DSI, Juridique, IRP pour les points concernant les collaborateurs), validation en Comité IA, approbation finale en Comité des Risques pour les révisions structurelles ou par la DG pour les évolutions majeures, publication et communication.
Référentiels sources	ISO 42001 §7.5 ; ISO 27001 §7.5
Contrôle testable / preuve	Procédure de révision documentée ; historique des versions tracé ; communications archivées.
Tier applicable (AI Act × AISVS)	Gouvernance — structurel
Rôle RACI	Responsable : RSSI — Approbateur : Comité des Risques ou DG selon ampleur — Consulté : DPO, DSI, Juridique, IRP — Informé : ensemble des collaborateurs
Fréquence de revue	Continue ; version annuelle a minima

ANNEXES

Les annexes A à M complètent la politique avec les éléments de traçabilité, les templates, les checklists, le playbook d'incident, les contrôles avancés de priorité P2 et les références bibliographiques.

Annexe A — Glossaire intégral

Le présent glossaire complète celui du chapitre 3 en ajoutant les termes techniques émergents et les concepts mobilisés dans les annexes. La référence indiquée correspond à la source faisant autorité pour la définition retenue.

Terme	Définition	Source
AI-BOM	AI Bill of Materials : inventaire structuré des composants d'un SIA (modèles, datasets, bibliothèques, APIs, dépendances).	OWASP AISVS Ch. 6
AIIA	AI Impact Assessment : évaluation d'impact dédiée à l'IA, couvrant droits fondamentaux, santé, sécurité, discrimination.	AI Act art. 27
AIPD	Analyse d'Impact relative à la Protection des Données, obligatoire pour les traitements à risque élevé.	RGPD art. 35
AIMS	AI Management System : système de management de l'IA selon ISO/IEC 42001.	ISO 42001
AML	Adversarial Machine Learning : exploitation de vulnérabilités dans les composants d'un SIA.	NIST AI 100-2e2023
Attaque adversariale	Envoi de requêtes construites pour tromper ou altérer le fonctionnement d'un SIA.	ISO 27090
Canary token	Enregistrement synthétique unique inséré dans un dataset pour détecter une fuite.	OWASP AISVS
Chain-of-thought	Technique consistant à demander au modèle de verbaliser son raisonnement intermédiaire.	Recherche ML
Circuit breaker	Disjoncteur automatique limitant le volume, coût, latence ou comportement d'un SIA.	OWASP AISVS Ch. 9
Cycle de vie SIA	Séquence itérative : conception, développement, données, TEVV, déploiement, exploitation, retrait.	ISO 42001
Data Card	Document décrivant un dataset : origine, licence, qualité, représentativité, usages.	OWASP GenAI Data Security
Data poisoning	Altération intentionnelle des données d'entraînement ou de feedback.	OWASP LLM04
Deepfake	Contenu synthétique représentant de manière réaliste des personnes réelles.	AI Act art. 50(4)
Differential privacy	Technique statistique garantissant qu'une donnée individuelle ne peut être inférée d'une sortie agrégée.	NIST SP 800-226
DLP (sortant)	Data Loss Prevention : détection de fuites de données dans les sorties d'un système.	NIST
Drift	Dérive des performances d'un SIA due à l'écart entre données d'entraînement et données de production.	ISO 42001
Embedding	Représentation vectorielle dense d'un contenu (texte, image) produite par un modèle.	ML général
Explicabilité	Capacité à rendre compréhensible les éléments ayant produit une sortie du SIA.	CLUSIF
Federated learning	Entraînement distribué permettant l'apprentissage sans centralisation des données.	OWASP AISVS Ch. 12
Fine-tuning	Spécialisation d'un modèle pré-entraîné sur un jeu de données ciblé.	CLUSIF §1.16
GPAI	General Purpose AI Model : modèle d'IA à usage général.	AI Act art. 3(63)
GPAI systémique	GPAI à capacité à fort impact (seuils annexe XIII AI Act).	AI Act art. 51

Terme	Définition	Source
Guard rails	Mécanismes techniques et procéduraux empêchant un SIA de produire des sorties indésirables.	OWASP
Hallucination	Production par un modèle d'une sortie factuellement erronée ou non fondée.	OWASP LLM09
HITL	Human-In-The-Loop : supervision humaine avec 5 niveaux (0 à 4).	AI Act art. 14
HITL niveau 4	Action autonome d'un SIA avec kill switch et supervision renforcée.	OWASP AISVS Ch. 14
Homomorphic encryption	Chiffrement permettant le calcul sur les données chiffrées sans déchiffrement.	NIST
IA générative	Sous-ensemble de l'IA produisant du contenu (texte, image, audio, vidéo, code).	OWASP GenAI
Jailbreak	Technique de contournement des garde-fous d'un LLM pour obtenir une sortie normalement bloquée.	OWASP LLM01
Kill switch	Mécanisme permettant l'arrêt immédiat d'un SIA par un opérateur autorisé.	OWASP AISVS Ch. 9
LLM	Large Language Model : modèle génératif entraîné sur un large corpus textuel.	OWASP LLM Top 10
MCP	Model Context Protocol : protocole d'interaction standardisé entre modèles et outils externes.	OWASP AISVS Ch. 10
Model Card	Document décrivant un modèle : finalité, données, métriques, limites, risques.	Google / OWASP
Modèle d'IA	Réseau de neurones et ses paramètres (poids, biais).	CLUSIF §1.7
Poisoning	Voir data poisoning.	OWASP LLM04
Prompt	Instruction textuelle transmise à un SIA pour obtenir une réponse.	OWASP
Prompt injection	Insertion de directives malveillantes dans un prompt ou contexte.	OWASP LLM01
Prompt système	Instruction persistante définissant rôle, périmètre, contraintes d'un SIA.	OWASP
Purple teaming	Exercice associant équipes offensives (red) et défensives (blue).	MITRE
RAG	Retrieval Augmented Generation : enrichissement d'un LLM par recherche documentaire contextuelle.	Recherche ML
Red teaming IA	Exercice offensif structuré pour identifier les vulnérabilités d'un SIA.	MITRE ATLAS ; ISO 27090
Risk Card	Document identifiant et qualifiant les risques potentiels d'un SIA.	OWASP
SBOM IA	Software Bill of Materials étendu aux composants ML (modèles, frameworks, datasets).	CycloneDX-ML
Secure multi-party computation	Technique de calcul collaboratif sans partage de données brutes.	OWASP AISVS Ch. 12
Shadow AI	Usage non déclaré, non référencé, non contrôlé de SIA par des collaborateurs.	CESIN 2026
SIA	Système d'Intelligence Artificielle.	AI Act art. 3(1) ; ISO 42001
SIA haut risque	SIA relevant de l'annexe III de l'AI Act ou produits annexe I.	AI Act art. 6
TEVV	Test, Evaluation, Verification, Validation.	NIST AI RMF
TLPT	Threat Led Penetration Testing selon DORA.	DORA art. 26
Tool use	Capacité d'un agent à invoquer des outils externes pour accomplir	OWASP

Terme	Définition	Source
	une tâche.	Agentic Security
Watermarking	Technique de marquage détectable d'un modèle ou d'un contenu synthétique.	AI Act art. 50 ; recherche
Zero-trust	Architecture supposant qu'aucun composant n'est digne de confiance par défaut.	ANSSI ; NIST SP 800-207

Annexe B — Matrice de traçabilité exigences vs référentiels

La matrice ci-dessous cartographie les exigences de la politique (SIA-001 à SIA-172) vers les principaux référentiels normatifs et réglementaires. La traçabilité inverse (exigence → référentiel) est disponible dans le registre unifié de l'annexe C, colonne Référentiels sources de chaque fiche.

B.1 Couverture des 22 règles CLUSIF SIA-01 à SIA-22

Règle CLUSIF	Objet	Exigence(s) v3.0 couvrante(s)
SIA-01	Formation collaborateurs aux menaces	SIA-138, 139
SIA-02	Sensibilisation utilisateurs	SIA-137
SIA-03	Analyse de risque SIA	SIA-021, 022
SIA-04	Sécurité supply chain conception	SIA-024, 062
SIA-05	DevSecOps IA	SIA-026, 027, 028
SIA-06	Supply chain évaluée	SIA-062, 066, 067
SIA-07	Actifs IA sensibles	SIA-029, 033, 045, 060
SIA-08	Documentation modèles/datasets/prompts	SIA-029, 033, 054
SIA-09	Dette technique IA	SIA-030
SIA-10	Sécurité infrastructure	SIA-027, 039
SIA-11	Protection modèle accès direct/indirect	SIA-034, 041, 046, 070
SIA-12	Hachages et signatures modèles	SIA-034, 070
SIA-13	Plans réponse incidents	SIA-116, 117, 119
SIA-14	Évaluation avant publication	SIA-038, 039
SIA-15	Surveillance comportement	SIA-044, 046
SIA-16	Log entrées système	SIA-045, 060
SIA-17	Mises à jour sécurisées	SIA-043
SIA-18	Analyse risques NIST AI RMF	Annexe I ; SIA-005
SIA-19	Menaces MITRE ATLAS	SIA-116, 120, 121 ; Annexe L
SIA-20	Contrôle code généré IA	SIA-087, 088, 089, 091, 092
SIA-21	Interdictions code généré	SIA-086
SIA-22	Sensibilisation code généré	SIA-093, 094

B.2 Couverture des 14 chapitres OWASP AISVS 1.0

Chapitre AISVS	Objet	Exigences v3.0 principales
Ch. 1	Training Data Governance	SIA-031, 032, 049, 050, 054, 172
Ch. 2	Model Input Validation	SIA-051, 052
Ch. 3	Model Lifecycle	SIA-025, 029, 033, 034, 048, 171
Ch. 4	Secure Deployment	SIA-039, 040, 043

Chapitre AISVS	Objet	Exigences v3.0 principales
Ch. 5	Authentication & Access Control	SIA-161, 162, 163
Ch. 6	Supply Chain	SIA-062-072, 090
Ch. 7	Output Security	SIA-047, 053
Ch. 8	Data Security Pipeline	Ch. 8 entier (SIA-049-061)
Ch. 9	Runtime Protection	SIA-041, 042, 080, 083
Ch. 10	MCP Security	SIA-077, 164, 165, 166
Ch. 11	Threat Modeling	SIA-021, 084
Ch. 12	Privacy Preservation	SIA-167, 168, 169, 170
Ch. 13	Monitoring & Observability	SIA-044, 045, 046, 060
Ch. 14	Human Oversight	SIA-096-103

B.3 Couverture AI Act par article

Article AI Act	Objet	Exigences v3.0
Art. 4	Compétence IA (AI literacy)	SIA-136, 137, 138, 139, 140
Art. 5	Pratiques prohibées	SIA-002, 014
Art. 6, Annexe III	Classification haut risque	SIA-014, 016, 017
Art. 9	Système de gestion des risques	SIA-021, 022, 116
Art. 10	Données et gouvernance	Ch. 8 (SIA-049-061), SIA-031, 036
Art. 11 + Annexe IV	Documentation technique	SIA-029, 066 ; Annexe E
Art. 12	Journalisation automatique	SIA-045, 060, 079, 118
Art. 13	Transparence et information	SIA-104, 115
Art. 14	Surveillance humaine	SIA-081, 096-103
Art. 15	Exactitude, robustesse, cybersécurité	SIA-035, 036, 037, 038
Art. 26	Obligations des déployeurs	SIA-006, 085
Art. 27	AIIA	SIA-022
Art. 50	Transparence (chatbots, deepfakes, contenus synthétiques)	SIA-104, 105, 106
Art. 51-55	GPAI et GPAI systémique	SIA-112, 113, 114
Art. 73	Incidents graves	SIA-118
Art. 99	Sanctions	SIA-150

B.4 Autres référentiels majeurs

Référentiel	Exigences principales
ISO 42001 (AIMS)	SIA-004, 005, 006, 009, 012, 020, 030, 033, 132, 133, 154, 156
NIST AI RMF (Govern-Map-Measure-Manage)	SIA-004, 005, 011, 101, 123, 141, 154, 156 ; Annexe I
ISO 27090 (guidance menaces IA)	SIA-021, 023, 032, 039, 060, 116, 117, 120
MITRE ATLAS	SIA-046, 116, 120, 121 ; Annexe L
DORA (Règlement UE 2022/2554)	SIA-040, 062, 071, 072, 073, 116, 118, 119, 128, 134

Référentiel	Exigences principales
NIS2 (Directive UE 2022/2555)	SIA-116, 118, 119, 129
RGPD	SIA-022, 048, 052, 055, 056, 057, 058, 059, 103, 108, 131
HDS (hébergement santé)	SIA-057, 130, 144
CESIN Baromètre 2026	SIA-011, 107, 109-111, 115, 137, 141, 142, 143, 145, 148, 149
CLUSIF PSSI IA	Voir section B.1 ci-dessus

Annexe C — Registre unifié des exigences SIA-001 à SIA-172

Le présent registre consolide l'ensemble des exigences de la politique dans un format opérationnel exploitable par un outil GRC. Les énoncés complets, référentiels sources, contrôles testables et RACI détaillés sont disponibles dans les chapitres et annexes correspondants.

Réf	Libellé	Tier	Responsabl e	Fréq uenc e
SIA-001	Inventaire exhaustif des SIA	Tous tiers	DSI	Conti nue / trim.
SIA-002	Non-déploiement pratiques prohibées AI Act art. 5	Tous tiers	Chef projet	À l'initiat ion
SIA-003	Qualification IN/OUT de périmètre	Tous tiers	RSSI	À l'initiat ion
SIA-004	Comité IA formellement mandaté, mensuel	Gouvernance	Président CIA	Mens uelle
SIA-005	Validation Comité IA avant développement	Tous tiers	Chef projet	À l'initiat ion
SIA-006	Propriétaire métier nommément désigné	Tous tiers	Dir. métier	Annu elle
SIA-007	Droit de veto RSSI opposable	Tous tiers	RSSI	Annu elle
SIA-008	Droit de veto DPO opposable	Tous tiers	DPO	Annu elle
SIA-009	Model Steward et Data Steward L2-L3	AISVS L2-L3	DSI / Data Office	Annu elle
SIA-010	Registre des dérogations	Tous tiers	RSSI	Trime striell e
SIA-011	Budget dédié sécurité IA	Gouvernance	RSSI	Annu elle
SIA-012	Audit interne annuel IA	Gouvernance	Audit interne	Annu elle
SIA-013	Cellule de Crise IA activable	Gouvernance	RSSI	Seme striell e
SIA-014	Classification AI Act	Méta	DPO	Annu elle
SIA-015	Classification AISVS	Méta	RSSI	Annu elle
SIA-016	Matrice tiering 2D + règles d'élévation	Méta	RSSI	Annu elle
SIA-017	Propagation tier au cycle de vie	Méta	RSSI	Conti nue

Réf	Libellé	Tier	Responsabl e	Fréq uenc e
SIA-018	Re-classification sur événement	Tous tiers	RSSI	À événe ment
SIA-019	Publication tier dans le registre	Tous tiers	RSSI	À chaqu e classif .
SIA-020	Rapport annuel de tiering	Gouvernance	RSSI	Annu elle
SIA-021	Threat modeling formel (ISO 27090)	AISVS L1-L3	RSSI	À l'initiat ion
SIA-022	AIIA + AIPD coordonnées	AI Act HR ; L2-L3	DPO	À l'initiat ion
SIA-023	Architecture zero-trust IA	AISVS L2-L3	Archi sec	À la conce ption
SIA-024	Analyse make/buy/API	Tous tiers	Chef projet	À l'initiat ion
SIA-025	Sélection de modèle argumentée	Tous tiers	Model Steward	À la conce ption
SIA-026	Pratiques DevSecOps IA	AISVS L1-L3	Lead dev	Conti nue
SIA-027	Isolation environnements	Tous tiers	DSI	Conti nue
SIA-028	Gestion centralisée des secrets	Tous tiers	Lead dev	Conti nue
SIA-029	Model Card / Data Card / Risk Card	AISVS L2-L3	Model/Data Steward	Annu elle
SIA-030	Gestion de la dette technique IA	AISVS L2-L3	DSI	Trime striell e
SIA-031	Provenance et lineage des données	AISVS L2-L3	Data Steward	Conti nue
SIA-032	Détection d'empoisonnement des données	AISVS L2-L3	Data/Model Steward	Avt chq entr.
SIA-033	Versioning complet des composants	Tous tiers	Model Steward	Conti nue
SIA-034	Hachage / signature modèles et datasets	AISVS L2-L3 ; AI Act HR	DSI	Conti nue
SIA-035	Tests fonctionnels documentés	Tous tiers	Model Steward	Avt MEP
SIA-036	Tests de biais et de fairness	AI Act HR ; L2-L3	Model Steward	Avt MEP
SIA-037	Tests adversariaux	AISVS L2-L3	RSSI	Avt

Réf	Libellé	Tier	Responsabl e	Fréq uenc e
				MEP + trim.
SIA-038	Red teaming formel avant mise en production	AISVS L3 ; AI Act HR	RSSI	Avt MEP + trim.
SIA-039	Security Gate avant mise en production	Tous tiers	RSSI	Avt MEP
SIA-040	Plan de rollback (24h L2 / 4h L3)	AISVS L2-L3	DSI	Ann. L2 / Sem. L3
SIA-041	Kill switch pour L3 et haut risque	AISVS L3 ; AI Act HR	DSI	Seme striell e
SIA-042	Circuit breakers configurés	AISVS L2-L3	DSI	Trime striell e
SIA-043	Mises à jour sécurisées et canarisées	AISVS L2-L3	Model Steward	À chq MAJ
SIA-044	Drift monitoring continu	AISVS L2-L3	Model Steward	Mens uelle
SIA-045	Journalisation immuable des entrées	Tous tiers	DSI	Conti nue
SIA-046	Détection anomalies comportementales	AISVS L2-L3	RSSI	Conti nue
SIA-047	DLP sortant sur les sorties	AISVS L2-L3	RSSI	Conti nue
SIA-048	Retrait sécurisé et post-mortem	Tous tiers	Model Steward	À la décisi on
SIA-049	Inventaire des sources data-IA	Tous tiers	Data Steward	Conti nue
SIA-050	Classification datasets	Tous tiers	Data Steward	À l'intég ration
SIA-051	Filtrage des entrées	AISVS L1-L3	DSI	Conti nue
SIA-052	Masquage dynamique des PII	AISVS L2-L3 ; santé obl.	Data Steward	Conti nue
SIA-053	Scan post-génération sorties	AISVS L2-L3	RSSI	Conti nue
SIA-054	Data Card avec lineage	Tous tiers	Data Steward	À chaqu e ingest ion
SIA-055	Interdiction données adhérents SIA public	Tous tiers (impératif)	RSSI	Conti nue

Réf	Libellé	Tier	Responsabl e	Fréq uenc e
SIA-056	Minimisation des données	Tous tiers	DPO	Annu elle
SIA-057	Base légale et HDS pour données santé	Santé	DPO	Annu elle
SIA-058	Anonymisation / pseudonymisation par défaut	Tous tiers ; L3 impératif	Data Steward	Annu elle
SIA-059	Durées de conservation documentées	Tous tiers	DPO	Annu elle
SIA-060	Logs immuables pipeline data	AISVS L2-L3	DSI	Conti nue
SIA-061	Chiffrement embeddings sensibles	AISVS L2-L3	Data Steward	Seme striell e
SIA-062	Due diligence avant contractualisation	Tous tiers	Achats	À chq contra t
SIA-063	Certifications exigées (ISO 27001, HDS ; SecNumCloud rec. L3)	Selon tier	Achats	Annu elle
SIA-064	Hébergement France/UE	Données sensibles	DSI	Annu elle
SIA-065	Clause de non-rétroaction	Tous tiers	Juridique	Audit annue l
SIA-066	AI-BOM fournisseur	Tous tiers	RSSI	Annu elle
SIA-067	SBOM IA étendu aux composants ML	Tous tiers	DSI	À chq build
SIA-068	Scan quotidien vulnérabilités ML	Tous tiers	DSI	Conti nue
SIA-069	Conformité licences	Tous tiers	DSI	Annu elle
SIA-070	Scan des modèles tiers importés	Tous tiers	Model Steward	À chq import
SIA-071	Clause d'audit annuel	Fournisseurs critiques	Juridique	Annu elle
SIA-072	Exit strategy testée	Fournisseurs critiques	DSI	Bisan nuelle
SIA-073	Monitoring continu fournisseurs	Fournisseurs critiques	RSSI	Trime striell e
SIA-074	Qualification agentique, tier L2 minimum	Agentique	RSSI	Annu elle
SIA-075	AI-BOM agentique	Agentique	Model Steward	Trime striell e
SIA-076	Moindre privilège par outil	Agentique	RSSI	Seme striell e
SIA-077	Sécurité MCP (manifest signing, allowlist)	Agentique MCP	RSSI	Trime

Réf	Libellé	Tier	Responsabl e	Fréq uenc e
				striell e
SIA-078	Sandboxing des actions agentiques	Agentique	DSI	Seme striell e
SIA-079	Journalisation immuable des actions	Agentique	DSI	Conti nue
SIA-080	Kill switch agentique dédié	Agentique	DSI	Trime striell e
SIA-081	HITL niveau 4 pour actions à impact	Agentique	Propriétaire	Seme striell e
SIA-082	Interdictions d'actions autonomes (liste étendue)	Agentique (impératif)	RSSI	Seme striell e
SIA-083	Rate limiting et quotas	Agentique	DSI	Trime striell e
SIA-084	Tests spécifiques agents	Agentique	RSSI	Avt MEP + trim.
SIA-085	Chaîne de responsabilité formalisée	Agentique	Comité IA	Annu elle
SIA-086	Interdictions de périmètre gén. code	Tous (impératif)	RSSI	Seme striell e
SIA-087	Interdiction exécution automatique	Tous tiers	DSI	Conti nue
SIA-088	Interdiction commit automatique	Tous tiers	DSI	Conti nue
SIA-089	Pipeline de vérification automatisée	Tous tiers	Lead dev	Conti nue
SIA-090	Validation des dépendances référencées	Tous tiers	Lead dev	Conti nue
SIA-091	Revue humaine systématique	Tous tiers	Lead dev	Conti nue
SIA-092	Contrôle qualité code généré périodique	Tous tiers	Audit interne	Seme striell e
SIA-093	Formation développeurs (4h min)	Tous développeurs	DRH	Ini. + annue lle
SIA-094	Journalisation sollicitations code	Périmètres sensibles	DSI	Conti nue
SIA-095	Outils de génération approuvés	Tous développeurs	RSSI	Trime striell e
SIA-096	Positionnement HITL niveau 0-4	Tous tiers	Propriétaire	Annu

Réf	Libellé	Tier	Responsabl e	Fréq uenc e
				elle
SIA-097	Connaissance du système par superviseurs	AI Act HR ; L2-L3	Propriétaire	Ini. + annue lle
SIA-098	Interfaces et outils de supervision	AI Act HR ; L2-L3	DSI	Annu elle
SIA-099	Pouvoir effectif d'intervention	AI Act HR ; L2-L3	DSI / propriétaire	Seme striell e
SIA-100	Autorité effective du superviseur	AI Act HR ; L2-L3	DRH	Annu elle
SIA-101	Prévention du biais d'automation	AISVS L3 ; AI Act HR	Model Steward	Annu elle
SIA-102	Limitation temps d'exposition	Supervision volumétrique	Propriétaire	Conti nue
SIA-103	Droits art. 22 RGPD opérationnels	Décisions significatives	DPO	Annu elle
SIA-104	Information des interlocuteurs	SIA personnes	Propriétaire	Annu elle
SIA-105	Marquage des contenus synthétiques	SIA générant contenu	Model Steward	Seme striell e
SIA-106	Encadrement strict des deepfakes	Tous (impératif)	Juridique	Conti nue
SIA-107	Matrice d'usage GPAI publics	Tous (impératif)	RSSI	Annu elle
SIA-108	Interdiction absolue export adhérents GPAI	Tous (impératif)	RSSI	Conti nue
SIA-109	Dispositif de détection shadow AI	Gouvernance	RSSI	Trime striell e
SIA-110	Procédure traitement des cas shadow AI	Gouvernance	RSSI	Trime striell e
SIA-111	Alternatives souveraines aux GPAI publics	Gouvernance	DSI	Seme striell e
SIA-112	Obligations fournisseur GPAI interne	Fournisseur GPAI	Model Steward	Annu elle
SIA-113	Obligations GPAI systémique art. 55	GPAI systémique	RSSI	Seme striell e
SIA-114	Évaluation régulière risque GPAI	Gouvernance	RSSI	Seme striell e
SIA-115	Information parties prenantes	SIA impact externe	DPO	Annu elle
SIA-116	Dispositif détection incidents IA	Tous tiers	RSSI	Seme striell e

Réf	Libellé	Tier	Responsabl e	Fréq uenc e
SIA-117	Typologie des incidents IA	Tous tiers	RSSI	Annu elle
SIA-118	Matrice de notifications réglementaires	Tous (impératif)	RSSI	Seme striell e
SIA-119	Activation Cellule de Crise IA	Tous tiers	RSSI	Seme striell e
SIA-120	Red teaming trimestriel	L3 ; AI Act HR ; agentique	RSSI	Trime striell e
SIA-121	Purple teaming semestriel	L3 ; AI Act HR	RSSI	Seme striell e
SIA-122	Tabletop exercises IA	Gouvernance	RSSI	Seme striell e
SIA-123	Post-mortem obligatoire	Tous tiers	RSSI	À chq inc. M+
SIA-124	Partage CERT-FR et ISAC	Gouvernance	RSSI	Conti nue
SIA-125	Base de connaissance des incidents	Gouvernance	RSSI	Annu elle
SIA-126	Veille réglementaire IA	Gouvernance	Juridique	Trime striell e
SIA-127	Feuille de route conformité AI Act	Gouvernance	DPO	Seme striell e
SIA-128	Intégration DORA des SIA critiques	DORA critique	RSSI	Annu elle
SIA-129	Obligations NIS2	NIS2	RSSI	Annu elle
SIA-130	Hébergement HDS données santé	Santé (impératif)	DPO	Annu elle
SIA-131	Registre RGPD à jour	Tous tiers	DPO	Seme striell e
SIA-132	Feuille de route ISO 42001	Gouvernance	RSSI	Seme striell e
SIA-133	Audit externe annuel	Gouvernance	Audit interne	Annu elle
SIA-134	TLPT DORA	DORA critique	RSSI	≥ 3 ans
SIA-135	Reporting réglementaire piloté	Gouvernance	Juridique	Calen drier régul.
SIA-136	Plan annuel de formation	Gouvernance	DRH	Annu

Réf	Libellé	Tier	Responsabl e	Fréq uenc e
				elle
SIA-137	Sensibilisation obligatoire (1h)	Tous collaborateurs	DRH	Emb. + annue lle
SIA-138	Formation RSSI/DPO/DSI (16h)	Gouvernance	DRH	Annu elle
SIA-139	Formation développeurs (8h)	Développeurs IA	DRH/lead tech	Avt projet + an.
SIA-140	Formation superviseurs (4h)	Superviseurs HITL	Propriétaire	Avt sup. + an.
SIA-141	Communications régulières	Gouvernance	RSSI	Mens uelle min.
SIA-142	Évaluation maturité annuelle	Gouvernance	RSSI	Annu elle
SIA-143	Position stratégique souveraineté	Gouvernance	DG	Annu elle
SIA-144	Hébergement souverain données sensibles	Sensible	DSI	Annu elle
SIA-145	Priorité éditeurs européens	Tous tiers	Achats	Annu elle
SIA-146	Clauses contractuelles types	Tous contrats IA	Juridique	Annu elle
SIA-147	Plan de réversibilité	Fournisseurs critiques	DSI	Bisan nuelle
SIA-148	Suivi risques extraterritoriaux	Gouvernance	Juridique	Seme striell e
SIA-149	Participation écosystèmes souveraineté	Gouvernance	RSSI	Annu elle
SIA-150	Grille de sanctions graduée	Tous collaborateurs	DRH	Annu elle
SIA-151	Procédure disciplinaire conforme	Gouvernance	DRH	Conti nue
SIA-152	Articulation obligations pénales/civiles	Tous tiers	Juridique	Au cas par cas
SIA-153	Communication cas anonymisés pédagogiques	Gouvernance	RSSI	Bilan annue l
SIA-154	Revue annuelle de la politique	Gouvernance	RSSI	Annu elle
SIA-155	Revue d'urgence sur événement	Gouvernance	RSSI	À évène ment
SIA-156	Indicateurs de performance (KPI)	Gouvernance	RSSI	Mens.

Réf	Libellé	Tier	Responsabl e	Fréq uenc e
				/trim.
SIA-157	Tableau de bord pilotage	Gouvernance	RSSI	Conti nue
SIA-158	Retour d'expérience des incidents	Gouvernance	RSSI	À chq inc. sign.
SIA-159	Benchmark externe	Gouvernance	RSSI	Annu elle
SIA-160	Processus d'évolution de la politique	Gouvernance	RSSI	Conti nue
SIA-161	[P2] Authentification appels modèles	AISVS L2-L3	DSI	Trime striell e
SIA-162	[P2] Rotation automatique secrets IA	AISVS L2-L3	DSI	Seme striell e
SIA-163	[P2] RBAC granulaire outils agentiques	Agentique	RSSI	Seme striell e
SIA-164	[P2] MCP manifest signing	Agentique MCP	RSSI	Conti nue
SIA-165	[P2] MCP server allowlist et revocation	Agentique MCP	RSSI	Trime striell e
SIA-166	[P2] Scope least privilege outils MCP	Agentique MCP	RSSI	Annu elle
SIA-167	[P2] Differential privacy datasets sensibles	L3 ; RGPD art. 9	Data Steward	À chq entr.
SIA-168	[P2] Federated learning multi-sources	Cas multi-entités	Data Steward	À l'étud e
SIA-169	[P2] Homomorphic encryption cas critiques	L3 cas critique	Data Steward	À l'étud e
SIA-170	[P2] Secure multi-party computation	Inter-entités	Data Steward	À l'étud e
SIA-171	[P2] Watermarking modèles propriétaires	L3 ; modèles valeur	Model Steward	À l'entra î. + sem.
SIA-172	[P2] Canary tokens datasets sensibles	AISVS L2-L3	Data Steward	À chq datas et

Annexe D — RACI détaillé par processus IA

La matrice ci-dessous détaille les responsabilités par processus clé de la gouvernance IA du Groupe. Légende : R = Responsable (exécute) ; A = Approbateur (décide) ; C = Consulté (avis) ; I = Informé.

Processus	D G	R S SI	D P O	D SI	Model Steward	Data Steward	Comité IA	Au dit
Qualification d'un nouveau SIA	I	C	A	C	—	—	A	I
Classification tier AI Act × AISVS	—	A	C	C	C	C	A	I
Validation de mise en production	—	A	A	C	R	C	A	I
Threat modeling et analyse risques	—	R	C	C	C	—	I	I
AIIA et AIPD	I	C	R	C	C	C	A	I
Red teaming et purple teaming	I	R	I	C	C	—	I	I
Gestion d'incident IA critique	A	R	C	C	C	C	I	I
Notification réglementaire incident	A	R	C	I	—	—	I	I
Due diligence fournisseur IA	—	A	C	C	C	—	I	I
Contractualisation (clauses types)	—	C	C	C	—	—	I	—
Monitoring drift et dérive	—	C	—	C	R	C	I	I
Revue annuelle de la politique	A	R	C	C	—	—	C	C
Audit interne IA	I	C	C	C	C	C	C	R
Formation et sensibilisation	I	C	C	I	I	I	I	I
Gestion des dérogations	—	R	C	I	—	—	A	I

Note : Pour chaque SIA, la RACI est complétée par le propriétaire métier (Responsable ultime de la finalité) et par le manager opérationnel (Responsable de la conduite au quotidien). Cette RACI macro est affinée au cas par cas dans les fiches projet.

Annexe E — Templates

Les templates ci-dessous sont fournis à titre de cadre minimal. Les champs obligatoires sont adaptés au tier du SIA. Les templates complets exploitables en production sont tenus à jour par le RSSI dans un espace de référence partagé.

E.1 Model Card

Champ	Description
Nom du modèle	Identifiant unique cohérent avec le registre central SIA-001
Version	Version sémantique (MAJOR.MINOR.PATCH)
Date d'émission	Date de publication de la fiche
Propriétaire	Model Steward nommé désigné (SIA-009)
Finalité déclarée	Description fonctionnelle précise et limitative
Architecture	Type de modèle, nombre de paramètres, framework
Données d'entraînement	Synthèse ; renvoi à la Data Card détaillée
Métriques de performance	Valeurs et jeux de test associés
Tests de biais	Résultats fairness et mitigations appliquées
Limites connues	Cas d'usage non supportés, régimes de défaillance
Risques identifiés	Renvoi à la Risk Card détaillée
Hachage / signature	Empreintes cryptographiques du modèle déployé (SIA-034)
Tier AI Act × AISVS	Positionnement dans la matrice du ch. 6
Date de la prochaine revue	Selon SIA-029

E.2 Data Card

Champ	Description
Nom du dataset	Identifiant unique
Version	Version et date de production
Propriétaire	Data Steward nommé désigné
Source(s) primaire(s)	Origine des données avec licence applicable
Taille et structure	Volumétrie, schéma, formats
Classification	Public / Interne / Confidentiel / Secret (voir ch. 17) et typologie RGPD
Période couverte	Dates de collecte et fraîcheur
Représentativité	Couverture statistique, populations couvertes
Biais connus	Limitations et impacts potentiels
Transformations appliquées	Preprocessing, anonymisation, pseudonymisation
Base légale	RGPD art. 6 et, si applicable, art. 9 ou art. 10
Durée de conservation	Selon SIA-059
Hachage	Empreinte cryptographique (SIA-034)
Usages autorisés / proscrits	Cas d'usage validés et exclusions

E.3 Risk Card

Champ	Description
Identifiant du risque	Référence unique
SIA concerné	Renvoi au registre central
Catégorie	Biais, privacy, sécurité, conformité, sûreté, impact social
Description	Nature et contexte du risque
Impact potentiel	Évaluation qualitative et quantitative si possible
Probabilité	Très faible / faible / moyenne / élevée / très élevée
Parties affectées	Adhérents, collaborateurs, tiers, Groupe
Mesures d'atténuation	Contrôles techniques et organisationnels mis en place
Risque résiduel	Niveau après atténuation
Acceptation	Validation formelle (Comité IA, Comité des Risques)
Date de la prochaine revue	Selon criticité

Annexe F — Checklists OWASP AISVS par niveau

Les checklists ci-dessous synthétisent les contrôles essentiels par niveau AISVS. Elles constituent un outil opérationnel de vérification rapide et renvoient aux exigences détaillées dans le corps de la politique.

F.1 AISVS Level 1 — Baseline

- Inventaire des SIA à jour dans le registre central (SIA-001).
- Qualification AI Act documentée (SIA-014).
- Qualification AISVS documentée (SIA-015).
- Propriétaire métier désigné (SIA-006).
- Logging des accès et opérations IA (SIA-045).
- Contrôles d'accès de base RBAC (SIA-161 en P2).
- Gestion de vulnérabilités dépendances (SIA-068).
- Clauses contractuelles minimales si fournisseur externe (SIA-065, 146).
- Sensibilisation utilisateurs effectuée (SIA-137).
- Filtrage basique des entrées (SIA-051).

F.2 AISVS Level 2 — Standard

- Ensemble des contrôles Level 1.
- Model Card et Risk Card produites et à jour (SIA-029).
- Data Card avec lineage (SIA-054).
- TEVV complet avant mise en production (SIA-035, 036, 037).
- DLP sur pipeline data (SIA-047, 053).
- RBAC granulaire (SIA-163).
- Supervision humaine selon niveau HITL (SIA-096 à 099).
- Drift monitoring continu (SIA-044).
- Rollback testé (SIA-040, SLA 24h).
- Red teaming trimestriel (SIA-120).
- Signatures cryptographiques modèles et datasets (SIA-034).
- Gestion de la dette technique IA (SIA-030).

F.3 AISVS Level 3 — Advanced

- Ensemble des contrôles Level 1 et Level 2.
- Red teaming formel avant mise en production et trimestriel en exploitation (SIA-038, 120).
- Purple teaming semestriel (SIA-121).
- Audit indépendant annuel (SIA-133).
- Kill switch testé semestriellement (SIA-041).

- Circuit breakers configurés et monitorés (SIA-042).
- Rollback testé semestriellement (SIA-040, SLA 4h).
- MCP security complète (SIA-077, 164, 165, 166).
- Agentic action security (SIA-074 à 085 pour les agents).
- Hébergement SecNumCloud recommandé (SIA-144).
- HITL niveau 4 pour actions à impact personnes (SIA-081).
- Differential privacy pour datasets très sensibles (SIA-167).
- Watermarking des modèles de forte valeur (SIA-171).
- Canary tokens dans les datasets critiques (SIA-172).

Annexe G — Matrice décisionnelle de tiering

La matrice ci-dessous consolide la règle de décision du chapitre 6. Elle croise la qualification AI Act (axe vertical) et la posture AISVS (axe horizontal). Chaque cellule indique le socle minimal de contrôles à appliquer.

AI Act ↓ / AISVS →	L1 Baseline	L2 Standard	L3 Advanced
Pratiques prohibées	Interdit	Interdit	Interdit
Haut risque	Élevé à L2 automatique (SIA-016)	Socle complet AI Act + AISVS L2	Socle complet + contrôles avancés
GPAI systémique	Élevé à L2 minimum	Socle AI Act art. 55 + AISVS L2	Socle AI Act art. 55 + AISVS L3
GPAI	Socle allégé + art. 53	Socle AI Act art. 53 + AISVS L2	Socle AI Act art. 53 + AISVS L3
Risque limité (art. 50)	Baseline + transparence	Baseline + transparence + AISVS L2	Socle complet + transparence
Risque minimal	Baseline	AISVS L2	AISVS L3

G.1 Règles d'élévation automatique

- Tout SIA AI Act haut risque est au minimum AISVS L2.
- Tout SIA traitant des données de santé adhérents est au minimum AISVS L3.
- Tout SIA traitant des données financières adhérents est au minimum AISVS L3.
- Tout SIA agentique au sens du chapitre 10 est au minimum AISVS L2.
- Tout SIA faisant intervenir un GPAI à risque systémique est au minimum AISVS L2.

G.2 Procédure de reclassification

La reclassification d'un SIA est réalisée selon SIA-018 sur événement déclencheur : changement de finalité, extension de périmètre ou de données, incident majeur, évolution réglementaire, modification substantielle. Le registre central est mis à jour, les parties prenantes notifiées, les contrôles propagés.

Annexe H — Playbook de gestion d'incident IA

Le playbook ci-dessous cadre la conduite opérationnelle d'un incident IA. Il est décliné en procédures détaillées par typologie d'incident dans les espaces RSSI dédiés.

H.1 Phases de traitement

Phase	Objectif	Acteurs	Livrable
T0 Détection	Identifier l'incident et sa gravité initiale	SOC / superviseur / utilisateur	Ticket d'alerte qualifié
T1 Qualification	Évaluer la typologie et le niveau de gravité	RSSI + Model Steward	Fiche de qualification
T2 Mobilisation	Activer l'équipe d'intervention adaptée au niveau	RSSI + Cellule de Crise si Critique/Majeur	Activation formalisée
T3 Confinement	Limiter les effets : kill switch, circuit breaker, rollback, isolation réseau	DSI + RSSI	Actions tracées
T4 Éradication	Identifier et supprimer la cause racine	RSSI + Model Steward + DSI	Rapport technique
T5 Restauration	Remettre en service de manière contrôlée, monitoring renforcé	DSI + Model Steward	Validation propriétaire métier
T6 Notifications	Notifier les autorités et parties prenantes selon les délais	RSSI + Juridique + DPO + Communication	Accusés de réception
T7 Post-mortem	Analyse des causes racines, enseignements	RSSI + équipe concernée	Rapport post-mortem (SIA-123)
T8 Amélioration	Intégrer les enseignements dans les procédures et la politique	RSSI	Mises à jour documentaires (SIA-158)

H.2 Arbre de décision simplifié

- Incident confirmé ? Non → classer « Information » et archiver. Oui → continuer.
- Impact personnes identifié ? Oui → notifier DPO immédiatement.
- Impact données personnelles (fuite, altération) ? Oui → activer procédure RGPD art. 33, délai 72h CNIL.
- Impact fonction ICT critique DORA ? Oui → activer procédure DORA, délai selon RTS.
- Entité NIS2 concernée ? Oui → activer procédure NIS2, pré-notification 24h.
- Incident grave SIA haut risque AI Act ? Oui → notification dans les 15 jours à l'autorité nationale.
- GPAI systémique concerné ? Oui → notification sans délai à l'AI Office.

Annexe I — Déclinaison NIST AI RMF (Govern-Map-Measure-Manage)

Le NIST AI Risk Management Framework 1.0 articule la gestion des risques IA autour de quatre fonctions. La présente annexe restitue comment la politique v3.0 met en œuvre chaque fonction.

I.1 Govern

Culture, processus et documentation permettant d'anticiper et de gérer les risques IA à l'échelle du Groupe.

- Instances de gouvernance (Comité des Risques, Comité IA, Comité d'Éthique, Cellule de Crise) : SIA-004, 013.
- RACI et propriétaires : SIA-006, 009 ; Annexe D.
- Politique opposable, droits de veto RSSI/DPO : SIA-007, 008.
- Dérogations tracées : SIA-010.
- Budget dédié : SIA-011.
- Audit interne annuel : SIA-012.
- Revue annuelle et d'urgence : SIA-154, 155, 160.

I.2 Map

Établissement du contexte permettant d'encadrer les risques d'un SIA donné.

- Qualification d'un SIA : SIA-001, 003.
- Classification AI Act et AISVS : SIA-014, 015, 016.
- Threat modeling : SIA-021.
- AIIA et AIPD : SIA-022.
- Sélection de modèle argumentée : SIA-025.
- Data Cards et provenance : SIA-031, 054.
- AI-BOM et SBOM IA : SIA-066, 067.

I.3 Measure

Outils, techniques et méthodologies pour analyser, évaluer et surveiller les risques.

- Tests fonctionnels, biais, adversariaux : SIA-035, 036, 037.
- Red teaming et purple teaming : SIA-038, 120, 121.
- Drift monitoring : SIA-044.
- Détection anomalies : SIA-046.
- Indicateurs de performance KPI : SIA-156, 157.
- Évaluation maturité annuelle : SIA-142.
- Base de menaces MITRE ATLAS : SIA-116, 120 ; Annexe L.

I.4 Manage

Allocation des ressources, priorisation, traitement des risques mesurés et cartographiés.

- Gestion des incidents et notifications : SIA-116 à 125.
- Cellule de Crise IA : SIA-119.
- Post-mortem et lessons learned : SIA-123, 125, 158.
- Gestion de la dette technique IA : SIA-030.
- Mises à jour sécurisées : SIA-043.
- Retrait sécurisé : SIA-048.
- Feuille de route conformité AI Act : SIA-127.

Annexe J — Conformité sectorielle complémentaire

La présente annexe, à caractère informatif, rappelle deux cadres sectoriels qui peuvent concerner les SIA du Groupe selon son périmètre d'activité. Elle ne crée pas d'exigences supplémentaires mais signale les obligations à intégrer lors de projets relevant de ces cadres.

J.1 Solvabilité II — Article 41 et gouvernance des modèles actuariels

Pour les entités du Groupe exerçant une activité d'assurance soumise à la directive Solvabilité II, l'article 41 impose un système de gouvernance garantissant une gestion saine et prudente de l'activité. Lorsqu'un SIA intervient dans la tarification, le provisionnement, la souscription, la détection de fraude ou la gestion actif-passif, les obligations suivantes se superposent à la politique v3.0 :

- Système de gouvernance des modèles actuariels documenté, intégrant les SIA comme catégorie spécifique.
- Fonction actuarielle informée et associée aux décisions structurantes sur les SIA actuariels.
- Opinion formelle de la fonction actuarielle sur les risques portés par les SIA sous sa supervision.
- Reporting ACPR pilier 2 (ORSA) intégrant les risques IA matériels.
- Interdiction de génération de code par IA pour les modules actuariels étendue au sens de SIA-086.

J.2 EHDS — Espace européen des données de santé

Le règlement européen sur l'espace européen des données de santé (EHDS) institue un cadre d'usage primaire et secondaire des données de santé. Pour les SIA santé du Groupe, les points d'attention suivants sont à surveiller :

- Obligation de mise à disposition, pour l'usage secondaire, des données de santé détenues par les organismes de protection sociale, selon des modalités à définir par actes délégués.
- Portabilité des données pour les personnes entre professionnels de santé et organismes.
- Articulation avec les obligations HDS françaises et avec le RGPD.
- Vigilance sur le cadre futur de l'accès secondaire aux données pour entraînement de SIA, en particulier pour la recherche publique et privée.

Le dispositif de veille réglementaire (SIA-126) intègre l'EHDS et ses évolutions, et la politique v3.0 sera mise à jour lors de l'adoption d'actes délégués structurants.

Annexe K — Contrôles avancés (priorité P2)

La présente annexe regroupe douze exigences complémentaires de priorité P2, constitutives d'une posture de sécurité avancée. Ces exigences ne sont pas obligatoires pour toutes les tiers mais sont recommandées et applicables selon les niveaux définis dans chaque fiche. Le gabarit d'exigence unifié est utilisé au même titre que dans le corps.

K.1 Authentification et gestion des secrets IA

Identifiant	SIA-161
Exigence	Les appels aux modèles IA — qu'ils soient internes ou consommés via API externe — doivent être authentifiés par des mécanismes robustes : clés API à haute entropie, OAuth 2.0 avec scopes restreints, ou mTLS pour les communications serveur-serveur. L'authentification anonyme est interdite en production.
Référentiels sources	OWASP AISVS Ch. 5 ; OAuth 2.0 RFC 6749 ; ANSSI
Contrôle testable / preuve	Configuration documentée par service ; scan des endpoints non authentifiés ; revue trimestrielle.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Audit interne
Fréquence de revue	Continue ; revue trimestrielle

Identifiant	SIA-162
Exigence	Les secrets associés aux SIA (clés API, tokens, mots de passe techniques, certificats) doivent être gérés dans un coffre-fort centralisé avec rotation automatique périodique : 90 jours maximum pour les clés API, 30 jours pour les tokens d'accès long-lived, à expiration pour les tokens court-lived.
Référentiels sources	OWASP AISVS Ch. 5 ; ISO 27001 §8.24
Contrôle testable / preuve	Coffre-fort en place ; politique de rotation configurée ; incidents de rotation manquée loggés.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : DSI — Consulté : RSSI — Informé : Audit interne
Fréquence de revue	Continue ; audit semestriel

Identifiant	SIA-163
Exigence	Les outils exposés aux agents (voir ch. 10) doivent être protégés par un RBAC granulaire au niveau de chaque action : un agent ne peut invoquer un outil que si la permission correspondante est explicitement accordée dans son profil, avec contrôle à chaque appel et pas seulement à l'initialisation.
Référentiels sources	OWASP Agentic Security ; OWASP AISVS Ch. 5 et 9

Contrôle testable / preuve	Matrice de permissions par agent × outil publiée ; logs d'autorisation ; tests d'abus.
Tier applicable (AI Act × AISVS)	Agentique — tous tiers
Rôle RACI	Responsable : RSSI — Consulté : Model Steward — Informé : DSI
Fréquence de revue	Continue ; audit semestriel

K.2 Model Context Protocol avancé

Identifiant	SIA-164
Exigence	Les manifests MCP décrivant les outils et leurs scopes doivent être signés cryptographiquement par l'émetteur avec un algorithme au moins équivalent à Ed25519, la signature étant vérifiée avant toute utilisation. Les manifests non signés ou à signature invalide sont rejetés.
Référentiels sources	OWASP AISVS Ch. 10 ; ANSSI guides cryptographiques
Contrôle testable / preuve	Vérification automatique au chargement ; journal des rejets ; algorithme documenté.
Tier applicable (AI Act × AISVS)	Agentique utilisant MCP
Rôle RACI	Responsable : RSSI — Consulté : DSI, Model Steward — Informé : Audit interne
Fréquence de revue	Continue

Identifiant	SIA-165
Exigence	Seuls les serveurs MCP figurant explicitement sur une allowlist approuvée peuvent être utilisés par les agents du Groupe. La liste est tenue par le RSSI, révisée trimestriellement, et comporte pour chaque serveur : finalité, propriétaire, scopes autorisés, date d'expiration de l'autorisation. La révocation est immédiate sur décision RSSI.
Référentiels sources	OWASP AISVS Ch. 10 ; ANSSI
Contrôle testable / preuve	Allowlist MCP publiée et à jour ; blocage technique des serveurs hors allowlist ; revue trimestrielle.
Tier applicable (AI Act × AISVS)	Agentique utilisant MCP
Rôle RACI	Responsable : RSSI — Consulté : Model Steward — Informé : Comité IA
Fréquence de revue	Trimestrielle

Identifiant	SIA-166
Exigence	Les scopes déclarés par les serveurs MCP doivent être minimaux et explicites : pas de scope agrégé (read_everything, admin_full), décomposition par ressource et par action. Les scopes excessifs font l'objet

	d'une demande de réduction auprès du fournisseur ou, à défaut, d'un refus d'ajout à l'allowlist.
Référentiels sources	OWASP AISVS Ch. 10 ; ISO 27001 §8.3
Contrôle testable / preuve	Revue de scopes documentée avant ajout à l'allowlist ; journal des refus.
Tier applicable (AI Act × AISVS)	Agentique utilisant MCP
Rôle RACI	Responsable : RSSI — Consulté : Model Steward — Informé : Audit interne
Fréquence de revue	À chaque ajout ; revue annuelle

K.3 Privacy-enhancing technologies

Identifiant	SIA-167
Exigence	Lorsque l'entraînement ou l'évaluation d'un SIA implique des datasets à forte sensibilité (santé, financier adhérent) et que l'anonymisation pleine n'est pas possible sans perte d'utilité, la confidentialité différentielle doit être appliquée avec un paramètre epsilon documenté et justifié, accompagnée d'une évaluation de l'utilité résiduelle du modèle.
Référentiels sources	NIST SP 800-226 ; OWASP AISVS Ch. 12 ; CNIL anonymisation
Contrôle testable / preuve	Paramètres epsilon documentés ; évaluation utilité vs privacy ; validation DPO.
Tier applicable (AI Act × AISVS)	AISVS L3 ; données RGPD art. 9
Rôle RACI	Responsable : Data Steward — Consulté : DPO — Informé : RSSI
Fréquence de revue	À chaque entraînement concerné

Identifiant	SIA-168
Exigence	Lorsque la mutualisation de données entre entités nécessite un entraînement IA mais sans transfert effectif des données, la technique du federated learning devrait être évaluée comme alternative au transfert centralisé, avec analyse de risques spécifique (fuite via gradients, inversion de modèle).
Référentiels sources	OWASP AISVS Ch. 12 ; RGPD ; CNIL
Contrôle testable / preuve	Analyse de faisabilité documentée ; AIPD si mise en œuvre ; évaluation des fuites via gradients.
Tier applicable (AI Act × AISVS)	Cas d'usage multi-entités
Rôle RACI	Responsable : Data Steward — Consulté : RSSI, DPO — Informé : Comité IA
Fréquence de revue	À l'étude de cas d'usage

Identifiant	SIA-169
Exigence	Pour les cas d'usage critiques où le modèle doit inférer sur des données que le fournisseur du modèle ne doit pas voir (par exemple calcul actuariel partagé), l'homomorphic encryption devrait être évaluée. Son coût computationnel et ses limitations fonctionnelles doivent être explicités et arbitrés.
Référentiels sources	OWASP AISVS Ch. 12 ; NIST
Contrôle testable / preuve	Étude comparée sécurité / coût / performance ; décision motivée archivée.
Tier applicable (AI Act × AISVS)	AISVS L3 — cas d'usage critique
Rôle RACI	Responsable : Data Steward — Consulté : RSSI, architecte — Informé : Comité IA
Fréquence de revue	À l'étude de cas d'usage

Identifiant	SIA-170
Exigence	Le secure multi-party computation devrait être évalué pour les calculs IA collaboratifs entre entités concurrentes ou mutuellement défiantes (par exemple benchmark sectoriel, calcul de risques agrégés) où les données ne peuvent être centralisées. La maturité de l'outillage et la cohérence avec l'audit doivent être vérifiées.
Référentiels sources	OWASP AISVS Ch. 12 ; recherche académique
Contrôle testable / preuve	Étude de maturité ; décision motivée ; accord des parties prenantes.
Tier applicable (AI Act × AISVS)	Cas d'usage inter-entités
Rôle RACI	Responsable : Data Steward — Consulté : RSSI, Juridique — Informé : Comité IA
Fréquence de revue	À l'étude de cas d'usage

K.4 Protection du patrimoine modèles et datasets

Identifiant	SIA-171
Exigence	Les modèles propriétaires du Groupe présentant une valeur significative en propriété intellectuelle ou une sensibilité particulière devraient intégrer un dispositif de watermarking robuste, permettant la détection d'une exfiltration par interrogation massive ou par accès direct aux poids.
Référentiels sources	OWASP AISVS Ch. 3 ; recherche académique ML watermarking
Contrôle testable / preuve	Dispositif de watermarking déployé ; vérification périodique d'efficacité ; tests de détection.
Tier applicable (AI Act × AISVS)	AISVS L3 ; modèles propriétaires à forte valeur

Rôle RACI	Responsable : Model Steward — Consulté : RSSI, Juridique — Informé : Comité IA
Fréquence de revue	À l'entraînement + audit semestriel

Identifiant	SIA-172
Exigence	Les datasets sensibles utilisés en entraînement devraient intégrer des canary tokens — enregistrements synthétiques uniques conçus pour détecter une fuite — dont la présence dans des sorties de modèles ou dans des fuites externes constitue un indicateur d'incident. La gestion des canaries est confidentielle.
Référentiels sources	OWASP AISVS Ch. 1 ; recherche académique data canaries
Contrôle testable / preuve	Canaries générés et documentés confidentiellement ; mécanisme de détection en place ; alertes SOC.
Tier applicable (AI Act × AISVS)	AISVS L2-L3
Rôle RACI	Responsable : Data Steward — Consulté : RSSI, SOC — Informé : Comité IA (confidentiel)
Fréquence de revue	À chaque dataset majeur

Annexe L — Taxonomie MITRE ATLAS et scénarios types

Le MITRE ATLAS (Adversarial Threat Landscape for Artificial-Intelligence Systems) est la taxonomie de référence retenue par la politique (SIA-019) pour la modélisation des menaces, le red teaming et la détection. Le tableau ci-dessous présente une sélection de TTPs emblématiques pour le secteur de la protection sociale. La liste complète et actualisée est consultable sur atlas.mitre.org.

Référence	Technique	Description	Mitigations principales
AML.T0000	Reconnaissance	Cartographie des SIA et de leur surface d'attaque	Limitation des informations publiques ; honeypots
AML.T0020	Poisoning des données d'entraînement	Insertion de données malveillantes dans le pipeline	Provenance ; détection statistique ; validation
AML.T0040	Injection de données adversariales	Envoi de prompts ou d'entrées malveillants	Input filtering ; rate limiting
AML.T0043	Craft adversarial data	Construction d'entrées spécifiquement conçues pour tromper	Adversarial training ; robustness testing
AML.T0051	LLM Prompt Injection	Insertion d'instructions dans le prompt utilisateur ou le contexte	Validation ; prompts système isolés ; DLP sortant
AML.T0053	Jailbreak du LLM	Contournement des garde-fous du modèle	Garde-fous multi-couches ; red teaming
AML.T0055	Membership inference	Inférence de l'appartenance d'une donnée au jeu d'entraînement	Differential privacy ; rate limiting
AML.T0057	Modèle inversion	Reconstruction de données d'entraînement depuis les sorties	Output filtering ; differential privacy
AML.T0059	Évasion du modèle	Construction d'entrées éludant la classification	Adversarial training ; détection anomalies
AML.T0061	Extraction du modèle	Vol du modèle par interrogation massive	Rate limiting ; watermarking ; API monitoring
AML.T0062	Supply chain compromise	Altération dans la chaîne d'approvisionnement (modèles, datasets)	AI-BOM ; signatures ; isolation
AML.T0064	Reward hacking	Exploitation de la fonction de récompense en RL	Alignement ; revue humaine
AML.T0065	External harms	Effets indirects sur le monde réel via le SIA	HITL ; interdictions de périmètre (SIA-082)

Pour le secteur de la protection sociale, les scénarios d'attaque les plus sensibles identifiés sont : l'exfiltration de données de santé ou financières via requêtes à un SIA de traitement, l'empoisonnement ciblé des données de fraude pour induire des décisions erronées, la compromission d'un agent de service client conduisant à la divulgation non autorisée, et les deepfakes utilisés dans des processus de souscription ou de résiliation.

Annexe M — Bibliographie normative et sources publiques

La bibliographie ci-dessous liste les sources publiques utilisées pour l'élaboration de la présente politique. Elle n'est pas exhaustive et est mise à jour à chaque revue annuelle.

M.1 Textes réglementaires européens

- Règlement (UE) 2024/1689 du 13 juin 2024 établissant des règles harmonisées concernant l'intelligence artificielle (AI Act).
- Règlement (UE) 2016/679 du 27 avril 2016 (RGPD).
- Règlement (UE) 2022/2554 du 14 décembre 2022 (DORA).
- Directive (UE) 2022/2555 du 14 décembre 2022 (NIS2).
- Directive 2009/138/CE du 25 novembre 2009 (Solvabilité II).
- Règlement européen sur l'espace européen des données de santé (EHDS).

M.2 Textes réglementaires français

- Code de la santé publique, notamment L.1111-8 (hébergement données de santé).
- Code du travail, livre III, titre III (sanctions disciplinaires).
- Référentiel HDS (Hébergeur de Données de Santé) — ANS.
- Référentiel SecNumCloud — ANSSI.

M.3 Normes et standards techniques

- ISO/IEC 42001:2023 — Information technology — Artificial intelligence — Management system.
- ISO/IEC 27001:2022 — Information security management systems.
- ISO/IEC 27701:2019 — Privacy information management.
- ISO/IEC DIS 27090 — Guidance on addressing security threats to AI systems.
- ISO/IEC 29119-11 — Testing of AI-based systems (en développement).
- ETSI prEN 304 223 — Cybersecurity of AI (en développement).
- prEN 18282 — CEN-CENELEC JTC 21 (en développement).
- NIST AI Risk Management Framework 1.0 (2023).
- NIST AI 100-2e2023 — Adversarial Machine Learning: A Taxonomy and Terminology.
- NIST SP 800-207 — Zero Trust Architecture.
- NIST SP 800-226 — Guidelines for Evaluating Differential Privacy.

M.4 Référentiels professionnels et guides

- OWASP Top 10 for Large Language Model Applications (2025).
- OWASP Agentic Security Initiative.

- OWASP GenAI Data Security Risks and Mitigations (2026).
- OWASP AI Security Verification Standard (AISVS) 1.0.
- MITRE ATLAS — Adversarial Threat Landscape for AI Systems — atlas.mitre.org.
- MIT AI Risk Repository.
- CLUSIF — Modèle de Politique de Sécurité des Systèmes d'Information (PSSI) pour l'Intelligence artificielle (février 2025).
- CESIN — Baromètre annuel de la cybersécurité des entreprises françaises (éditions 2024 à 2026).
- ANSSI — Guides et recommandations sur la sécurité des systèmes d'IA.
- ANSSI — Recommandation R34 sur la classification des données et l'usage des services tiers.
- CNIL — Recommandations relatives à l'IA, l'anonymisation, les décisions automatisées (RGPD art. 22).
- ENISA — Publications sur la sécurité de la chaîne d'approvisionnement et des systèmes d'IA.
- ACPR — Recommandations sur la résilience opérationnelle numérique et l'IA dans l'assurance.
- EIOPA — Publications sur l'usage de l'IA en assurance.

M.5 Références complémentaires

- Documentation publique Google sur les Model Cards (Model Cards for Model Reporting).
- Documentation publique Google sur les Data Cards.
- CISA — SBOM best practices.
- OpenSSF — Supply chain security.
- Gaia-X — Documents de référence sur l'infrastructure de données européenne.

Approbation

La présente politique est approuvée par les signataires suivants et entre en vigueur à compter de la date indiquée.

Rôle	Nom	Date	Signature
Directeur Général			
Directeur des Risques			
RSSI			
DPO			
DSI			
Directeur Juridique			

Date d'entrée en vigueur	[JJ/MM/AAAA]
Prochaine révision programmée	[JJ/MM/AAAA]
Version	3.0
Classification	CONFIDENTIEL — Diffusion interne